Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности
Направление подготовки (специальность) 10.05.03 «Информационная безопасность автоматизированных систем»
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Атапина Максима Дмитриевича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы сканирования портов»

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 245 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (Р.С. Лопатин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ М.Д. Атапин
(подпись) (инициалы, фамилия)

«02» июля 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Атапину Максиму Дмитриевичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы сканирования портов»

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.2025

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Глава 1. Исследование баз данных и актуальных риск-калькуляторов
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Глава 2. Установление взаимосвязей между CAPEC-шаблонами атак и эксплуатируемыми уязвимостями

Глава 3. Формирование сценариев заданных шаблонов атаки в виде последовательности реализации техник MITRE ATT&CK

Глава 4. Разработка организационно-правовых регламентов для заданных шаблонов атак CAPEC

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 – 22.05.25
2	Исследование баз данных и актуальных риск-калькуляторов	22.03.25 – 22.05.25
3	Установление взаимосвязей между CAPEC-шаблонами атак и эксплуатируемыми уязвимостями	23.05.25 – 31.05.25
4	Формирование сценариев заданных шаблонов атаки в виде последовательности реализации техник MITRE ATT&CK	01.06.25 – 12.06.25
5	Разработка организационно-правовых регламентов для заданных шаблонов атак CAPEC	13.06.25 – 24.06.25
6	Заключение	25.06.25 – 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.2025

Задание принял к исполнению 22.03.2025
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Атапина Максима Дмитриевича

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы сканирования портов»

Характеристика выпускной квалификационной работы

Актуальность исследования

Атаки класса «Методы сканирования портов» эксплуатируют методы сетевой разведки. Рост количества объектов защиты и роли информационных технологий в жизни человека делает сетевую разведку одной из самый полезных, хоть и не вредоносных атак. Злоумышленники благодаря полученным после разведки данным имеют перед собой множество вариантов и типов атак для реализации, т. к. им становится известна конфигурация сети, её топология, операционные системы устройств, процессы, службы и процессы, эксплуатирующиеся в сети. Потому актуальность проблемы противодействия атакам данного типа только возрастает.

Задачи, решаемые в ВКР

— организация, сбор открытых интернет-источников и суммаризация данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

— установление соответствия между кибератаками класса «Методы сканирования портов» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

— оценка рисков нарушения информационной безопасности посредством кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости в автоматизированных информационных системах;

— формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости в автоматизированных информационных системах.

Структура ВКР

Введение – 5 страниц

Глава 1. Исследование действующих баз данных ИБ и актуальных риск-калькуляторов – 5 страниц

Глава 2. Установление взаимосвязей между CAPEC-шаблонами атак и эксплуатируемыми уязвимостями – 18 страниц

Глава 3. Формирование сценариев заданных шаблонов атаки в виде последовательности реализации техник MITRE ATT&CK – 128 страниц

Глава 4. Разработка организационно-правовых регламентов для заданных шаблонов атак CAPEC – 28 страниц

Заключение – 2 страницы

Список литературы – 11 страниц

Приложение А – 36 страниц

Краткая характеристика полученных результатов *(по разделам ВКР)*

1) разработана база данных кибератак класса «Методы сканирования портов» на АИС, систематизирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

2) получено векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE, CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

3) сформирована методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Методы сканирования портов» с учётом специфики используемых злоумышленником сценариев;

4) разработан комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости АИС.

Автор ВКР _____ Ф.И.О. *(полностью)* Ананьин Максим Дмитриевич
(подпись)

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 10

1 Исследование действующих баз данных ИБ и актуальных риск-калькуляторов ... 17

1.1 Анализ баз данных, аккумулирующих информацию об угрозах информационной безопасности и уязвимостях программного обеспечения 17

1.1.1 CAPEC 17

1.1.2 MITRE ATT&CK 18

1.1.3 БДУ ФСТЭК России 18

1.1.4 NVD NIST 19

1.2 Исследование риск-калькуляторов, предоставляющих информацию о степени критичности уязвимостей 20

1.2.1 CVSS 20

1.2.2 EPSS 20

1.2.3 OWASP 21

2 Установление взаимосвязей между CAPEC-шаблонами атак и эксплуатируемыми уязвимостями 22

2.1 Установление взаимосвязей между шаблоном атак CAPEC-300 и эксплуатируемыми уязвимостями 25

2.1.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-300 25

2.1.2 Пример паспорта уязвимости, связанной с CAPEC-300 27

2.2 Установление взаимосвязей между шаблоном атак CAPEC-305 и эксплуатируемыми уязвимостями 28

2.2.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-305 28

2.2.2 Пример паспорта уязвимости, связанной с CAPEC-305 30

2.3 Установление взаимосвязей между шаблоном атак CAPEC-306 и эксплуатируемыми уязвимостями 30
2.3.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-306 30
2.3.2 Пример паспорта уязвимости, связанной с CAPEC-306 33
2.4 Установление взаимосвязей между шаблоном атак CAPEC-307 и эксплуатируемыми уязвимостями 33
2.4.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-307 33
2.4.2 Пример паспорта уязвимости, связанной с CAPEC-307 36
2.5 Установление взаимосвязей между шаблоном атак CAPEC-308 и эксплуатируемыми уязвимостями 37
2.5.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-308 37
2.5.2 Пример паспорта уязвимости, связанной с CAPEC-308 39
3 Формирование сценариев заданных шаблонов атаки в виде последовательности реализации техник MITRE ATT&CK 40
3.1 Формирование сценариев CAPEC-300 в виде последовательности реализации техник MITRE ATT&CK 41
3.1.1 Оценка критичности группы уязвимостей, связанной с CAPEC-300 41
3.1.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атаки CAPEC-300 45
3.1.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-300 54
3.2 Формирование сценариев CAPEC-305 в виде последовательности реализации техник MITRE ATT&CK 70
3.2.1 Оценка критичности группы уязвимостей, связанной с CAPEC-305 70

3.2.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-305 72

3.2.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-305 81

3.3 Формирование сценариев CAPEC-306 в виде последовательности реализации техник MITRE ATT&CK 94

3.3.1 Оценка критичности группы уязвимостей, связанной с CAPEC-306 94

3.3.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-306 96

3.3.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-306 104

3.4 Формирование сценариев CAPEC-307 в виде последовательности реализации техник MITRE ATT&CK 120

3.4.1 Оценка критичности группы уязвимостей, связанной с CAPEC-307 120

3.4.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-307 122

3.4.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-307 131

3.5 Формирование сценариев CAPEC-308 в виде последовательности реализации техник MITRE ATT&CK 151

3.5.1 Оценка критичности группы уязвимостей, связанной с CAPEC-308 151

3.5.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-308 153

3.5.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-308 159

4 Разработка организационно-правовых регламентов для заданных шаблонов атак CAPEC 168

ЗАКЛЮЧЕНИЕ 196

СПИСОК ЛИТЕРАТУРЫ 198

ПРИЛОЖЕНИЕ А 209

ВВЕДЕНИЕ

В современную эпоху информационных технологий кибератаки и уязвимости, которые они эксплуатируют, находятся в тесной взаимосвязи. Поэтому противодействие атакам путём оценки и регулирования рисков успешности их реализации является одной из первостепенных задач, выполняемых специалистами по защите информации. В рамках этой проблемы на данный момент исследованы следующие аспекты защиты информации [1-17]: от агрегации сведений об уязвимостях [1, 2] до калькуляции соответствующих этим уязвимостям параметров [3-6], от построения атласа кибератак [7] до разработки риск-ландшафтов [8, 9] единичных и массированных атак [10]. Также, кроме вышеуказанного, были исследованы вопросы разработки и использования нейросетевого инструментария противодействия кибератакам [11-15] и подготовки соответствующих кадров [16, 17], но во многом вне поля зрения в настоящий момент остаются кибератаки класса «Методы сканирования портов» и соответствующие им риск-модели.

Атаки класса «Методы сканирования портов», которым посвящено данное исследование, на первый взгляд не являются вредоносными и наносящими сильный ущерб атакуемым системам, если рассматривать их обособленно от атак других классов. На самом же деле сетевая разведка – это всего лишь один из начальных этапов любой атаки, когда злоумышленникам необходимо сформировать список возможных целей и получить информацию о конфигурации целевой системы или сети, поэтому опасность атак класса «Методы сканирования портов» кроется в раскрытии таких данных для злоумышленников. Проблема противодействия сетевой разведке является критической задачей при формировании стратегий защиты, так как в случае успешного проведения разведывательного этапа, дальнейшие действия злоумышленников малопредсказуемы.

Исследование Positive Technologies (2 июля 2024 год), в рамках которого исследователи провели 28 проектов по тестированию на проникновение, показало, что в 63% случаев пентестеры смогли добыть необходимую для продолжения атаки инфор-

мацию путём реализации техники «исследование сетевой конфигурации», в 48% случае они достигли того же результата использованием техники «просмотр текущей конфигурации системы» и в 40% случаев успешно провели сетевую разведку техникой «исследование файловой системы» [18].

Согласно вышесказанному, а также при исследовании аналогов [19-22], описывающих сканирование портов как один из методов реализации кибератак, можно сделать вывод, что популярность сетевой разведки как одного из самых эффективных способов получения информации о целевой системе неуклонно растёт. Существует необходимость в самостоятельной оценке критичности существующих угроз информационной безопасности, поэтому у организаций есть возможность использования различных баз данных [25-36] и риск-калькуляторов [37-48].

Однако многообразие подходов к оценке рисков и несовершенство аналитических возможностей вышеупомянутого обеспечения создают необходимость в проведении дополнительных исследований для систематизации знаний [49-89].

Упомянутые научные работы охватывают различные объекты защиты: сетевое пространство [69, 82-83, 85-89] в контексте противодействия компьютерным атакам [10, 8-9, 73-76] и уязвимостям [1-5, 88], также с применением средств искусственного интеллекта [11-15, 17, 62-64, 67], автоматизированные информационные системы [62-64] и другие объекты информатизации [66, 70-72, 77-80, 84-89], предприятия различных отраслей [58-61, 65, 69, 93-95], но их объединяет наличие общей цели исследований – оценка и регулирование рисков, что также является предметом исследования данной работы.

Согласно отчётам компаний [23-24], основной деятельностью которых является защита информации, существуют следующие статистические данные относительно атак класса «Методы сканирования портов»:

1) наиболее сканируемыми портами являются 22/TCP, который эксплуатирует протокол SSH (48% всех зафиксированных инцидентов сетевой разведки), 443/TCP для протокола HTTPS (32%) и 3389/TCP для работы протокола RDP операционной системы Windows, позволяющего выполнять удалённое подключение к рабочему столу (22%);

2) случаи использования протокола IPv6 для обхода механизмов защиты при сетевой разведке выросло на 35% по сравнению с 2023 годом;

3) 18% всех систем в мире с открытым для установки соединения портом протокола RDP (Remote Desktop Protocol) регистрируют инциденты сетевого сканирования ежедневно;

4) Только 12% организаций в мире применяют механизм rate-limiting, позволяющий ограничивать входящий трафик фиксированным значением количества запросов в единицу времени для противодействия сетевой разведке.

Таким образом можно сделать вывод, что факт роста цифровизации и роли информационных технологий в жизни человека, несмотря на появление новых методов защиты от кибератак и совершенствование уже существующих, только повысил актуальность проблемы защиты автоматизированных информационных систем от атак класса «Методы сканирования портов».

Однако, предоставляемое в аналогах [19-22] методическое и иное обеспечение для оценки опасности атак класса «Методы сканирования портов» не способно полностью разрешить проблемы, связанные с защитой информации, что создаёт противоречия относительно их полезности в контексте обеспечения информационной безопасности. Например, эффективность предлагаемых в них мер защиты и оценок вероятности эксплуатации уязвимостей на различных этапах кибератаки уступает эффективности применения вероятностных моделей, построенных на основе тактик, рекомендуемых MITRE ATT&CK. Также существующие аналоги не способны обеспечить специалистов по защите информации необходимой и достаточной информацией о применяемых злоумышленниками техниках на различных этапах атаки и, соответственно, не позволяют объективно предугадывать действия, вероятно совершаемые ими на следующих этапах атак. Кроме того, анализ аналогов показал, что предлагаемые в них защитные меры не столь эффективны при практическом применении из-за отсутствия оценки критичности уязвимостей с опорой на открытые данные современных риск-калькуляторов. При этом разработанные в рамках данного исследования организационно-правовые регламенты способны помочь специалистам по защите информации повысить защищённость автоматизированных информационных систем от

атак класса «Методы сканирования портов», поскольку включают в себя конкретные методы и процедуры реагирования на фиксируемые инциденты нарушения безопасности и чёткие алгоритмы устранения последствий кибератак. В свою очередь, аналоги не способны обеспечить сопоставимый уровень защиты из-за отсутствия привязки к конкретным тактикам, которые вероятно эксплуатируются злоумышленниками, из-за чего предлагаемые в них контрмеры имеют обобщённый характер.

После исследования аналогов [19-22] становится возможным сформировать следующее целеполагание данного исследования.

Объектом исследования являются автоматизированные информационные системы, подвергающиеся кибератакам класса «Методы сканирования портов».

Предметом исследования являются процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Методы сканирования портов», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования заключается в повышении защищённости автоматизированных информационных систем (АИС) от кибератак класса «Методы сканирования портов».

Исследование аналогов позволило выявить **противоречия** между:

— необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Методы сканирования портов»;

— потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

— существующей методологией вероятностной оценки опасности кибератак класса «Методы сканирования портов», использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

— несовершенством процедур регламентации противодействия кибератакам класса «Методы сканирования портов» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для ликвидации данных противоречий и достижения поставленной цели требуется выполнить следующие **задачи**:

— организация, сбор открытых интернет-источников и суммаризация данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

— установление соответствия между кибератаками класса «Методы сканирования портов» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

— оценка рисков нарушения информационной безопасности посредством кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости в автоматизированных информационных системах;

— формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

— структурированная база данных кибератак класса «Методы сканирования портов» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

— векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

— методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Методы сканирования портов», с учётом специфики используемых злоумышленниками сценариев;

— комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости АИС.

Новизна полученных результатов заключается в следующем:

— в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Методы сканирования портов», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

— впервые для класса кибератак «Методы сканирования портов» были предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

— в отличие от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Методы сканирования портов», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

— для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Методы сканирования портов».

Практическая ценность полученных результатов состоит в том, что:

— созданная база данных метрик кибератак класса «Методы сканирования портов» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

— сформированное множество сценариев и их рисканализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Методы сканирования портов»;

— предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Методы сканирования портов», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

— предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Методы сканирования портов» на защищаемые АИС.

Теоретическая значимость результатов видится в следующем:

— сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

— разработанные сценарии атак класса «Методы сканирования портов» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

— представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Методы сканирования портов», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

— в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Методы сканирования портов» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Исследование действующих баз данных ИБ и актуальных риск-калькуляторов

1.1 Анализ баз данных, аккумулирующих информацию об угрозах информационной безопасности и уязвимостях программного обеспечения

Растущее от года к году количество и сложность кибератак побуждают прибегать к использованию специализированных источников знаний, называемых базами данных угроз и уязвимостей, таких как MITRE ATT&CK, БДУ ФСТЭК России, NVD NIST и CAPEC, а также риск-калькуляторов, таких как CVSS версий 3.1 и 4.0, EPSS и OWASP. Они позволяют получить систематизированную информацию о тактиках, применяемых злоумышленниками, уязвимостях ПО и типах атак. Разработка стратегий защиты и различных организационно-правовых регламентов всегда начинается с поиска и анализа информации в этих источниках.

Перед началом выполнения задач, поставленных во введении, необходимо исследовать применяемые в данной работе источники информации.

1.1.1 CAPEC

CAPEC представляет собой каталог шаблонов кибератак. В отличие от стандартных баз данных такого типа, фиксирующие уязвимые места систем, CAPEC делает возможным детализацию полного цикла атак – от сетевой разведки до реализации.

Каждый шаблон атаки CAPEC содержит цели и механизмы атаки, рекомендации по организации защитных мер и оценку сложности реализации шаблона атаки. Ценность данного ресурса для специалистов по защите информации состоит в возможности прогнозирования кибератак, разработке многоуровневых мер защиты, возможности повышения квалификации персонала. Также возможно использование CAPEC совместно с другими базами данных, например MITRE ATT&CK, что создаёт сильную основу для комплексного анализа кибератак.

CAPEC через понимание базовых паттернов атаки позволяет предсказывать возможные угрозы безопасности, обеспечивать комплексную защиту, учитывающую

возможные тактики злоумышленников, а также способствует организации мер, обеспечивающих проактивную безопасность систем.

1.1.2 MITRE ATT&CK

MITRE ATT&CK представляет собой базу знаний о тактиках, техниках и процедурах, эксплуатируемых злоумышленниками при совершении атак. В отличие от традиционных подходов, фокусирующихся на анализе только лишь уязвимостей, MITRE ATT&CK предоставляет детализированную информацию о поведении нарушителей безопасности информации на всех этапах атаки.

Матрица MITRE ATT&CK основана на анализе реальных инцидентов, что позволяет говорить об актуальности и эффективности предлагаемых в ней мер обнаружения атак и противодействия им. Также, как и CAPEC, матрица MITRE ATT&CK может быть использована совместно с другими базами данных, что позволяет решать задачи по обеспечению информационной безопасности более эффективно.

В практической деятельности MITRE ATT&CK можно использовать для раннего обнаружения угроз, мониторинга вредоносной активности специалистами по защите информации и поиска эффективных контрмер на инциденты, возникающие при реализации техник.

В качестве преимуществ MITRE ATT&CK можно выделить возможность перехода от реактивной к проактивной защите, возможность понимания атак целостно с точки зрения её жизненного цикла и наличие актуальных знаний, позволяющих разрабатывать более эффективные меры безопасности.

1.1.3 БДУ ФСТЭК России

Следующей базой данных рассмотрим БДУ ФСТЭК России – отечественное решение в области адаптации данных об уязвимостях, существующих в иностранных источниках. В качестве ключевой особенности можно выделить ориентацию на российские нормативные требования и стандарты информационной безопасности.

БДУ ФСТЭК России учитывает специфику российского законодательства в области информационной безопасности и охватывает все наиболее значимые компоненты любой информационной инфраструктуры (операционные системы и приложения, сетевое оборудование и актуальные киберугрозы).

Эта база данных также позволяет специалистам работать совместно с международными аналогичными источниками данных об уязвимостях и содержит рекомендации по устранению уязвимостей, полезные в практической деятельности.

1.1.4 NVD NIST

Последним источником для рассмотрения является база данных NVD, обслуживаемая Национальным Институтом Стандартов и Технологий. Это централизованный реестр уязвимостей ПО, который этим и отличается от CAPEC и MITRE ATT&CK - своей узкой специализацией на систематизации данных об уязвимостях, но не о тактиках и техниках атак.

Каждая запись об уязвимости, хранящаяся в этой базе данных, содержит детальное описание уязвимости, рекомендации и меры по устранению, оценки критичностей по CVSS 2.0, 3.1 и 4.0 вместе с векторами, содержащими оценки каждой метрики уязвимости. NVD является основой для стандарта классификации уязвимостей CVE, а также эффективным образовательным ресурсом и постоянно актуализируется, что делает её надёжным источником информации для специалистов по защите информации.

Таким образом, все четыре базы данных, несмотря на отличия в применяемых подходах, способны дополнять друг друга при комплексном подходе к оценке и регулированию рисков. БДУ ФСТЭК России особенно ценна для организаций, которым требуется соблюдать требования российских регуляторов и законодательных актов при осуществлении своей деятельности.

1.2 Исследование риск-калькуляторов, предоставляющих информацию о степени критичности уязвимостей

Выше были исследованы источники, которые позволят выявить уязвимости автоматизированных информационных систем, но далее возникает необходимость в приоритизации этих уязвимостей. Для этого разработчики риск-калькуляторов предлагают разнообразные решения в области систем оценок уязвимостей.

1.2.1 CVSS

CVSS (Common Vulnerability Scoring System) – это стандарт оценки уязвимостей разработки FIRST. На данный момент существуют устаревшая версия CVSS 2.0, устаревающая CVSS 3.1 и актуальная на сегодняшний день CVSS версии 4.0. Оценка уязвимостей согласно этой системе производится несколькими группами метрик: базовые (отражают неизменные свойства уязвимостей), временные (отражают динамически изменяемые со временем показатели) и контекстные. Критичность каждой уязвимости оценивается в числовом диапазоне от 0 до 10, где 0 – отсутствие угрозы от уязвимости, 10 – уязвимость критическая.

1.2.2 EPSS

EPSS (Exploit Prediction Scoring System). Особенностями данной системы оценки уязвимостей является прогнозирование вероятности эксплуатации уязвимости от 0 до 100 процентов, используя при этом в своей работе методы машинного обучения. Она анализирует активность злоумышленников, наличие у уязвимости эксплойтов и имеющуюся статистику атак с эксплуатацией конкретной уязвимости. В отличие от CVSS, EPSS фокусируется на вероятности эксплуатации уязвимости, а не её критичности, т. е. уязвимость с низким или средним значением оценки калькулятора CVSS, но высокой вероятностью эксплуатации согласно оценке EPSS должна устраняться в первую очередь.

1.2.3 OWASP

OWASP Risk Rating Calculator. Данная система применима в веб-приложениях, анализ уязвимостей происходит в несколько этапов:

1) анализ факторов угрозы;

2) оценка потенциального воздействия;

3) расчёт общего риска;

4) отнесение уязвимости к определённому классу опасности (низкая, средняя, высокая или критическая).

Фокус CVSS на первичной оценке критичности уязвимости, EPSS на анализе актуальности угрозы на основе вероятностных оценок и OWASP на учитывании последствий эксплуатации уязвимости для бизнес-процессов организации позволяет сделать вывод о том, что комбинированный подход к оценке уязвимостей с использованием всех вышеперечисленных риск-калькуляторов является предпочтительным и высокоэффективным вариантом при оценке и регулировании рисков безопасности.

2 Установление взаимосвязей между CAPEC-шаблонами атак и эксплуатируемыми уязвимостями

Как было упомянуто выше, CAPEC (Common Attack Pattern Enumeration and Classification) – это база данных с чёткой структурой шаблонов кибератак, разработанная MITRE. Данная система классификации предоставляет систематизированные методы проведения атак, описание эксплуатируемых при их реализации уязвимостей и рекомендации по организации защитных мер. Структура данных следующая: уровень абстракции – категория атак – техники.

Существует терминология, применяемая CAPEC при описании шаблонов атак:

1) attack (атака) – общее описание воздействия, осуществляемого при эксплуатации уязвимостей;

2) attack vector (вектор атаки) – способ реализации атаки злоумышленником. Организация деструктивного воздействия и способы эксплуатации уязвимостей описываются в векторе атак;

3) attack technique (техника атаки) – совокупность методов, применяемых злоумышленником в ходе реализации атаки;

4) mitigation (защита) – меры, направленные на предотвращение атаки или уменьшение ущерба от её реализации;

5) targeted weakness (уязвимость) – слабое место в системе, на эксплуатацию которого направлены действия нарушителей безопасности информации;

6) impact (последствия) – негативные последствия успешной реализации атаки.

В практической деятельности CAPEC может использоваться специалистами по защите информации для классификации угроз, разработки мер защиты и моделирования сценариев реализации атак. Для разработчиков эта база данных может быть полезна для анализа уязвимостей архитектуры, разработки тестов на проникновение и, соответственно, создания систем и сетей с высокой степенью защищённости.

Для данной работы актуальными являются атаки класса «Методы сканирования портов», общим шаблоном атаки которых служит CAPEC-169 «Футпринтинг».

Приведём описание шаблона атаки CAPEC-169 «Футпринтинг». Данный шаблон описывает те атаки, в которых злоумышленник эксплуатирует методы, позволяющие собирать информацию о свойствах и характеристиках целевой системы. Футпринтинг – это термин, являющийся обобщающим для множества техник, чаще всего использующихся злоумышленниками для подготовки к атаке посредством использования специальных средств сканирования для раскрытия информации о топологии, конфигурации и защитных механизмов целевого приложения, системы или сети. Информация, получаемая при сканировании, может включать в себя статус портов, информацию о приложениях и операционных системах, в том числе об их версиях. В отличие от «fingerprinting», футпринтинг нацелен на формирование более целостного взгляда на систему или сеть, в то время как техника «fingerprinting» нацелена на получение информации о конкретном приложении или операционной системе. Несмотря на то, что футпринтинг не имеет цели нанести какой-либо ущерб, данная техника с помощью информации, которую она даёт злоумышленнику, может сильно увеличить ущерб от любой другой атаки, поэтому атаки класса «Методы сканирования портов» нельзя оставлять без внимания, т. к. получаемая после сканирования сети или системы информация даёт злоумышленникам большую вариативность для проведения атак других классов.

В рамках данного исследования будут рассмотрены шаблоны атак CAPEC, для которых CAPEC-169 является объединяющим, а именно:

1) CAPEC-300 «Сканирование портов»;

2) CAPEC-305 «TCP ACK сканирование»;

3) CAPEC-306 «Сканирование окна TCP»;

4) CAPEC-307 «TCP RPC сканирование»;

5) CAPEC-308 «UDP сканирование».

Взаимосвязь данных шаблонов атаки с CAPEC-169 отразим на рисунке 1 в виде графа.

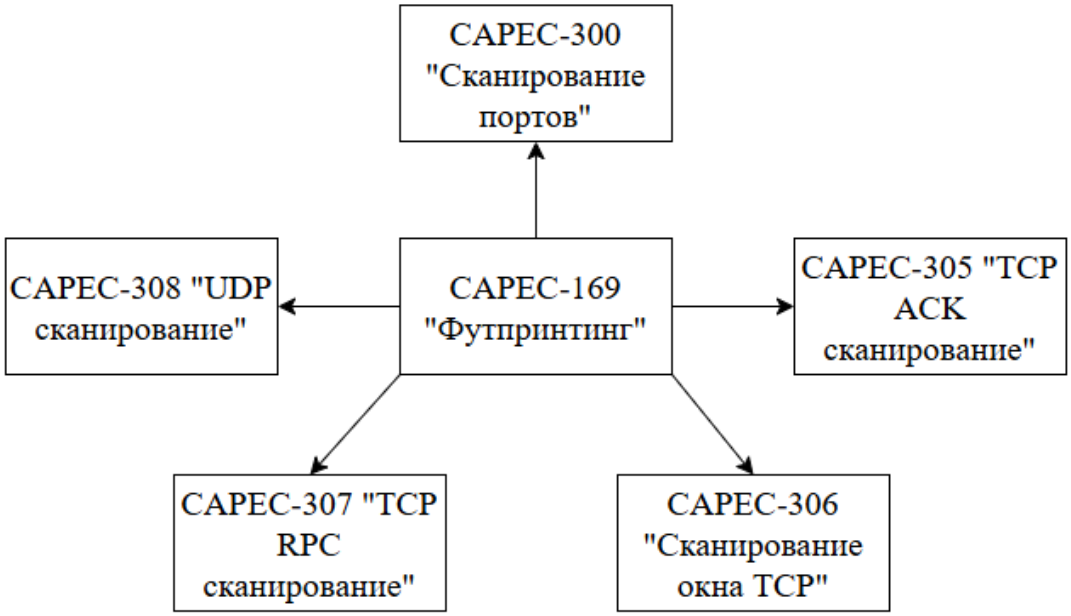


Рисунок 1 – Древовидный граф шаблонов атаки, связанных с CAPEC-169

Далее разработаем паспорта для каждого рассматриваемого в рамках исследования шаблона атаки CAPEC. Это позволит разложить шаблоны на тактики и техники, рекомендуемые MITRE ATT&CK, что, в свою очередь, позволит смоделировать вероятные действия злоумышленников в рамках реализации того или иного шаблона атаки. Также в каждом паспорте шаблона атаки будет отражён важный для дальнейшей работы параметр – тип ошибки, т. е. идентификатор Common Weakness Enumeration (CWE). На основе конкретного типа ошибки станет возможным разработать для каждого шаблона атаки группы потенциально эксплуатируемых злоумышленниками уязвимостей.

Данные группы уязвимостей будут сформированы на основе информации, предоставляемой National Institute of Standards and Technologies (NIST) и их собственной базой уязвимостей. Помимо этого, будут использованы базы данных Common Vulnerabilities Enumeration (CVE) и БДУ ФСТЭК России, которые, в свою очередь, при формировании собственных баз ориентируются на NIST и дополняют информацию об уязвимостях, предоставляемую базой данных NIST. Также для каждой уязвимости далее будут разработаны паспорта уязвимостей, систематизирующие необходимую для дальнейшей работы информацию.

После выбора источников, с помощью которых будет осуществляться сбор информации о шаблонах атаки, тактик и техник, уязвимостей, становится возможным приступить к разбору каждого рассматриваемого в работе шаблона атаки и приведения их паспортов.

2.1 Установление взаимосвязей между шаблоном атак CAPEC-300 и эксплуатируемыми уязвимостями

2.1.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-300

Согласно описанию шаблона атаки CAPEC-300 «Сканирование портов», злоумышленник эксплуатирует методы, позволяющие определить состояние портов на удалённой целевой системе, т. к. любое приложение, процесс или служба, работающие на TCP или UDP протоколах, будет иметь открытый для установления соединения порт.

Паспорт данного шаблона атаки с связанным с ним идентификатором ошибки CWE отобразим в таблице 1.

Таблица 1 – Паспорт шаблона атаки CAPEC-300

Идентификатор системы CAPEC	CAPEC-300 «Сканирование портов».	
Описание вектора атаки	Злоумышленник эксплуатирует методы, позволяющие определить состояние портов на удалённой целевой системе, т. к. любое приложение, процесс или служба, работающие на TCP или UDP протоколах, будет иметь открытый для установления соединения порт.	
Тип атаки	Футпринтинг (разведка с целью сбора информации о целевой системе).	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: раскрытие конфиденциальной информации нелегитимному лицу.	Данный идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями.

Итак, шаблон атаки CAPEC-300 «Сканирование портов» связан только с одним идентификатором ошибки – CWE-200 (раскрытие конфиденциальной информации нелегитимному лицу).

Древовидный граф шаблона атаки CAPEC-300 отразим на рисунке 2.

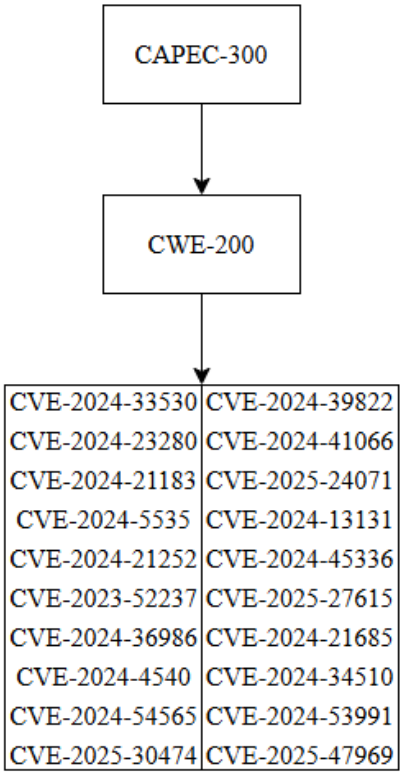


Рисунок 2 – Древовидный граф шаблона атаки CAPEC-300

Отразим в таблице 2 шаблон атаки CAPEC-300 со связанными с ним идентификатором ошибки и уязвимостями.

Таблица 2 – Соотношение «атака – уязвимость» для шаблона атаки CAPEC-300

Шаблон атаки	Наименование шаблона атаки	Связанный с ним идентификатор ошибки CWE	Уязвимости
1	2	3	4
CAPEC-300	Сканирование портов	CWE-200	CVE-2024-33530
			CVE-2024-23280
			CVE-2024-21183
			CVE-2024-5535
			CVE-2024-21152
			CVE-2023-52237

Продолжение таблицы 2

1	2	3	4
CAPEC-300	Сканирование портов	CWE-200	CVE-2024-36986
			CVE-2024-4540
			CVE-2024-54565
			CVE-2025-30474
			CVE-2024-39822
			CVE-2024-41066
			CVE-2025-24071
			CVE-2024-13131
			CVE-2024-45336
			CVE-2025-27615
			CVE-2024-21685
			CVE-2024-34510
			CVE-2024-53991
			CVE-2025-47969

2.1.2 Пример паспорта уязвимости, связанной с CAPEC-300

Приведём паспорт одной из уязвимостей в таблице 3. Паспорта других уязвимостей будут приведены в Приложении А.

Таблица 3 – Паспорт уязвимости CVE-2024-33530

Идентификатор уязвимости	CVE-2024-33530 Уязвимость протокола XMPP (Extensible Messaging and Presence Protocol) программного обеспечения для проведения видеоконференций Jitsi Meet связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть пароль от совещаний с помощью HTTP POST-запросов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена в ходе исследований
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

2.2 Установление взаимосвязей между шаблоном атак CAPEC-305 и эксплуатируемыми уязвимостями

2.2.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-305

Перейдём к следующему шаблону атаки – CAPEC-305 «TCP ACK сканирование». Согласно описанию данного шаблона, при проведении атаки злоумышленник использует сегменты TCP ACK для сбора информации о межсетевых экранах или конфигурациях ACL. Целью в случае применении данного механизма сканирования является сбор данных о способах организации фильтрации трафика, а не о состоянии портов. Паспорт этого шаблона атаки приведён в таблице 4.

Таблица 4 – Паспорт шаблона атаки CAPEC-305

Идентификатор системы CAPEC	CAPEC-305 «TCP ACK сканирование».	
Описание вектора атаки	Злоумышленник использует сегменты TCP ACK для сбора информации о межсетевых экранах или конфигурациях ACL. Целью в случае применении данного механизма сканирования является сбор данных о способах организации фильтрации трафика, а не о состоянии портов.	
Тип атаки	Футпринтинг (разведка с целью сбора информации о целевой системе).	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: раскрытие конфиденциальной информации нелегитимному лицу.	Данный идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями.

Отразим связанные с данным шаблоном атаки идентификатор ошибки CWE и уязвимости в виде графа на рисунке 3.

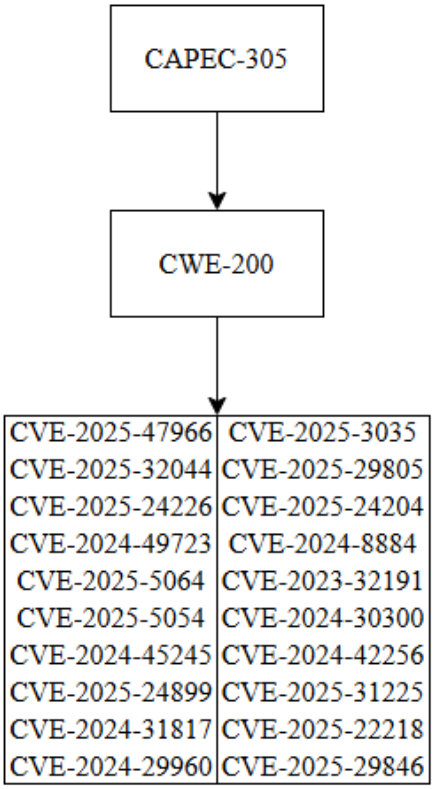


Рисунок 3 – Древовидный граф шаблона атаки CAPEC-305

Приведём в таблице 5 связанные с CAPEC-305 идентификатор ошибки CWE и уязвимости.

Таблица 5 - Соотношение «атака – уязвимость» для шаблона атаки CAPEC-305

Шаблон атаки	Наименование шаблона атаки	Связанный с ним идентификатор ошибки CWE	Уязвимости
1	2	3	4
CAPEC-305	TCP ACK сканирование	CWE-200	CVE-2025-47966
			CVE-2025-32044
			CVE-2025-24226
			CVE-2024-49723
			CVE-2025-5064
			CVE-2025-5054
			CVE-2024-45245
			CVE-2025-24899
			CVE-2024-31817
			CVE-2024-29960
			CVE-2025-3035
			CVE-2025-29805
			CVE-2025-24204
			CVE-2024-8884

Продолжение таблицы 5

1	2	3	4
CAPEC-305	TCP ACK сканирование	CWE-200	CVE-2023-32191
			CVE-2024-30300
			CVE-2024-42256
			CVE-2025-31225
			CVE-2025-22218
			CVE-2025-29846

2.2.2 Пример паспорта уязвимости, связанной с CAPEC-305

Приведём паспорт одной из уязвимостей в таблице 6. Паспорта других уязвимостей, связанных с данным шаблоном атаки, будут размещены в Приложении А.

Таблица 6 – Паспорт уязвимости CVE-2025-47966

Идентификатор уязвимости	CVE-2025-47966 Уязвимость платформы автоматизации Power Automate for Desktop связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.1 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

2.3 Установление взаимосвязей между шаблоном атак CAPEC-306 и эксплуатируемыми уязвимостями

2.3.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-306

Далее рассмотрим шаблон атаки CAPEC-306 «Сканирование окна TCP». Согласно этому шаблону, злоумышленник при реализации такой атаки применяет данный механизм сканирования для сбора информации о состоянии портов и типа опе-

рационной системы на целевой системе. Некоторые операционные системы возвращают положительный размер окна TCP, когда пакет RST отправляется с открытого порта, и отрицательное значение, когда пакет RST исходит из закрытого порта. Паспорт данного шаблона атаки продемонстрирован в таблице 7.

Таблица 7 – Паспорт шаблона атаки CAPEC-306

Идентификатор системы CAPEC	CAPEC-306 «Сканирование окна TCP».	
Описание вектора атаки	Злоумышленник применяет данный механизм сканирования для сбора информации о состоянии портов и типа операционной системы на целевой системе. Некоторые операционные системы возвращают положительный размер окна TCP, когда пакет RST отправляется с открытого порта, и отрицательное значение, когда пакет RST исходит из закрытого порта.	
Тип атаки	Футпринтинг (разведка с целью сбора информации о целевой системе).	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: раскрытие конфиденциальной информации нелегитимному лицу.	Данный идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями.

Далее на рисунке 4 для наглядности приведём граф, показывающий взаимосвязь шаблона атаки с идентификатором ошибки CWE и уязвимостями, потенциально эксплуатируемыми при реализации атаки.

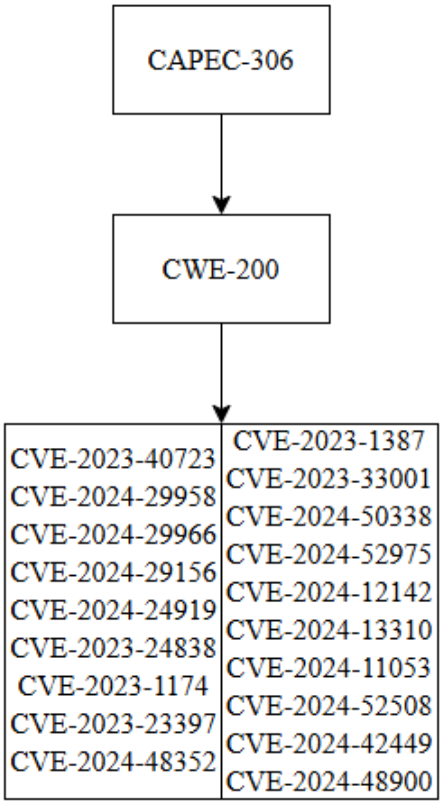


Рисунок 4 – Древовидный граф шаблона атаки CAPEC-306

Приведём в таблице 8 связанные с CAPEC-305 идентификатор ошибки CWE и уязвимости.

Таблица 8 - Соотношение «атака – уязвимость» для шаблона атаки CAPEC-306

Шаблон атаки	Наименование шаблона атаки	Связанный с ним идентификатор ошибки CWE	Уязвимости
1	2	3	4
CAPEC-306	Сканирование окна TCP	CWE-200	CVE-2023-40723
			CVE-2024-29958
			CVE-2024-29966
			CVE-2024-29156
			CVE-2024-24919
			CVE-2023-24838
			CVE-2023-1174
			CVE-2023-23397
			CVE-2024-48352
			CVE-2023-1387
			CVE-2023-33001
			CVE-2024-50338
			CVE-2024-52975
			CVE-2024-12142

Продолжение таблицы 8

1	2	3	4
CAPEC-306	Сканирование окна TCP	CWE-200	CVE-2024-13310
			CVE-2024-11053
			CVE-2024-52508
			CVE-2024-42449
			CVE-2024-48900

2.3.2 Пример паспорта уязвимости, связанной с CAPEC-306

Также приведём в таблице 9 паспорт одной из уязвимостей, связанной с шаблоном атаки CAPEC-306. Паспорта остальных уязвимостей для данного CAPEC будут размещены в Приложении А.

Таблица 9 – Паспорт уязвимости CVE-2023-40723

Идентификатор уязвимости	CVE-2023-40723 Уязвимость системы управления безопасностью FortiSIEM связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить пароль базы данных с помощью специально созданных API-запросов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

2.4 Установление взаимосвязей между шаблоном атак CAPEC-307 и эксплуатируемыми уязвимостями

2.4.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-307

Перейдём к рассмотрению шаблона атаки CAPEC-307 «TCP RPC сканирование». Его паспорт приведён в таблице 10. При выполнении данного метода сканирования злоумышленник отправляет датаграмму RPC на UDP порты и записывает ответ

от них. После становится возможным идентификация RPC-сервисов, потому что содержимое ответных UDP пакетов часто указывает на конкретные приложения. Такие приложения и становятся целью злоумышленника, т. к. они часто небезопасны.

Таблица 10 – Паспорт шаблона атаки CAPEC-307

Идентификатор системы CAPEC	CAPEC-307 «TCP RPC сканирование».	
Описание вектора атаки	При выполнении данного метода сканирования злоумышленник отправляет датаграмму RPC на UDP порты и записывает от них ответ. После становится возможным идентифицировать RPC-сервисы, потому что содержимое ответных UDP пакетов часто указывает на конкретные приложения. Такие приложения и становятся целью злоумышленника, т. к. они часто небезопасны.	
Тип атаки	Футпринтинг (разведка с целью сбора информации о целевой системе).	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: раскрытие конфиденциальной информации нелегитимному лицу.	Данный идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями.

Далее приведём на рисунке 5 древовидный граф, демонстрирующий взаимосвязь данного шаблона атаки с идентификатором ошибки CWE и уязвимостями, вероятно эксплуатируемыми при реализации атаки типа «TCP RPC сканирование».

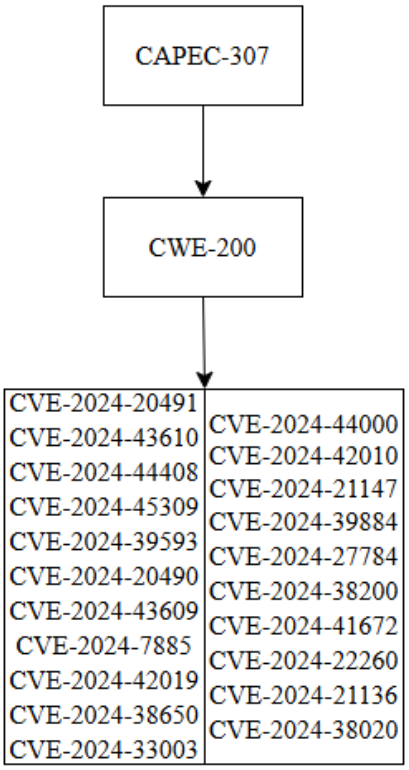


Рисунок 5 – Древовидный граф шаблона атаки CAPEC-307

Для систематизации данных, в таблице 11 приведено соотношение шаблона атаки CAPEC-307, идентификатора ошибки CWE и уязвимостей, вероятно эксплуатируемых злоумышленниками при совершении атаки.

Таблица 11 – Соотношение «атака – уязвимость» для шаблона атаки CAPEC-307

Шаблон атаки	Наименование шаблона атаки	Связанный с ним идентификатор ошибки CWE	Уязвимости
1	2	3	4
CAPEC-307	TCP RPC сканирование	CWE-200	CVE-2024-20491
			CVE-2024-43610
			CVE-2024-44408
			CVE-2024-45309
			CVE-2024-39593
			CVE-2024-20490
			CVE-2024-43609
			CVE-2024-7885
			CVE-2024-42019
			CVE-2024-38650
			CVE-2024-33003
			CVE-2024-44000
			CVE-2024-42010

Продолжение таблицы 11

1	2	3	4
CAPEC-307	TCP RPC сканирование	CWE-200	CVE-2024-21147
			CVE-2024-39884
			CVE-2024-27784
			CVE-2024-38200
			CVE-2024-41672
			CVE-2024-22260
			CVE-2024-21136
			CVE-2024-38020

2.4.2 Пример паспорта уязвимости, связанной с CAPEC-307

В таблице 12 разместим паспорт одной из уязвимостей. Паспорта остальных уязвимостей, связанных с данным шаблоном атак, приведены в Приложении А.

Таблица 12 – Паспорт уязвимости CVE-2024-20491

Идентификатор уязвимости	CVE-2024-20491 Уязвимость функции ведения журнала веб-интерфейса управления платформы аналитики и автоматизации работы с многооблачными сетями дата-центров Cisco Nexus Dashboard Insights связана с раскрытием информации через регистрационные файлы. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию, путём чтения файла технической поддержки, содержащего внутренний журнал с учётными данными удалённого контроллера.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

2.5 Установление взаимосвязей между шаблоном атак CAPEC-308 и эксплуатируемыми уязвимостями

2.5.1 Соотношение «атака-уязвимость» для шаблона атаки CAPEC-308

Перейдём к рассмотрению последнего в рамках данного исследования шаблона атаки - CAPEC-308 «UDP сканирование». Согласно описанию данного шаблона атаки злоумышленник реализует UDP сканирование для получения информации о статусе UDP портов на целевой системе. При данном механизме сканирования датаграмма UPD отправляется на порт и злоумышленник ожидает свидетельств того, что порт закрыт, т. к. открытые UDP порты не отправляют ответных пакетов из-за отсутствия в UDP протоколе механизмов установления соединения. Паспорт данного шаблона атаки приведён в таблице 13

Таблица 13 – Паспорт шаблона атаки CAPEC-308

Идентификатор системы CAPEC	CAPEC-308 «UDP сканирование».	
Описание вектора атаки	Злоумышленник реализует данный тип сканирования для получения информации о статусе UDP портов на целевой системе. При данном механизме сканирования датаграмма UPD отправляется на порт и злоумышленник ожидает свидетельств того, что порт закрыт, т. к. открытые UDP порты не отправляют ответных пакетов из-за отсутствия в UDP протоколе способов установления соединения.	
Тип атаки	Футпринтинг (разведка с целью сбора информации о целевой системе).	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: раскрытие конфиденциальной информации нелегитимному лицу.	Данный идентификатор CWE не следует использовать для сопоставления с реальными уязвимостями.

Далее для наглядности разместим на рисунке 6 граф, отражающий взаимосвязь CAPEC-308, CWE-200 и группы уязвимостей.

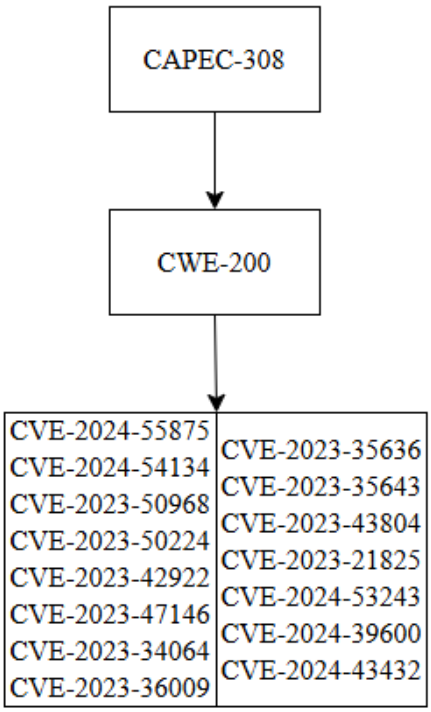


Рисунок 6 – Древовидный граф шаблона атаки CAPEC-308

Для систематизации данных, в таблице 14 приведено соотношение шаблона атаки CAPEC-308, идентификатора ошибки CWE и уязвимостей.

Таблица 14 – Соотношение «атака – уязвимость» для шаблона атаки CAPEC-308

Шаблон атаки	Наименование шаблона атаки	Связанный с ним идентификатор ошибки CWE	Уязвимости
1	2	3	4
CAPEC-308	UDP сканирование	CWE-200	CVE-2024-55875
			CVE-2024-54134
			CVE-2023-50968
			CVE-2023-50224
			CVE-2023-42922
			CVE-2023-47146
			CVE-2023-34064
			CVE-2023-36009
			CVE-2023-35636
			CVE-2023-35643
			CVE-2023-43804
			CVE-2023-21825
			CVE-2024-53243
			CVE-2024-39600
			CVE-2024-43432

2.5.2 Пример паспорта уязвимости, связанной с CAPEC-308

Далее в таблице 15 приведём паспорт одной из уязвимостей, относящейся к шаблону атаки CAPEC-308. Паспорта остальных уязвимостей для этого шаблона атаки будут размещены в Приложении А.

Таблица 15 – Паспорт уязвимости CVE-2024-55875

Идентификатор уязвимости	CVE-2024-55875 Уязвимость функционального набора инструментов для приложений Kotlin HTTP http4k связана с неверным ограничением XML-ссылок на внешние объекты. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, проводить XXE-атаки
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

3 Формирование сценариев заданных шаблонов атаки в виде последовательности реализации техник MITRE ATT&CK

В этой главе будет рассмотрен один из методов оценки критичности уязвимостей, и по этому методу будут рассчитаны критичности каждой уязвимости, приведённой в предыдущей главе. Основными источниками, предоставляющими исходные данные для дальнейших вычислений, служат риск-калькуляторы, оценки которых дают основу для анализа критичностей уязвимостей и последующему расчёту вероятности успешной эксплуатации каждой из них.

Таким образом, упомянутыми выше риск-калькуляторами, на основе оценок которых будет выполняться дальнейшая работа по расчёту параметров уязвимостей, выступят OWASP, EPSS, CVSS версий 3.1 и 4.0.

Так как оценки вышеупомянутых риск-калькуляторов находятся в разных числовых диапазонах, для начала работы требуется их нормализовать для приведених в область допустимых значений {0;1}. Нормализация оценок будет производится по следующей формуле [5]:

$$m_{norm} = \frac{m - m_{min}}{m_{max} - m_{min}}, \quad (1)$$

где: m_{norm} – нормализованная оценка риск-калькулятора (CVSS 3.1, CVSS 4.0, EPSS, OWASP);

m – оценка критичности согласно данным риск-калькулятора;

m_{max} – максимально возможная оценка риск-калькулятора (для CVSS 3.1, CVSS 4.0 и OWASP – 10, для EPSS - 1);

m_{min} - минимально возможная оценка риск-калькулятора (для CVSS 3.1, CVSS 4.0 и OWASP – 0, для EPSS - 0).

Для расчёта значений критичности будет использован метод нахождения среднеквадратичного значения по формуле [5]:

$$K = \frac{1}{N}\sum_{i=1}^{N} M_{norm,i}^{2}, \quad (2)$$

где: K – значение критичности уязвимости;

N – количество используемых калькуляторов (в рамках данного исследования количество равняется четырём);

M_{norm} - нормализованная оценка критичности уязвимости.

Актуальность данного метода для настоящего исследования заключается в том, что в методе производится оценка «разброса» нормализованных оценок, таким образом берётся во внимание ценность крайних значений и вариабельность данных.

Данный метод широко используется в статистике и анализе данных, так как он позволяет учитывать не только среднюю величину, но и степень разброса оценок. Среднеквадратичное значение делает возможным количественную оценку степени разброса оценок по отношению к среднему, что полезно при оценке рисков, так как высокий разброс оценок позволяет говорить о достаточно серьёзных рисках.

Метод нахождения среднеквадратичного значения чувствителен к выбросам, что позволяет своевременно выявить нестабильность данных. Такой подход предоставляет возможность в точной оценке рисков и принятии эффективных решений по их снижению.

3.1 Формирование сценариев CAPEC-300 в виде последовательности реализации техник MITRE ATT&CK

3.1.1 Оценка критичности группы уязвимостей, связанной с CAPEC-300

В таблицах 16-17 приведены значения риск-калькуляторов для уязвимостей, связанных с шаблоном атаки CAPEC-300.

Таблица 16 – Оценки риск-калькуляторов для уязвимостей, связанных с CAPEC-300

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2024-33530	7.5	8.7	0.912	5.625
CVE-2024-23280	7.5	8.7	0.424	4.75
CVE-2024-21183	7.5	8.7	0.232	4.75
CVE-2024-5535	9.1	8.8	0.5152	3.25
CVE-2024-21152	8.1	8.6	0.367	4.625
CVE-2023-52237	7.5	7.7	0.12	4.125
CVE-2024-36986	6.3	6.8	0.58	5.875
CVE-2024-4540	7.5	8.7	0.628	4.375
CVE-2024-54565	6.2	6.9	0.19	3.125
CVE-2025-30474	7.5	2.3	0.65	5.125
CVE-2024-39822	6.5	7.1	0.224	6.5
CVE-2024-41066	5.5	6.8	0.38	5.25
CVE-2025-24071	7.5	7.8	0.53676	5.25
CVE-2024-13131	7.3	6.9	0.35372	6.75
CVE-2024-45336	6.1	6.2	0.26	4.25
CVE-2025-27615	8.2	8.8	0.76	3.25
CVE-2024-21685	7.4	8.1	0.275	4.625
CVE-2024-34510	7.5	8.7	0.56	4.625
CVE-2024-53991	7.5	8.7	0.18482	5
CVE-2025-47969	4.4	6.7	0.58	3

Таблица 17 – Нормализованные оценки калькуляторов для уязвимостей CAPEC-300

Уязвимость	$CVSS\ 3.1_{norm}$	$CVSS\ 4.0_{norm}$	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2024-33530	0.75	0.87	0.801	0.5625
CVE-2024-23280	0.75	0.87	0.901	0.475
CVE-2024-21183	0.75	0.87	0.72	0.475
CVE-2024-5535	0.91	0.88	0.112	0.325
CVE-2024-21152	0.81	0.86	0.71	0.4625
CVE-2023-52237	0.75	0.77	0.11	0.4125
CVE-2024-36986	0.63	0.68	0.18	0.5875
CVE-2024-4540	0.75	0.87	0.18	0.4375
CVE-2024-54565	0.62	0.69	0.19	0.3125
CVE-2025-30474	0.75	0.23	0.65	0.5125
CVE-2024-39822	0.65	0.71	0.224	0.65
CVE-2024-41066	0.55	0.68	0.38	0.525
CVE-2025-24071	0.75	0.78	0.53676	0.525
CVE-2024-13131	0.73	0.69	0.35372	0.675
CVE-2024-45336	0.61	0.62	0.26	0.425
CVE-2025-27615	0.82	0.88	0.76	0.325
CVE-2024-21685	0.74	0.81	0.66	0.4625
CVE-2024-34510	0.75	0.87	0.66	0.4625
CVE-2024-53991	0.75	0.87	0.18482	0.5
CVE-2025-47969	0.44	0.67	0.58	0.3

Теперь становится возможным рассчитать для данной группы уязвимостей критичность каждой. Результаты данной работы приведены в таблице 18.

Таблица 18 – Рассчитанные оценки критичностей уязвимостей CAPEC-300

Уязвимость	Значение критичности
CVE-2024-33530	0.754554049
CVE-2024-23280	0.767597876
CVE-2024-21183	0.718231335
CVE-2024-5535	0.655871367
CVE-2024-21152	0.726929544
CVE-2023-52237	0.578285451
CVE-2024-36986	0.556070196
CVE-2024-4540	0.621129264
CVE-2024-54565	0.498561995
CVE-2025-30474	0.570209665
CVE-2024-39822	0.591454986
CVE-2024-41066	0.544271302
CVE-2025-24071	0.65852796
CVE-2024-13131	0.630425023
CVE-2024-45336	0.501179858
CVE-2025-27615	0.729730258
CVE-2024-21685	0.680662591
CVE-2024-34510	0.701588599
CVE-2024-53991	0.633158438
CVE-2025-47969	0.516938101

Теперь проделанная работа позволяет перейти к следующему этапу – построению множества сценариев шаблона атаки CAPEC-300. Результатом построения будет нахождение следующих сценариев:

1. Сценарий, имеющий наибольший риск при реализации техник атак и эксплуатации приводящих к выполнению этих техник уязвимостей.

2. Сценарий, имеющий наименьший риск при реализации техник атак и эксплуатации приводящих к выполнению этих техник уязвимостей.

3. Сценарий, который будет обладать наибольшей вероятностью реализации злоумышленниками.

Для достижения данного результата будет построено множество сценариев, который, в свою очередь, будет сегментирован на несколько возможных подсценариев,

внутри которых будут рассматриваться и ранжироваться по вышеупомянутому показателю риска всевозможные сценарии с приведением вероятно эксплуатируемых уязвимостей, вероятностями их успешной эксплуатации и количественными показателями ущерба, который они могут нанести автоматизированной информационной системе в случае совершения атаки.

Также перед построением сценариев необходимо произвести расчёт значений ущерба для каждой уязвимости. Значение ущерба единичной атаки рассчитывается по формуле [3, 4]:

$$U = 1 - (1 - C) \times (1 - I) \times (1 - A), \quad (3)$$

где: U – значение ущерба от эксплуатации уязвимости;

C – оценка степени влияния уязвимости на конфиденциальность информационных ресурсов;

I – оценка степени влияния уязвимости на целостность информационных ресурсов;

A – оценка степени влияния уязвимости на доступность информационных ресурсов.

Источниками для оценок C, I, A служат векторы CVSS 3.1 для каждой уязвимости. Приведём пример вектора уязвимости с выделенными необходимыми для дальнейших расчётов метриками: *CVSS 3.1: AV:N/AC:H/PR:L/UI:N/S:U/**C:L/I:L/A:L***.

Возможными значениями метрик влияния на конфиденциальность, целостность и доступность уязвимых информационных ресурсов в риск-калькуляторе CVSS 3.1 являются **None**, **Low** или **High**. Для приведения качественных оценок метрик в количественные оценки введём правила перевода оценок и отразим их в таблице 19.

Таблица 19 – Правило перевода качественных оценок метрик в количественные

Качественная оценка метрики CVSS 3.1	Количественная оценка метрики CVSS 3.1
None	0
Low	0.2
High	0.5

Далее займёмся решением задачи расчёта вероятности успешной реализации единичных атак.

Имеем шаблоны атак класса «Методы сканирования портов» согласно системе CAPEC, связанный с ними идентификатор ошибки CWE-200 и группы уязвимостей, связанные с исследуемыми шаблонами атак. Таким образом, предполагая, что при реализации одной атаки может быть проэксплуатирована только одна из уязвимостей в технике, вероятность успешной реализации единичной атаки будет рассчитываться с помощью формулы [5].

$$P_i = \frac{\overline{k_\iota}}{\sum_{i=1}^{n} \overline{k_\iota}}, \quad (4)$$

где: *Pi* – значение вероятности успешной реализации единичной атаки;

i – порядковый номер уязвимости в микромодели;

Ki – значение критичности уязвимости.

Для каждой техники (полной группы событий) сумма вероятностей успешной реализации единичной атаки будет соответственно равна 1.

3.1.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атаки CAPEC-300

Теперь становится возможным выполнить соотношение техник и тактик с уязвимостями, привести для каждой уже рассчитанные значения критичностей и вероятностей успешной реализации единичной атаки, а также рассчитать значения ущерба. Для CAPEC-300 вышеупомянутые данные будут приведены в таблице 20.

Таблица 20 – Соотношение техник и тактик с уязвимостями для CAPEC-300

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Значения ущерба
CAPEC-300	T1590 «Сбор информации об атакуемой сетевой инфраструктуре»	CVE-2024-33530	0.754554049	0.495715333	0.5
		CVE-2024-23280	0.767597876	0.504284667	0.875
	T1659 «Внедрение контента»	CVE-2024-21183	0.718231335	0.52269116	0.5
		CVE-2024-5535	0.655871367	0.47730884	0.75
		ИЛИ			
	T1133 «Внешние службы удаленного доступа»	CVE-2024-21152	0.726929544	0.556942379	0.75
		CVE-2023-52237	0.578285451	0.443057621	0.875
	T1554 «Компрометация бинарных файлов ПО узла»	CVE-2024-36986	0.556070196	0.472367016	0.6
		CVE-2024-4540	0.621129264	0.527632984	0.5
		ИЛИ			
		CVE-2024-54565	0.498561995	0.466481301	0.5
		CVE-2025-30474	0.570209665	0.533518699	0.488
	T1218 «Выполнение с помощью системных бинарных файлов»	CVE-2024-39822	0.591454986	0.329638337	0.5
		CVE-2024-41066	0.544271302	0.303341236	0.5
		CVE-2025-24071	0.65852796	0.367020427	0.5
		ИЛИ			
	T1098 «Манипуляции с учетной записью»	CVE-2024-13131	0.630425023	0.55710702	0.488
		CVE-2024-45336	0.501179858	0.44289298	0.36
	T1649 «Кража или подделка сертификатов аутентификации»	CVE-2025-27615	0.729730258	0.517395036	0.6
		CVE-2024-21685	0.680662591	0.482604964	0.5
	T1606 «Подделка учетных данных для веб-ресурсов»	CVE-2024-34510	0.701588599	0.378891953	0.5
		CVE-2024-53991	0.633158438	0.34193634	0.5
		CVE-2025-47969	0.516938101	0.279171707	0.5

Разведку потенциальный злоумышленник проводит реализацией техники T1590 «Сбор информации об атакуемой сетевой инфраструктуре» эксплуатацией CVE-2024-33530 или CVE-2024-23280.

Первоначальный доступ злоумышленник получает проведением техник T1659 «Внедрение контента» (эксплуатация CVE-2024-21183 или CVE-2024-5535) или

T1133 «Внешние службы удаленного доступа» (CVE-2024-21152 или CVE-2023-52237).

Закрепление нарушитель вероятно производит с помощью техники T1554 «Компрометация бинарных файлов программного обеспечения узла» посредством эксплуатации CVE-2024-36986, CVE-2024-4540, CVE-2024-54565 или CVE-2025-30474.

Повышает привилегии потенциальный злоумышленник путём исполнения техник T1218 «Выполнение с помощью системных бинарных файлов» (эксплуатация CVE-2024-39822, CVE-2024-41066 или CVE-2025-24071) или T1098 «Манипуляции с учетной записью» (эксплуатация CVE-2024-13131 или CVE-2024-45336).

Получение учётных данных вероятно происходит посредством реализации техник T1649 «Кража или подделка сертификатов аутентификации» (эксплуатация CVE-2025-27615 или CVE-2024-21685) или T1606 «Подделка учетных данных для веб-ресурсов» (эксплуатация CVE-2024-34510, CVE-2024-53991 или CVE-2025-47969).

Визуализируем множество сценариев на рисунке 7 согласно данным таблицы 20.

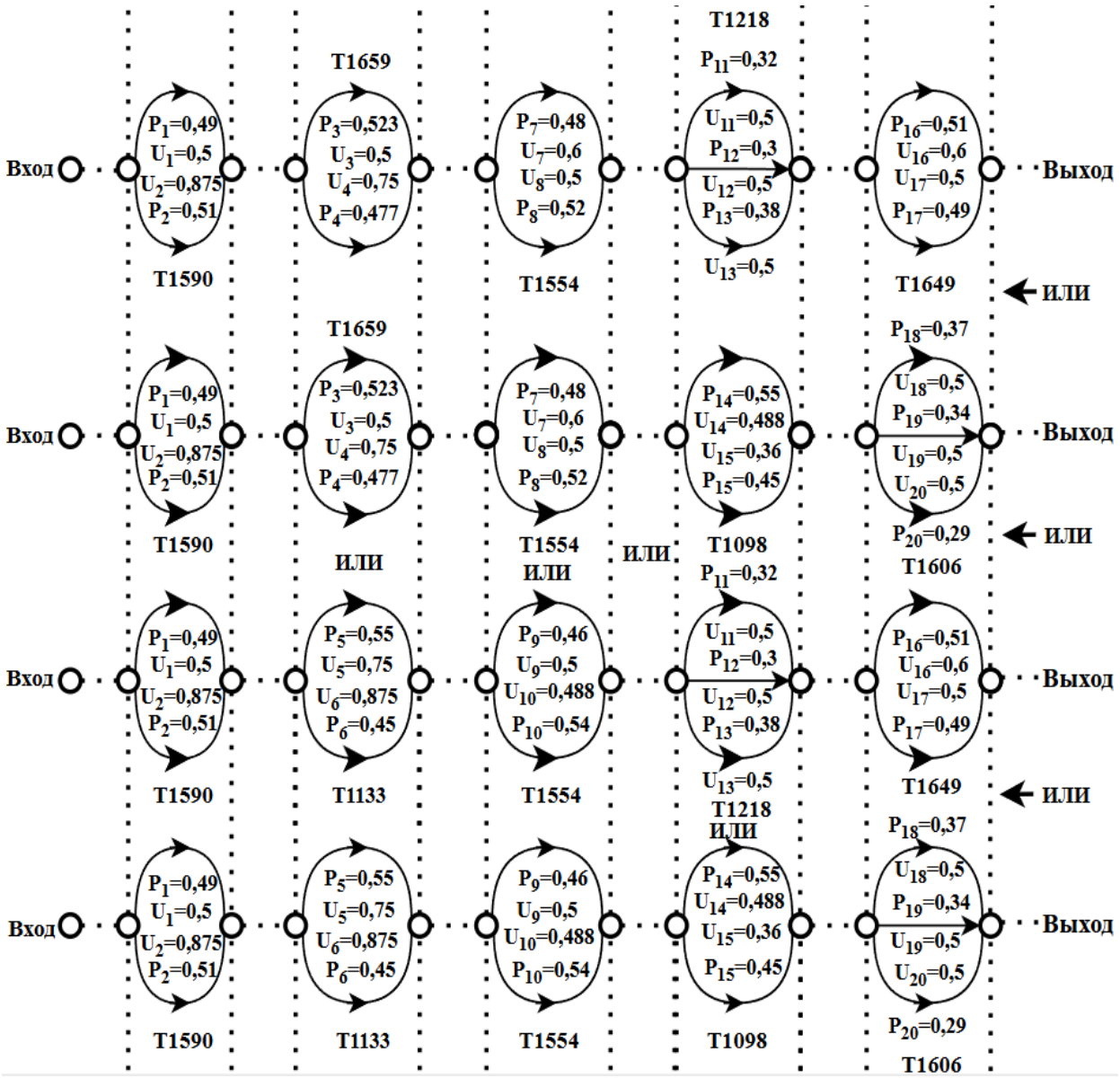


Рисунок 7 – Множество сценариев шаблоана атаки CAPEC-300

Далее целесообразно выделить «уникальные» для данного множества сценариев микромодели и конкретизировать имеющуюся информацию о вероятностях успешной эксплуатации уязвимостей и значениях ущерба от их эксплуатации.

На рисунках 8-16 проиллюстрированы микромодели множества сценариев шаблона атаки CAPEC-300, а в таблицах 21-29 систематизированы значения вероятностей успешной эксплуатации уязвимостей и значения ущерба от их эксплуатации.

Таблица 21 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 1 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-33530	0.495715333	0.5
CVE-2024-23280	0.504284667	0.875

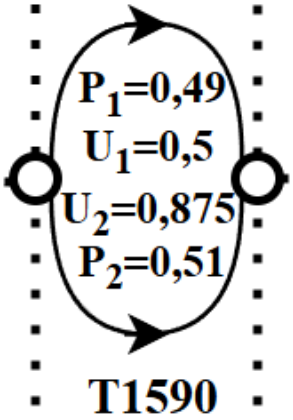


Рисунок 8 – Микромодель 1 для множества сценариев шаблона атаки CAPEC-300

Таблица 22 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 2 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-21183	0.52269116	0.5
CVE-2024-5535	0.47730884	0.75

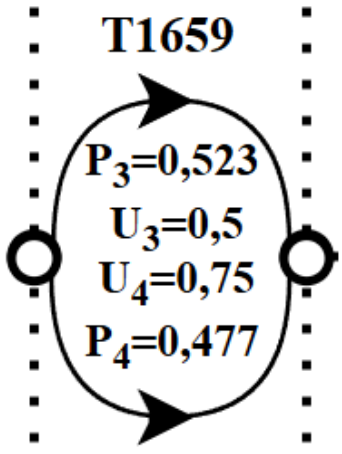


Рисунок 9 – Микромодель 2 для множества сценариев шаблона атаки CAPEC-300

Таблица 23 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 3 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-21152	0.556942379	0.75
CVE-2023-52237	0.443057621	0.875

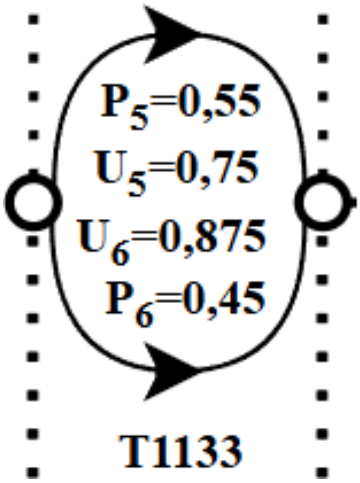


Рисунок 10 – Микромодель 3 для множества сценариев шаблона атаки CAPEC-300

Таблица 24 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 4 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-36986	0.472367016	0.6
CVE-2024-4540	0.527632984	0.5

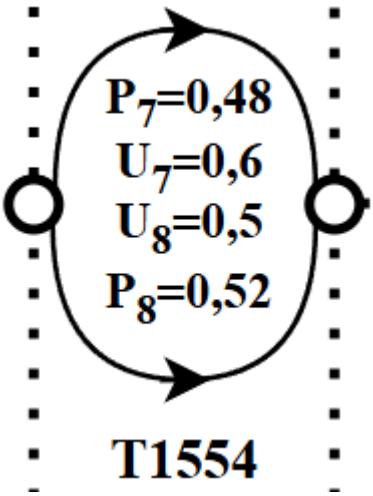


Рисунок 11 – Микромодель 4 для множества сценариев шаблона атаки CAPEC-300

Таблица 25 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 5 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-54565	0.466481301	0.5
CVE-2025-30474	0.533518699	0.488

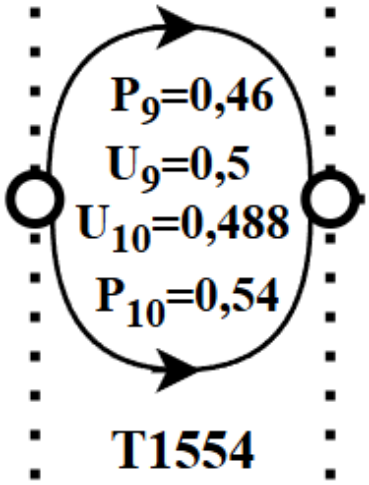


Рисунок 12 – Микромодель 5 для множества сценариев шаблона атаки CAPEC-300

Таблица 26 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 6 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-39822	0.329638337	0.5
CVE-2024-41066	0.303341236	0.5
CVE-2025-24071	0.367020427	0.5

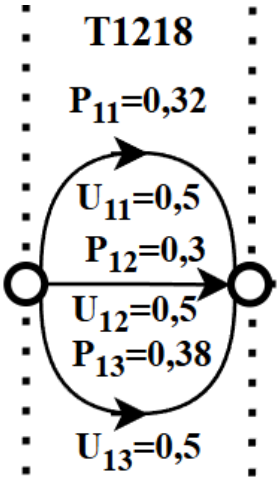


Рисунок 13 – Микромодель 6 для множества сценариев шаблона атаки CAPEC-300

Таблица 27 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 7 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-13131	0.55710702	0.488
CVE-2024-45336	0.44289298	0.36

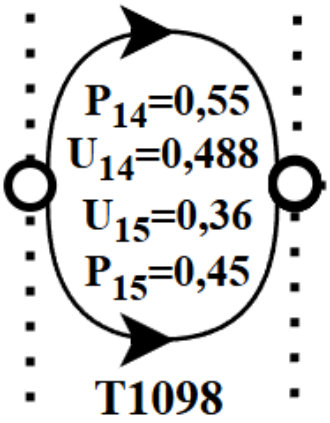


Рисунок 14 – Микромодель 7 для множества сценариев шаблона атаки CAPEC-300

Таблица 28 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 8 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2025-27615	0.517395036	0.6
CVE-2024-21685	0.482604964	0.5

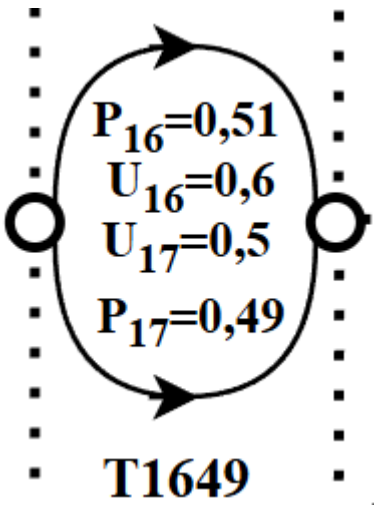


Рисунок 15 – Микромодель 8 для множества сценариев шаблона атаки CAPEC-300

Таблица 29 – Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 9 для CAPEC-300

Уязвимость атакуемой системы, вероятно эксплуатируемая заданной техникой	Вероятность успешной эксплуатации уязвимости атакуемой системы	Ущерб
CVE-2024-34510	0.378891953	0.5
CVE-2024-53991	0.34193634	0.5
CVE-2025-47969	0.279171707	0.5

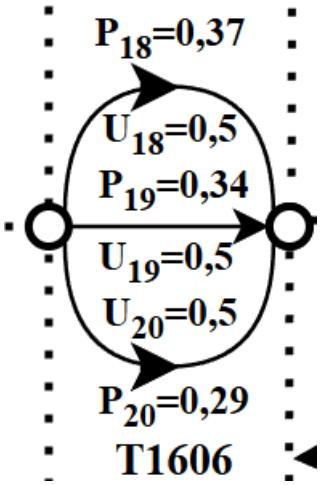


Рисунок 16 – Микромодель 9 для множества сценариев шаблона атаки CAPEC-300

После выделения микромоделей и систематизации имеющихся данных об уязвимостях становится возможным сформировать подсценарии из множества сценариев и произвести оценку рисков.

Риск сценария определяется как произведение вероятностей успешной реализации единичной атаки при эксплуатации соответствующих уязвимостей, умноженное на сумму значений ущерба, причиняемого каждой из уязвимостей. Таким образом, риск конкретного сценария будет рассчитываться по формуле [6].

$$Risk = \prod_{i=1}^{k} p_i \times \sum_{j=1}^{k} U_j, \quad (5)$$

где: *Risk* – риск сценария;

k – количество используемых техник;

p_i – вероятность успеха реализации единичной атаки;

U_j – значение ущерба от эксплуатации уязвимости при совершении единичной атаки.

3.1.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-300

После проделанной работы можно приступить к разработке подсценариев и расчёта рисков их сценариев для шаблона атаки CAPEC-300. На рисунке 17 проиллюстрирован подсценарий 1, а в таблице 30 приведены сценарии и результаты расчётов соответствующих им рисков.

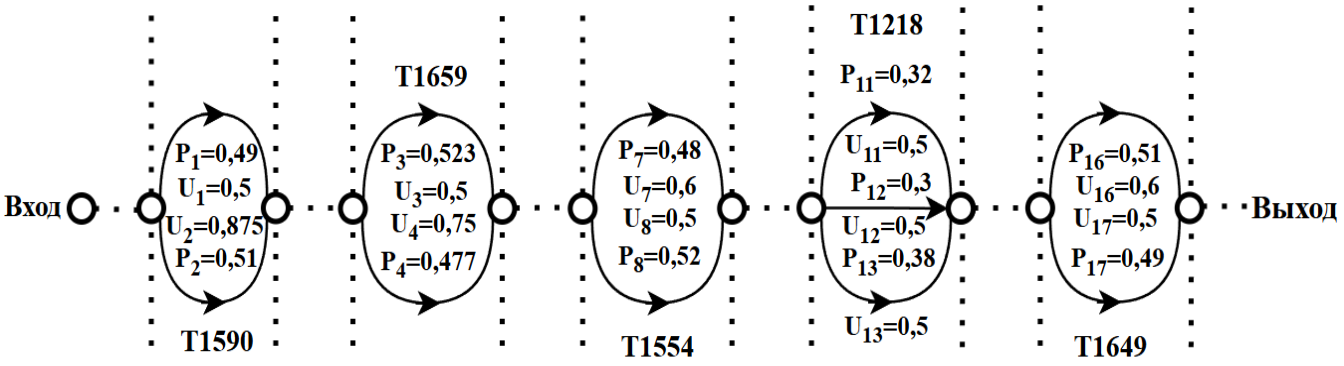


Рисунок 17 – Подсценарий 1 шаблона атаки CAPEC-300

Таблица 30 – Результаты расчёта рисков для подсценария 1 шаблона атаки CAPEC-300

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.056361274892906085
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.05062440350938201
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05186501953669879
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	**0.04658581059489653**
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06275283198464496
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.05636538019736971

Продолжение таблицы 30

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.060623745457885764
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.054372456207285765
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05578744889173633
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05003486008447475
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06749868096893276
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06053847460781486
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.05623327569740025
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.05067406612101927
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05174723155570997
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.04663151134115724
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.0626103172522332
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.056420674715279624
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.06068321743815538
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.054616763368019065
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05584217645821581
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.050259677491257426
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06756489727068861
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06081048701774125
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.06529885639827535
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.0589273556040323
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.0600895999825389
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05422638958143598
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.07270396512741385
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06560991483151661

Продолжение таблицы 30

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.0705666982522197
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.06360923955590589
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.06493719651384895
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.058534773362567294
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	**0.078569197867631**
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.07082274008363859
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.0644772383184791
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.05833296126264181
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05933352699019961
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05367941341407109
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.0717891728091959
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.0649481141836644
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.06985489902583698
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.06313740076518348
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.06428218150837409
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05810057580146725
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.07777667822812907
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.07029739319582773

По итогам расчётов возможно выделить сценарий с максимальным, минимальным значениями риска и самый вероятный для исполнения сценарий.

Максимальным риском обладает сценарий на рисунке 18. Это T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615), где Risk = 0.078569197867631.

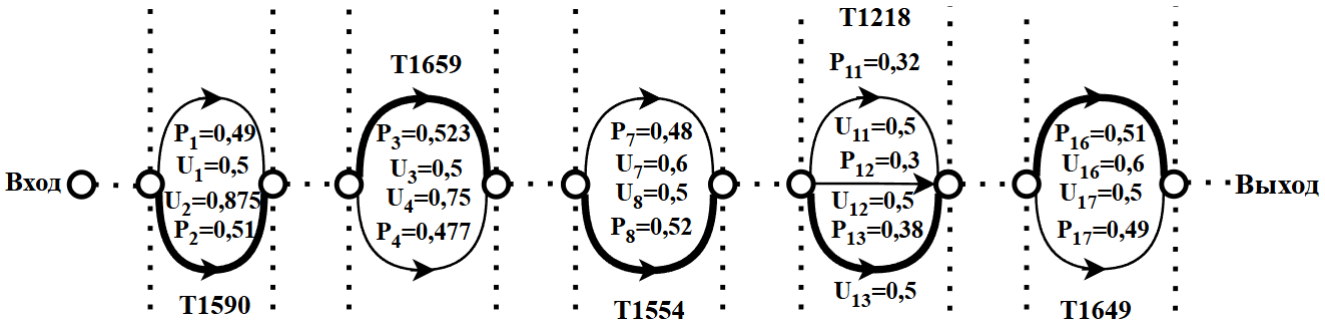


Рисунок 18 – Сценарий с наибольшим риском подсценария 1 шаблона атаки CAPEC-300

Минимальным риском обладает сценарий на рисунке 19. Это T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685), где Risk = 0.04658581059489653.

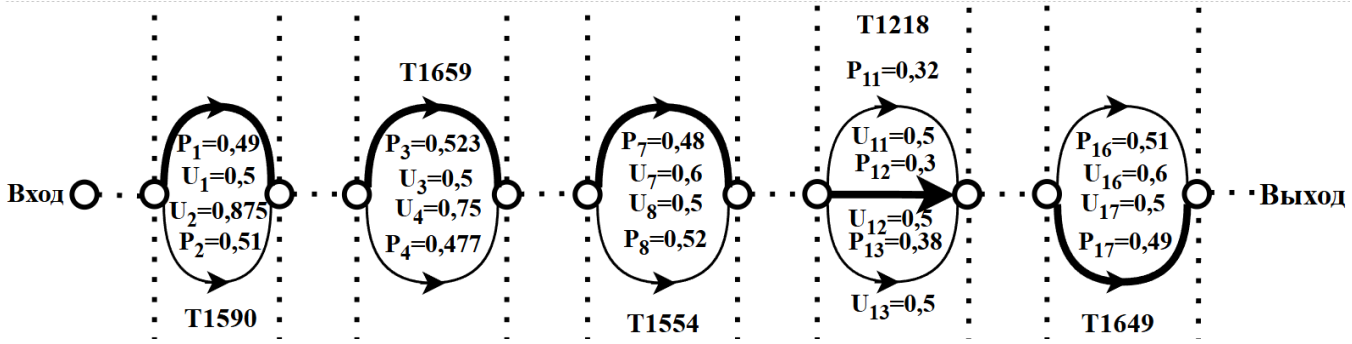


Рисунок 19 – Сценарий с наименьшим риском подсценария 1 шаблона атаки CAPEC-300

Наибольшую вероятность реализации имеет сценарий, проиллюстрированный на рисунке 20. Вероятность вычисляется произведением максимальных значений вероятностей успешной реализации атаки внутри техник: P_1 = 0.504284667 × × 0.52269116 × 0.527632984 × 0.367020427 × 0.517395036 = 0.02640981440928773.

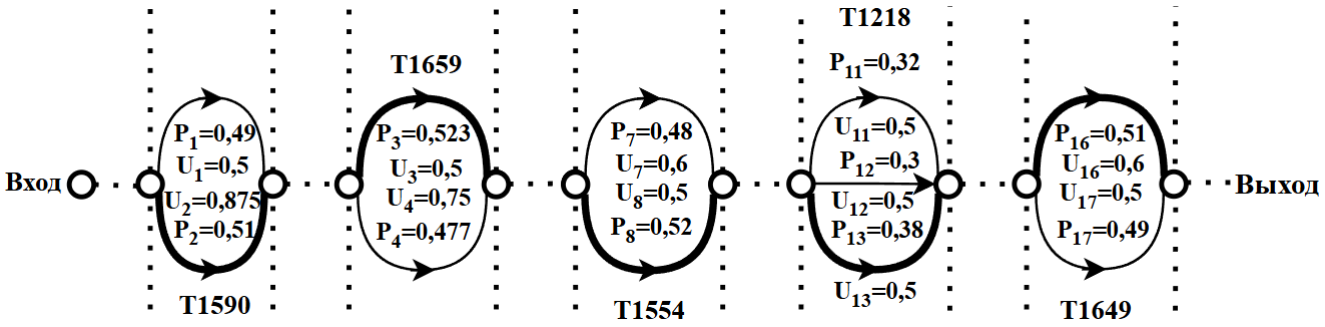


Рисунок 20 – Сценарий с наибольшим значением вероятности реализации для подсценария 1 шаблона атаки CAPEC-300

Теперь перейдём к рассмотрению подсценария 2. Он изображён на рисунке 21. А в таблице 31 приведём сценарии этого подсценария и результаты расчётов рисков для них.

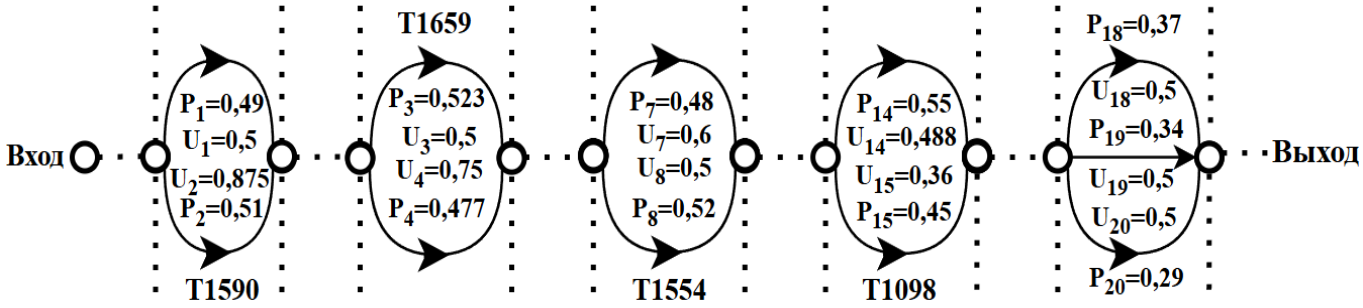


Рисунок 21 - Подсценарий 2 шаблона атаки CAPEC-300

Таблица 31 - Результаты расчёта рисков для подсценария 2 шаблона атаки CAPEC-300

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.06686138316677079
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06033998997963203
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.049264193454772225
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05052500409805872
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.04559699630193835
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	**0.03722737188941315**

Продолжение таблицы 31

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07179824571166554
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06479533060198724
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.052901727408634344
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05414216594395264
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.048861354578696496
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.0398925360319028
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.06695419585753956
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06042375008996361
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.04933257885358586
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05082704529657243
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.04586957760415722
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.037449919125652285
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07215247340482793
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06511500833588356
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.05316272622104992
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.054678734253462154
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.04934558815098795
T1590 (CVE-2024-33530) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.040287885391269845
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.0778728639699701
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.07027745477405123
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.05737757213195644
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.059233544955339
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.05345614074642034
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.043643919396839835

Продолжение таблицы 31

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	**0.08404816114822798**
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.07585043804494648
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.06192759817720881
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.06382992945788452
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.057604212199479504
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04703058543037256
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07711156972646907
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06959041414089795
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.056816642263151716
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05886052784945555
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.053119506244332676
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04336907634101573
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.0834526844693453
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.0753130417911588
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.06148884449134637
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.06361590237148604
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.057411060463200846
T1590 (CVE-2024-23280) -> T1659 (CVE-2024-5535) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.046872887948066565

Максимальным риском обладает сценарий, демонстрируемый на рисунке 22. Это T1590 (CVE-2024-23280) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-4540) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510), где Risk = 0.08404816114822798.

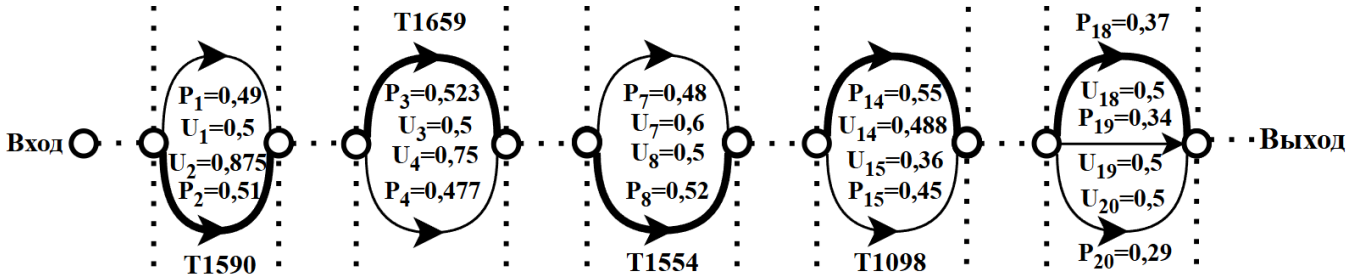


Рисунок 22 – Сценарий с наибольшим риском подсценария 2 шаблона атаки CAPEC-300

Минимальным риском обладает сценарий на рисунке 23. Это T1590 (CVE-2024-33530) -> T1659 (CVE-2024-21183) -> T1554 (CVE-2024-36986) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969), где Risk = 0.03722737188941315.

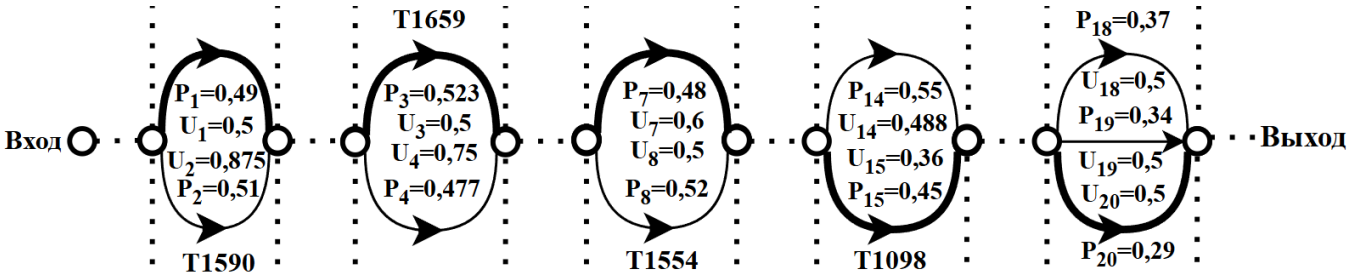


Рисунок 23 – Сценарий с наименьшим риском подсценария 2 шаблона атаки CAPEC-300

Наибольшую вероятность реализации имеет сценарий, приведённый на рисунке 24. P_2 = 0.504284667 × 0.52269116 × 0.527632984 × 0.55710702 × 0.378891953 = 0.029356675217683544.

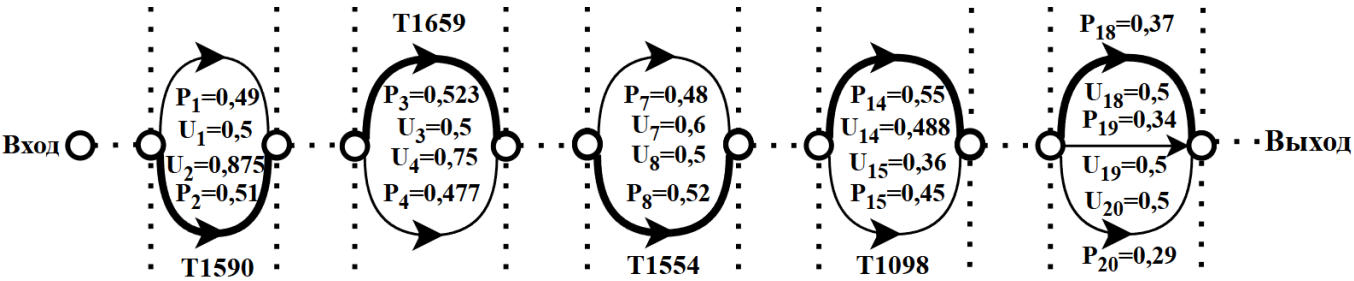


Рисунок 24 – Сценарий с наибольшим значением вероятности реализации для подсценария 2 шаблона атаки CAPEC-300

Перейдём к анализу подсценария 3. Он изображён на рисунке 25. А в таблице 32 приведены сценарии этого подсценария и рассчитанные риски для них.

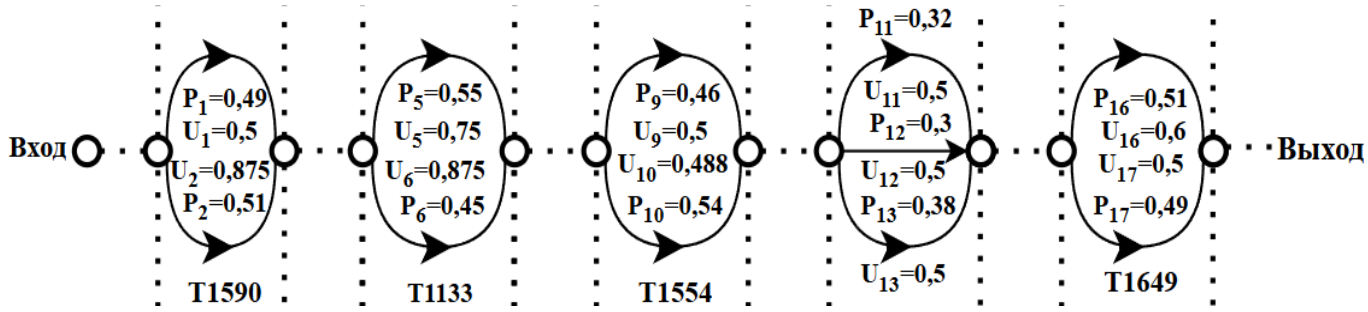


Рисунок 25 – Подсценарий 3 шаблона атаки CAPEC-300

Таблица 32 - Результаты расчёта рисков для подсценария 3 шаблона атаки CAPEC-300

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.059306267738353895
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.05326963299405
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05457507376728211
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.04902001527110455
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06603179686926697
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.059310587553442
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.06531690283869677
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.058581673111234966
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.06010620675708053
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05390828412203154
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.07272405809454136
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06522503078778691
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.05154764053508371
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.046451651846028376

Продолжение таблицы 32

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.04743539581925508
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	**0.04274594276094753**
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.0573933153898569
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.05171942453824682
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.0569569914375588
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.051263045283809816
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.05241321242774776
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.04717350432912432
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06341610477803185
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.0570764460851658
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.06871085630910506
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.062006431458593504
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.06322940550274142
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.05705983026664473
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.07650289724069134
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06903816818697037
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.07602958442397452
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.06853351749114098
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.06996427758260043
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.06306621399801056
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	**0.08465159360368839**
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.07630544760760193
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.059104675342424404
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.0534723698952618

Продолжение таблицы 32

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.054389563528679435
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.04920657871137697
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.06580734322134678
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.059536315497371685
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2025-27615)	0.0655654899930282
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-39822) -> T1649 (CVE-2024-21685)	0.059260476727972036
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2025-27615)	0.060334962718340636
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685)	0.054532935762906354
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615)	0.07300083586365573
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2024-21685)	0.06598081300514466

Максимальным риском обладает сценарий на рисунке 26. Это T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1218 (CVE-2025-24071) -> T1649 (CVE-2025-27615), где Risk = 0.08465159360368839.

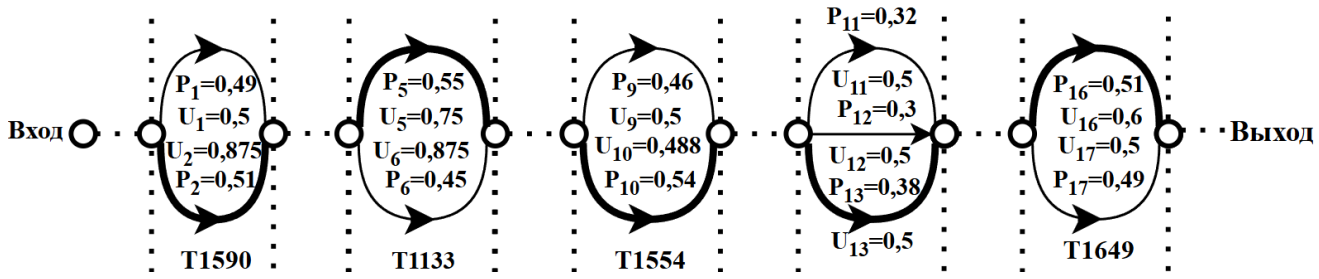


Рисунок 26 – Сценарий с максимальным риском для подсценария 3 шаблона атаки CAPEC-300

Минимальным риском обладает сценарий на рисунке 27. Это T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1218 (CVE-2024-41066) -> T1649 (CVE-2024-21685), где Risk = 0.04274594276094753.

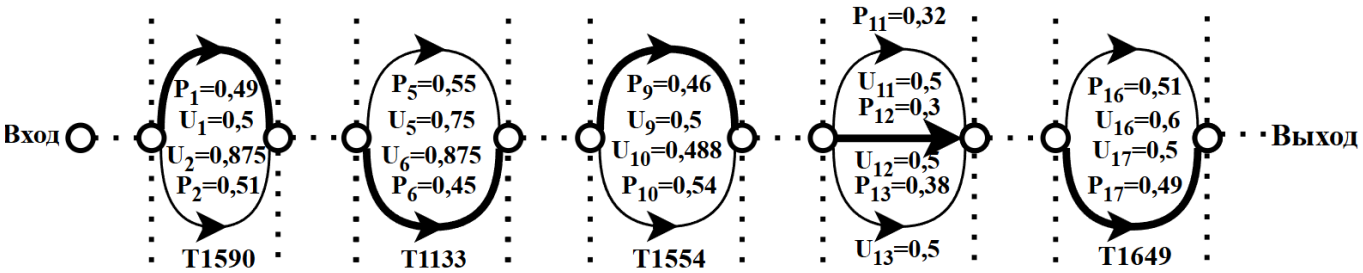


Рисунок 27 – Сценарий с минимальным риском подсценария 3 шаблона атаки CAPEC-300

Наибольшей вероятностью реализации обладает сценарий, проиллюстрированный на рисунке 28. $P_3 = 0.504284667 \times 0.556942379 \times 0.533518699 \times 0.367020427 \times \times 0.517395036 = 0.02845431717771038$.

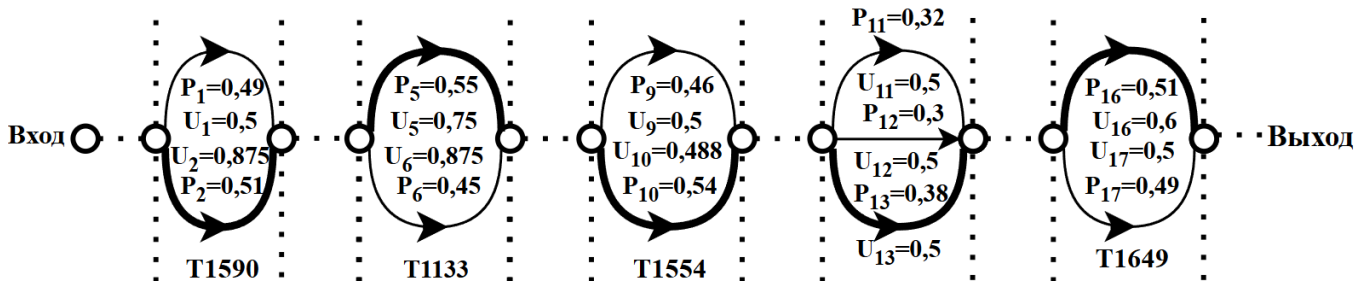


Рисунок 28 – Сценарий с наибольшим значением вероятности реализации для подсценария 3 шаблона атаки CAPEC-300

Перейдём к исследованию подсценария 4 шаблона атаки CAPEC-300. На рисунке 29 приведено его изображение на основном сценарии, а в таблице 33 приведены в соответствие возможные сценарии этого подсценария и результаты расчётов рисков для них.

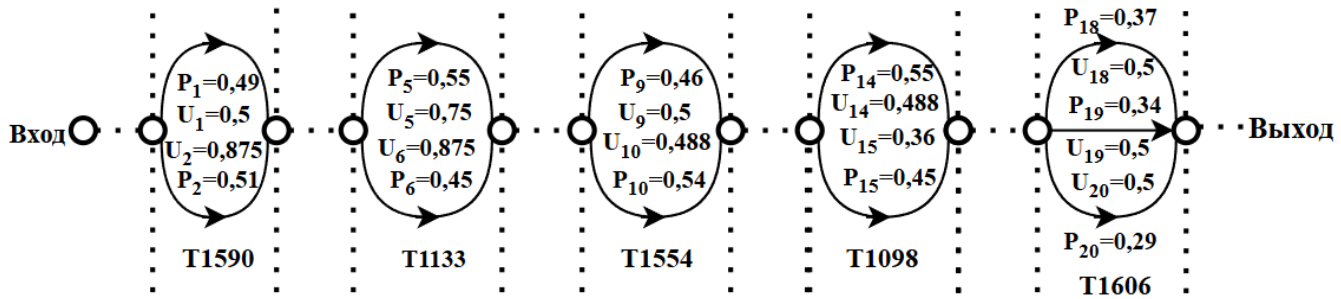


Рисунок 29 – Подсценарий 4 шаблона атаки CAPEC-300

Таблица 33 – Результаты расчёта рисков для подсценария 4 шаблона атаки CAPEC-300

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07443279271640037
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.0671729143781119
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.05484289026168539
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05640681047547791
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.0509051146965335
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04156115072431915
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.08475632691801509
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.07648953214424577
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.06244938240942879
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.06421634576084782
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.0579529389942964
T1590 (CVE-2024-33530) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04731530116016504
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.06191589625415207
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.05587686617605329
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.045620304973081706
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.047021698467076406
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.042435389158068805
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	**0.034646098242928386**
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07051693684145142
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06363899549900724
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.051957645113775174
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.053543163682550174
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.04832077661367521

Продолжение таблицы 33

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.03945118465854021
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.08609013761568851
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.07769324825540662
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.06343214862110484
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.06562643040822966
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.059225489597702685
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.048354266846575594
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	**0.0980824833744631**
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.08851590834175029
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.07226823925301992
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.07475577736584221
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.06746439639041615
T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.055080868860084065
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.07123625361354152
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.06428815297622899
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.05248764552562906
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.05439322156636706
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.049087923234972006
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04007751654179867
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510)	0.08117157929026196
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-53991)	0.07325442653180858
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2025-47969)	0.05980810141499173
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-34510)	0.06196995942733305
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2024-53991)	0.0559256562425087

Продолжение таблицы 33

Сценарий в формате «техника (уязвимость)»	Риск
T1590 (CVE-2024-23280) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969)	0.04566013930638773

Максимальный риск имеет сценарий на рисунке 30. Это T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510), где Risk = 0.0980824833744631.

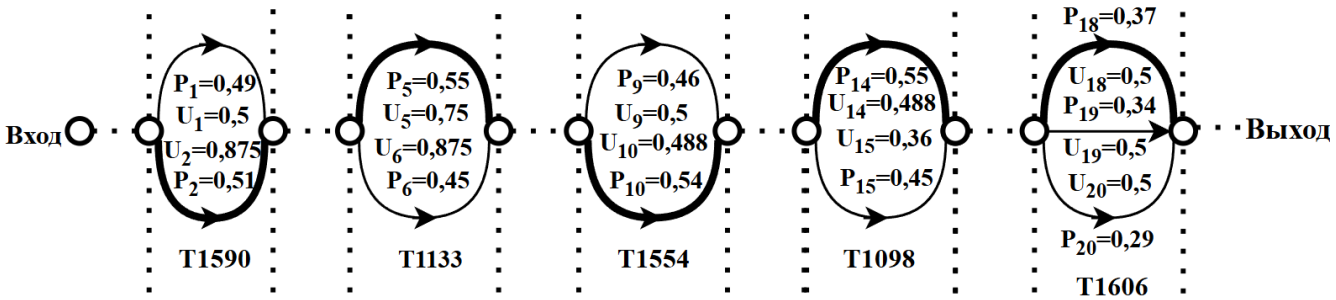


Рисунок 30 – Сценарий с максимальным риском подсценария 4 шаблона атаки CAPEC-300

Минимальным риском обладает сценарий на рисунке 31. Это T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969), где Risk = 0.034646098242928386.

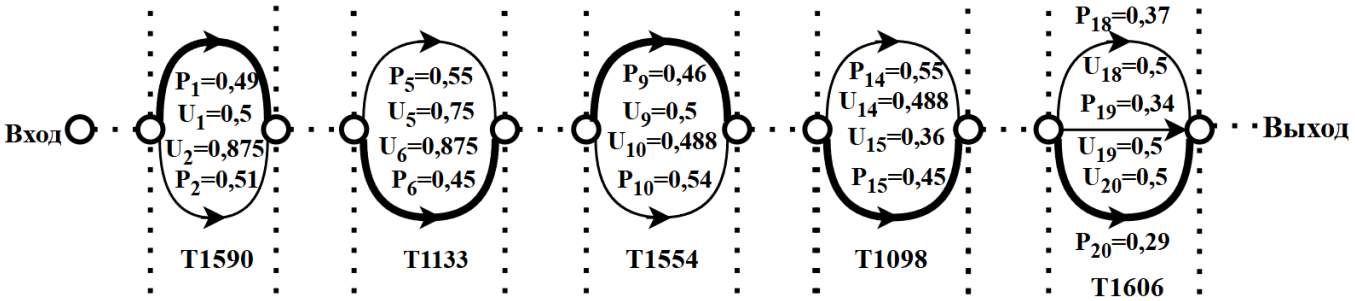


Рисунок 31 – Сценарий с минимальным значением риска подсценария 4 шаблона атаки CAPEC-300

Наибольшую вероятность реализации имеет сценарий, проиллюстрированный на рисунке 32. P_4 = 0.504284667 × 0.556942379 × 0.533518699 × 0.55710702 × × 0.378891953 = 0.0316293077634515.

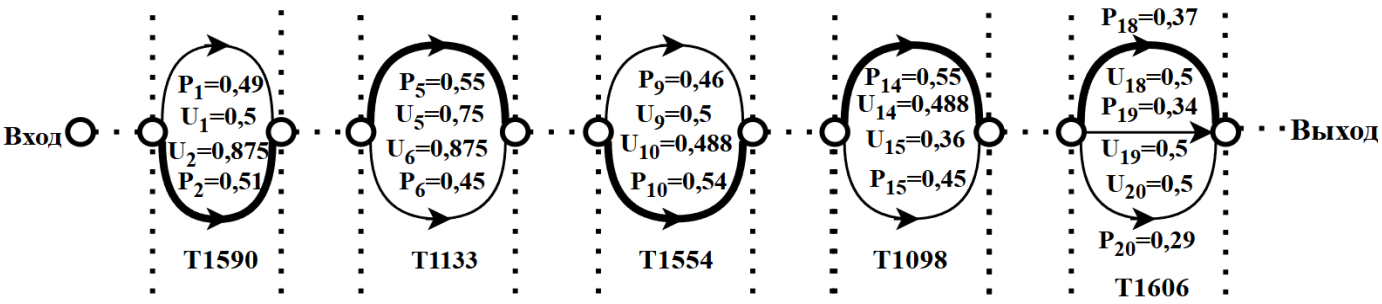


Рисунок 32 – Сценарий с наибольшим значением вероятности реализации для подсценария 4 шаблона атаки CAPEC-300

После проделанной работы можно сделать более конкретные выводы в контексте всего множества сценариев.

Сценарий с наибольшим риском изображён на рисунке 33 - подсценарий 4 - T1590 (CVE-2024-23280) -> T1133 (CVE-2024-21152) -> T1554 (CVE-2025-30474) -> T1098 (CVE-2024-13131) -> T1606 (CVE-2024-34510), где Risk = 0.0980824833744631.

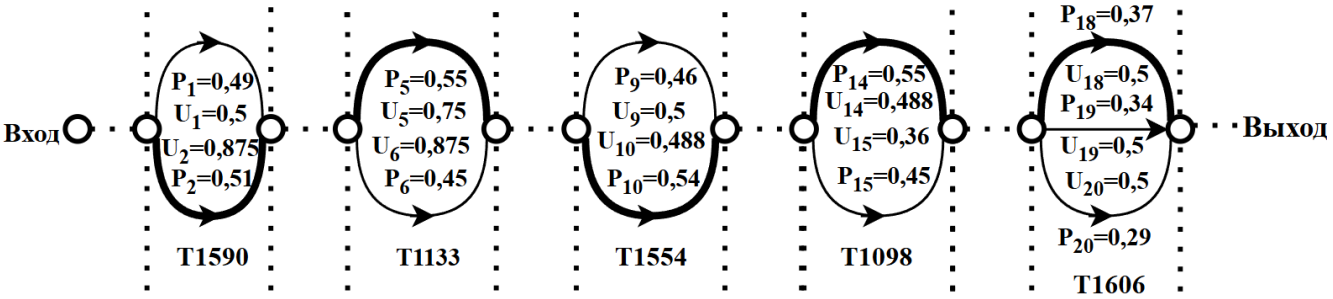


Рисунок 33 – Сценарий с наибольшим риском всего множества сценариев шаблона атаки CAPEC-300

Сценарий с наименьшим риском изображён на рисунке 34 – подсценарий 4 - T1590 (CVE-2024-33530) -> T1133 (CVE-2023-52237) -> T1554 (CVE-2024-54565) -> T1098 (CVE-2024-45336) -> T1606 (CVE-2025-47969), где Risk = 0.034646098242928386.

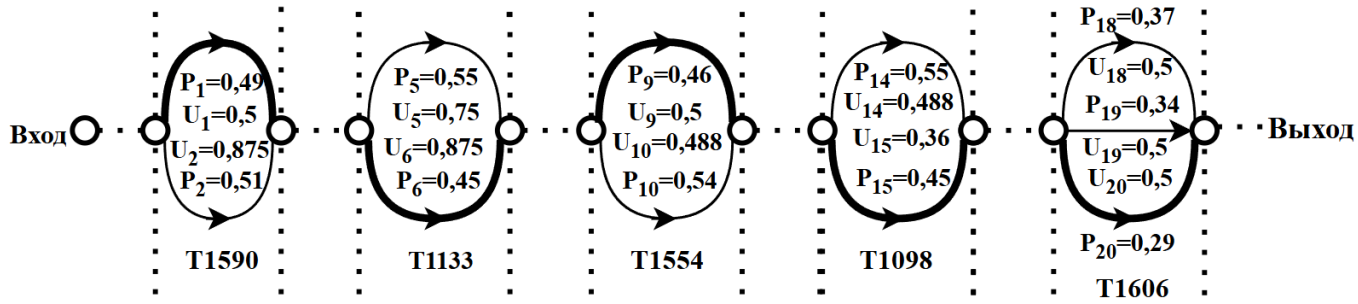


Рисунок 34 – Сценарий с наименьшим риском всего множества сценариев шаблона атаки CAPEC-300

Наибольшей вероятностью реализации обладает сценарий, изображённый на рисунке 35 – подсценарий 4 - P = 0.504284667 × 0.556942379 × 0.533518699 × × 0.55710702 × 0.378891953 = 0.0316293077634515.

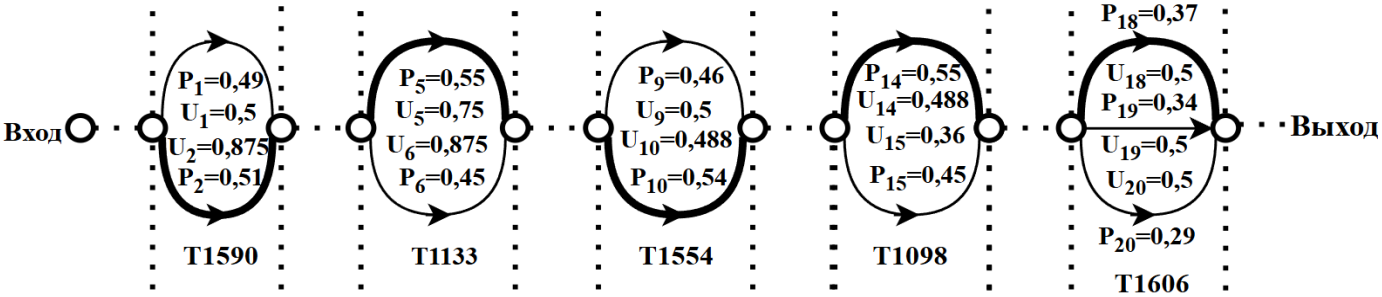


Рисунок 35 – Сценарий с наибольшим значением вероятности реализации для всего множества сценариев шаблона атаки CAPEC-300

3.2 Формирование сценариев CAPEC-305 в виде последовательности реализации техник MITRE ATT&CK

3.2.1 Оценка критичности группы уязвимостей, связанной с CAPEC-305

Далее приступим к оценке рисков реализации шаблона атаки CAPEC-305. В начале необходимо привести оценки риск-калькуляторов для каждой уязвимости. В таблице 34 приведены оценки риск-калькуляторов для группы уязвимостей шаблона атаки CAPEC-305.

Таблица 34 - Оценки риск-калькуляторов для уязвимостей, связанных с CAPEC-305

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2025-47966	9.8	9.3	0.156	6.875
CVE-2025-32044	7.5	8.7	0.83	4
CVE-2025-24226	5.5	5.2	0.17	6.125
CVE-2024-49723	3.3	4.8	0.1823	4.625
CVE-2025-5064	5.4	5.5	0.63	5.75
CVE-2025-5054	4.7	5.7	0.11	3.125
CVE-2024-45245	7.8	8.5	0.34	5.25
CVE-2025-24899	6.5	7.1	0.7	5.75
CVE-2024-31817	7.5	8.7	0.9053	6.875
CVE-2024-29960	6.8	8.5	0.91	4.125
CVE-2025-3035	8.6	8.8	0.43	6.5
CVE-2025-29805	7.5	8.7	0.99	5.375
CVE-2025-24204	9.8	9.3	0.67	6.25
CVE-2024-8884	9.8	9.3	0.166	4.5
CVE-2023-32191	10	10	0.164	3.25
CVE-2024-30300	9.8	9.3	0.712	6.625
CVE-2024-42256	9.8	9.3	0.28	6.75
CVE-2025-31225	7.1	7.1	0.42	3.625
CVE-2025-22218	8.5	9	0.121	6.25
CVE-2025-29846	7.2	8.6	0.1653	6.625

Проведём нормализацию полученных оценок и сведём обновлённые данные в таблицу 35.

Таблица 35 – Нормализованные оценки риск-калькуляторов для уязвимостей, связанных с CAPEC-305

Уязвимость	$CVSS\ 3.1_{norm}$	$CVSS\ 4.0_{norm}$	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2025-47966	0.98	0.93	0.156	0.6875
CVE-2025-32044	0.75	0.87	0.83	0.4
CVE-2025-24226	0.55	0.52	0.17	0.6125
CVE-2024-49723	0.33	0.48	0.1823	0.4625
CVE-2025-5064	0.54	0.55	0.63	0.575
CVE-2025-5054	0.47	0.57	0.11	0.3125
CVE-2024-45245	0.78	0.85	0.34	0.525
CVE-2025-24899	0.65	0.71	0.7	0.575
CVE-2024-31817	0.75	0.87	0.9053	0.6875
CVE-2024-29960	0.68	0.85	0.86	0.4125
CVE-2025-3035	0.86	0.88	0.43	0.65
CVE-2025-29805	0.75	0.87	0.99	0.5375
CVE-2025-24204	0.98	0.93	0.67	0.625
CVE-2024-8884	0.98	0.93	0.166	0.45
CVE-2023-32191	1	1	0.164	0.325
CVE-2024-30300	0.98	0.93	0.712	0.6625

Продолжение таблицы 35

Уязвимость	CVSS 3.1_{norm}	CVSS 4.0_{norm}	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2024-42256	0.98	0.93	0.28	0.675
CVE-2025-31225	0.71	0.71	0.42	0.3625
CVE-2025-22218	0.85	0.9	0.121	0.625
CVE-2025-29846	0.72	0.86	0.1653	0.6625

Теперь возможен расчёт критичности каждой уязвимости. Приведём эти данные в таблице 36.

Таблица 36 – Критичности уязвимостей, связанных с шаблоном атаки CAPEC-305

Уязвимость	Значение критичности
CVE-2025-47966	0.761953452
CVE-2025-32044	0.736257428
CVE-2025-24226	0.494205486
CVE-2024-49723	0.382896703
CVE-2025-5064	0.574809751
CVE-2025-5054	0.404832141
CVE-2024-45245	0.656148802
CVE-2025-24899	0.660913194
CVE-2024-31817	0.808026042
CVE-2024-29960	0.723646366
CVE-2025-3035	0.72825133
CVE-2025-29805	0.804426232
CVE-2025-24204	0.816214586
CVE-2024-8884	0.716825641
CVE-2023-32191	0.730157688
CVE-2024-30300	0.83233861
CVE-2024-42256	0.76800472
CVE-2025-31225	0.573586578
CVE-2025-22218	0.696018319
CVE-2025-29846	0.656549758

3.2.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-305

Далее совместно с расчётом значений ущерба и вероятностей успешной эксплуатации данной группы уязвимостей приведём в таблице 37 соотношение техник и тактик с уязвимостями.

Таблица 37 – Соотношение тактик и техник с уязвимостями, связанными с шаблоном атаки CAPEC-305

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Значения ущерба
1	2	3	4	5	6
CAPEC-305	T1133 «Внешние службы удаленного доступа»	CVE-2025-47966	0.761953452	0.50857557	0.875
		CVE-2025-32044	0.736257428	0.49142443	0.5
	T1648 «Бессерверное выполнение»	CVE-2025-24226	0.494205486	0.563452574	0.5
		CVE-2024-49723	0.382896703	0.436547426	0.2
		ИЛИ			
	T1204 «Выполнение с участием пользователя»	CVE-2025-5064	0.574809751	0.586754972	0.36
		CVE-2025-5054	0.404832141	0.413245028	0.5
	T1036.004 «Маскировка задачи или службы»	CVE-2024-45245	0.656148802	0.49819128	0.875
		CVE-2025-24899	0.660913194	0.50180872	0.5
		ИЛИ			
		CVE-2025-24204	0.808026042	0.527544949	0.5
		CVE-2024-8884	0.723646366	0.472455051	0.875
	T1562.006 «Блокировка сбора признаков активности»	CVE-2024-31817	0.72825133	0.47514973	0.68
		CVE-2024-29960	0.804426232	0.52485027	0.5
		ИЛИ			
		CVE-2025-3035	0.816214586	0.532415635	0.875
		CVE-2025-29805	0.716825641	0.467584365	0.5
	T1210 «Эксплуатация уязвимостей в удаленных службах»	CVE-2023-32191	0.730157688	0.467302027	0.875
		CVE-2024-30300	0.83233861	0.532697973	0.875
		ИЛИ			
		CVE-2024-42256	0.76800472	0.572458036	0.875
		CVE-2025-31225	0.573586578	0.427541964	0.6
	T1119 «Автоматизированный сбор данных»	CVE-2025-22218	0.696018319	0.514590231	0.875
		CVE-2025-29846	0.656549758	0.485409769	0.875

Первоначальный доступ злоумышленник получает реализацией техники T1133 «Внешние службы удаленного доступа» эксплуатацией CVE-2025-47966 или CVE-2025-32044.

Тактика «Выполнение» реализуется с помощью техник T1648 «Бессерверное выполнение» (эксплуатация CVE-2025-24226 или CVE-2024-49723) или T1204 «Выполнение с участием пользователя» (эксплуатация CVE-2025-5064 или CVE-2025-5054).

Предотвращение обнаружения злоумышленник производит техниками T1036.004 «Маскировка задачи или службы» (эксплуатация CVE-2024-45245, CVE-2025-24899, CVE-2025-24204 или CVE-2024-8884) или T1562.006 «Блокировка сбора признаков активности» (эксплуатацией CVE-2024-31817, CVE-2024-29960, CVE-2025-3035 или CVE-2025-29805).

Осущесствляет перемещение внутри периметра потенциальный нарушитель путём реализации техник T1210 «Эксплуатация уязвимостей в удаленных службах» с эксплуатацией CVE-2023-32191, CVE-2024-30300, CVE-2024-42256 или CVE-2025-31225.

Сбор данных вероятно производится техникой T1119 «Автоматизированный сбор данных» с эксплуатацией CVE-2025-22218 или CVE-2025-29846.

Визуализируем данные таблицы 37 с помощью рисунка 36.

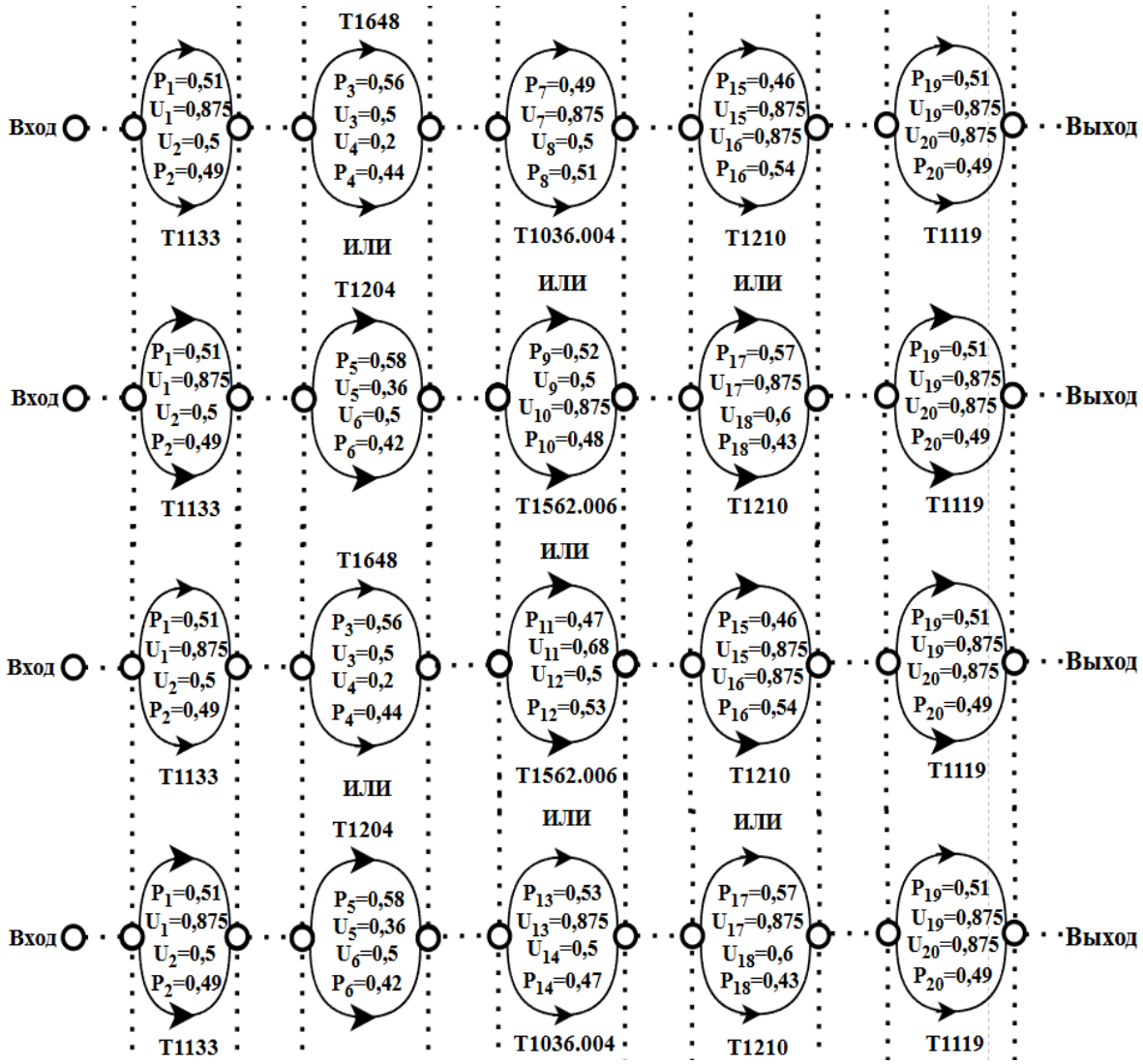


Рисунок 36 – Множество сценариев шаблона атаки CAPEC-305

Далее необходимо выделить микромодели данного множества сценариев и агрегировать необходимые для формирования подсценариев параметры этих микромоделей. На рисунках 37-46 приведены иллюстрации микромоделей, а в таблицах 38-47 сведены параметры вероятности успешной эксплуатации и значения ущерба соответствующих техникам уязвимостей.

Таблица 38 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 1 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-47966	0.50857557	0.875
CVE-2025-32044	0.49142443	0.5

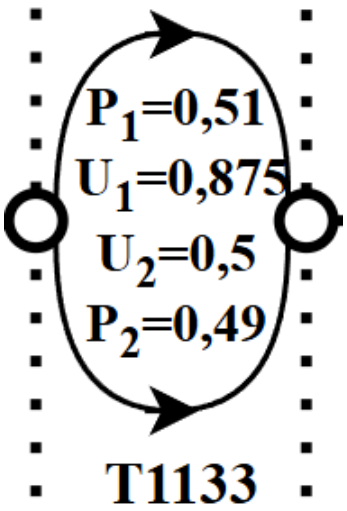


Рисунок 37 – Микромодель 1 множества сценариев шаблона атаки CAPEC-305

Таблица 39 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 2 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-24226	0.563452574	0.5
CVE-2024-49723	0.436547426	0.2

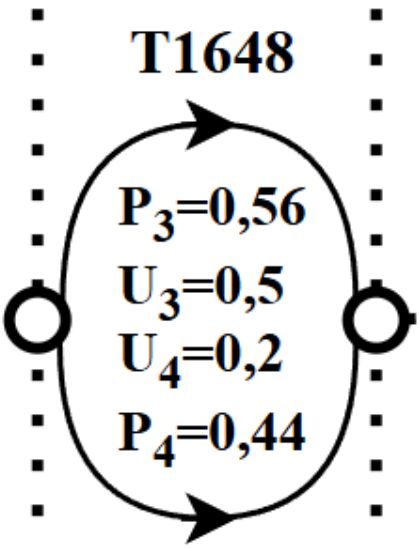


Рисунок 38 – Микромодель 2 множества сценариев шаблона атаки CAPEC-305

Таблица 40 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 3 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-5064	0.586754972	0.36
CVE-2025-5054	0.413245028	0.5

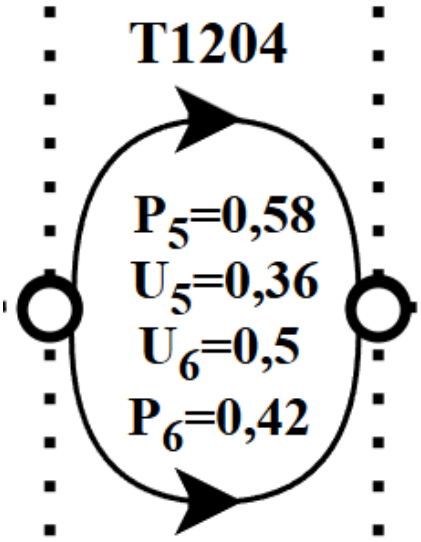


Рисунок 39 – Микромодель 3 множества сценариев шаблона атаки CAPEC-305

Таблица 41 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 4 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-45245	0.49819128	0.875
CVE-2025-24899	0.50180872	0.5

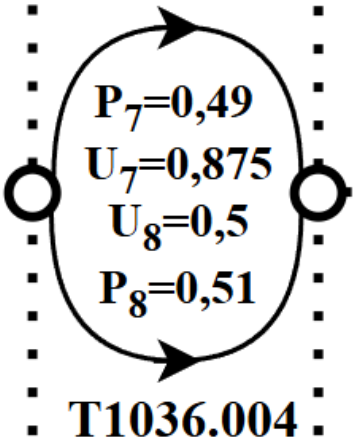


Рисунок 40 – Микромодель 4 множества сценариев шаблона атаки CAPEC-305

Таблица 42 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 5 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-3035	0.532415635	0.875
CVE-2025-29805	0.467584365	0.5

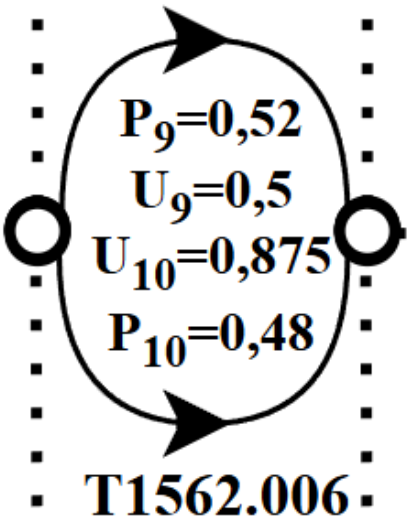


Рисунок 41 – Микромодель 5 множества сценариев шаблона атаки CAPEC-305

Таблица 43 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 6 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-31817	0.47514973	0.68
CVE-2024-29960	0.52485027	0.5

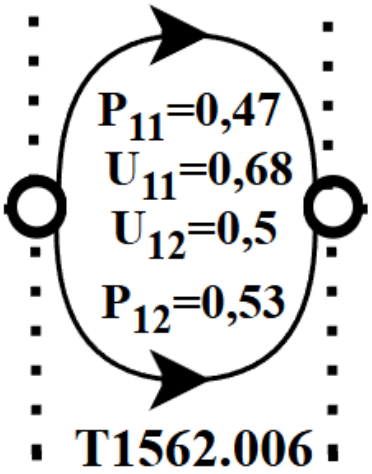


Рисунок 42 – Микромодель 6 множества сценариев шаблона атаки CAPEC-305

Таблица 44 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 7 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-24204	0.527544949	0.5
CVE-2024-8884	0.472455051	0.875

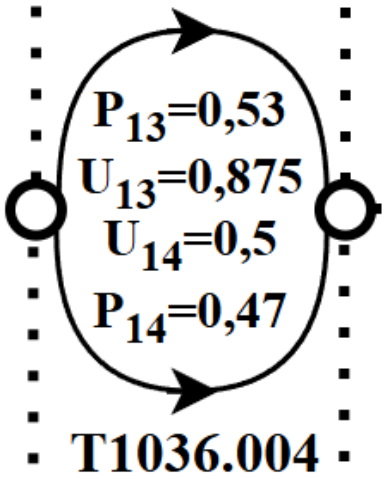


Рисунок 43 – Микромодель 7 множества сценариев шаблона атаки CAPEC-305

Таблица 45 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 8 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-32191	0.467302027	0.875
CVE-2024-30300	0.532697973	0.875

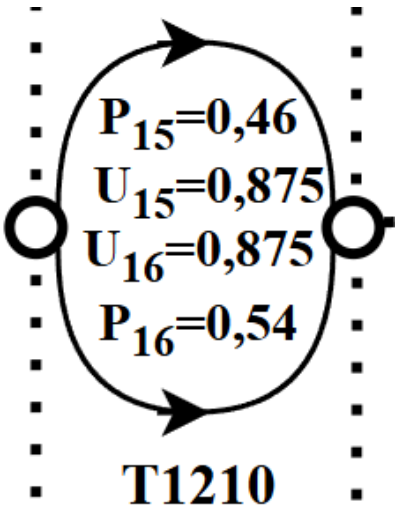


Рисунок 44 – Микромодель 8 множества сценариев шаблона атаки CAPEC-305

Таблица 46 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 9 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-42256	0.572458036	0.875
CVE-2025-31225	0.427541964	0.6

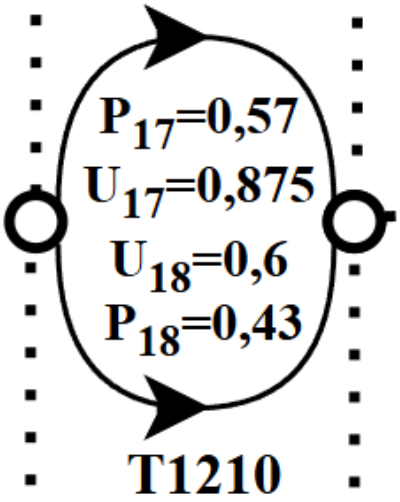


Рисунок 45 – Микромодель 9 множества сценариев шаблона атаки CAPEC-305

Таблица 47 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 10 для CAPEC-305

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2025-22218	0.514590231	0.875
CVE-2025-29846	0.485409769	0.875

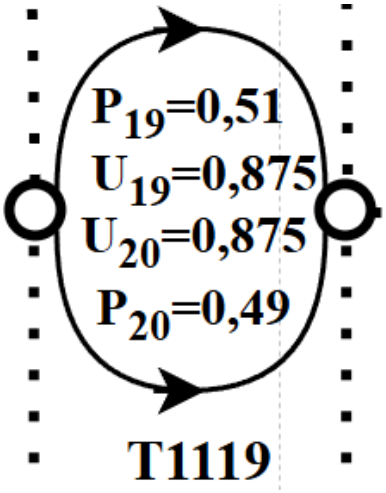


Рисунок 46 – Микромодель 10 множества сценариев шаблона атаки CAPEC-305

3.2.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-305

После проделанной работы становится возможным приступить к формированию подсценариев шаблона атаки CAPEC-305 и расчёту рисков возможных вариантов реализации атаки. На рисунке 47 изображён подсценарий 1 и в таблице 48 приведены возможные варианты сценариев в рамках данного подсценария и расчёты рисков для них.

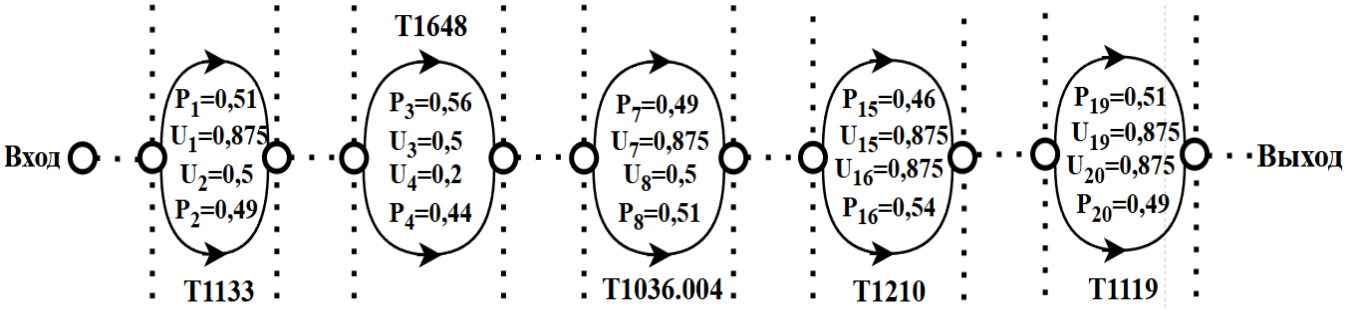


Рисунок 47 – Подсценарий 1 шаблона атаки CAPEC-305

Таблица 48 – Расчёт рисков для сценариев подсценария 1 шаблона атаки CAPEC-305

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.13731822368485858
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.12953142757651287
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	**0.15653503555824455**
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.1476585268691863
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.12534825101083694
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.11824022669354632
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.14288994135385596
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.134787194250096
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.09841107463035292
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.0928305555092463

Продолжение таблицы 48

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.112183078496128
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.10582160122374022
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.0890791331140609
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.08402779303367024
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.10154519112851489
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.09578694813729034
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.120247884466645
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.11342908260862967
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.13707581095709642
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.12930276115593775
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.1085912611067359
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.10243346218758542
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.1237879173100012
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.11676837360412072
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.08545454141328562
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.08060873819313509
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.09741336087656606
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2024-45245) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.09188941832167732
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.07636732817175647
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	**0.07203682637923901**
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.08705444994896301
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.08211792197848426

Максимальным риском обладает сценарий, изображённый на рисунке 48. Это T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1036.004 (CVE-2024-45245)

-> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218), где Risk = 0.15653503555824455.

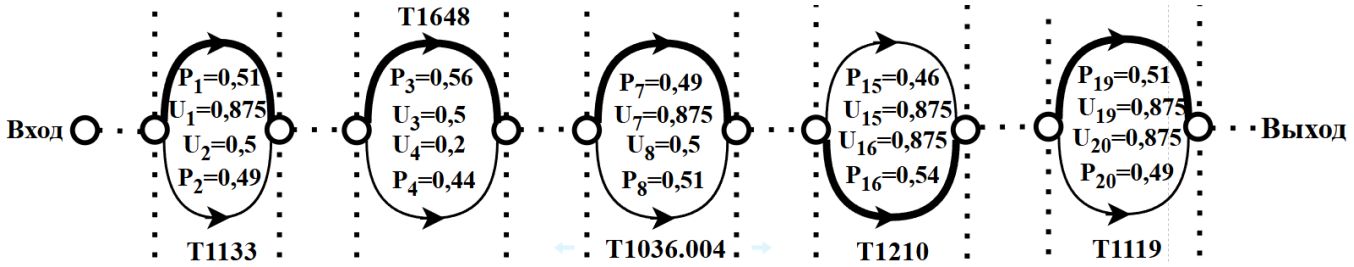


Рисунок 48 – Сценарий с максимальным риском для подсценария 1 шаблона атаки CAPEC-305

Минимальным риском обладает сценарий на рисунке 49. Это T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1036.004 (CVE-2025-24899) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846), где Risk = 0.07203682637923901.

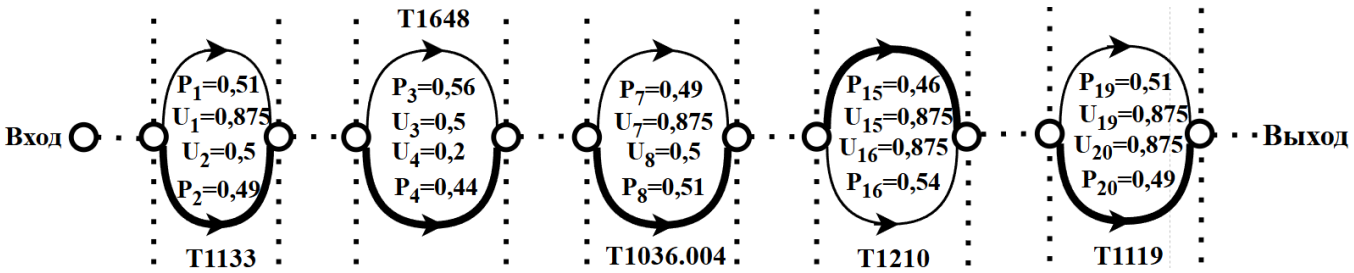


Рисунок 49 – Сценарий с минимальным риском для подсценария 1 шаблона атаки CAPEC-305

Наибольшей вероятностью реализации обладает сценарий, изображённый на рисунке 50. P_1 = 0.50857557 × 0.563452574 × 0.50180872 × 0.532697973 × × 0.514590231 = 0.03941791485623613.

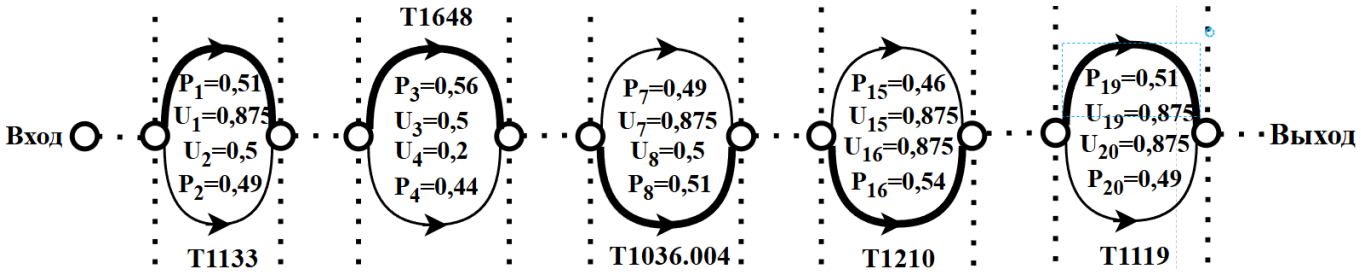


Рисунок 50 – Сценарий с наибольшим значением вероятности реализации для подсценария 1 шаблона атаки CAPEC-305

Далее перейдём к рассмотрению подсценария 2. Он изображён на рисунке 51. А в таблице 49 приведём возможные сценарии реализации данного шаблона атаки с расчётами рисков для каждого из них.

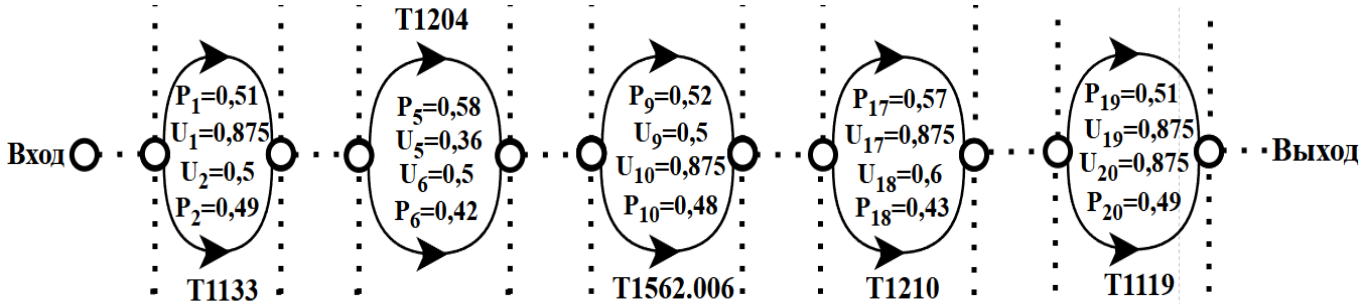


Рисунок 51 – Подсценарий 2 шаблона атаки CAPEC-305

Таблица 49 – Расчёт рисков для подсценария 2 шаблона атаки CAPEC-305

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	**0.16078875550933874**
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.15167103448099772
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.11060964933088555
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.10433739526407013
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.1530812261673007
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.14440056992085842
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.10575057638287198
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.09975386192985608

Продолжение таблицы 49

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.11779090565285627
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.11111142975283912
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.08129870891824253
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.07668856721067903
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.11193179618373725
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.10558456817907019
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.07755478691761605
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.07315694883940428
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.13864829346846796
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.13078607414289067
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.0943935445266692
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.08904084431362187
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.13278380188909433
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.12525413565794458
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.09088068869938672
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.08572718922860821
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.10204420794544922
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.09625766760152209
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.06976330708314661
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.06580729430113542
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.09749765719599061
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.0919689345162617
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.06697836089819416
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	**0.06318027186099273**

Максимальным риском обладает сценарий на рисунке 52. Это T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1562.006 (CVE-2024-29960) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218), где Risk = 0.16078875550933874.

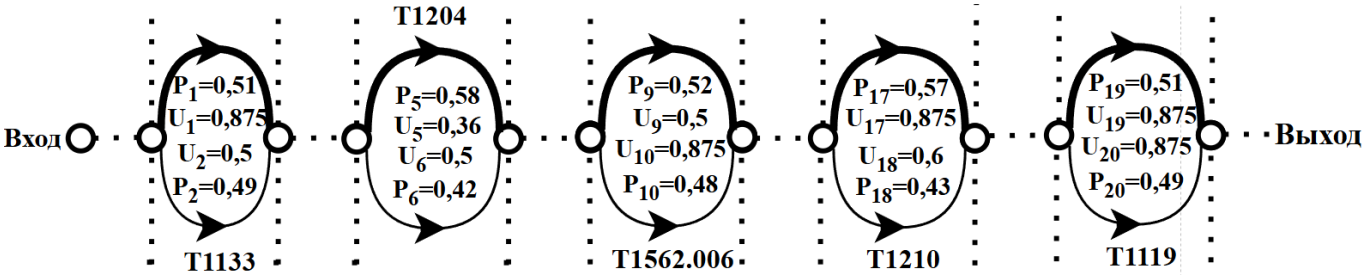


Рисунок 52 – Сценарий с максимальным риском для подсценария 2 шаблона атаки CAPEC-305

Минимальным риском обладает сценарий на рисунке 53. Это T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846), где Risk = 0.06318027186099273.

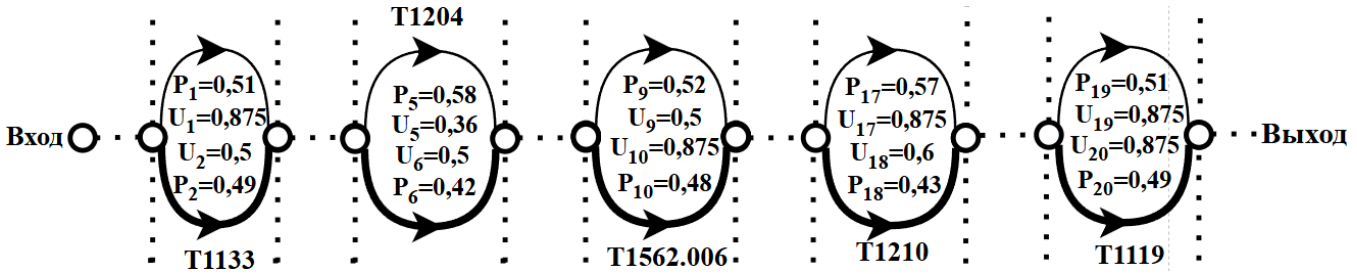


Рисунок 53 – Сценарий с минимальным риском для подсценария 2 шаблона атаки CAPEC-305

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 54. P_2 = 0.50857557 × 0.586754972 × 0.52485027 × 0.572458036 × 0.514590231 = 0.04613737604285186.

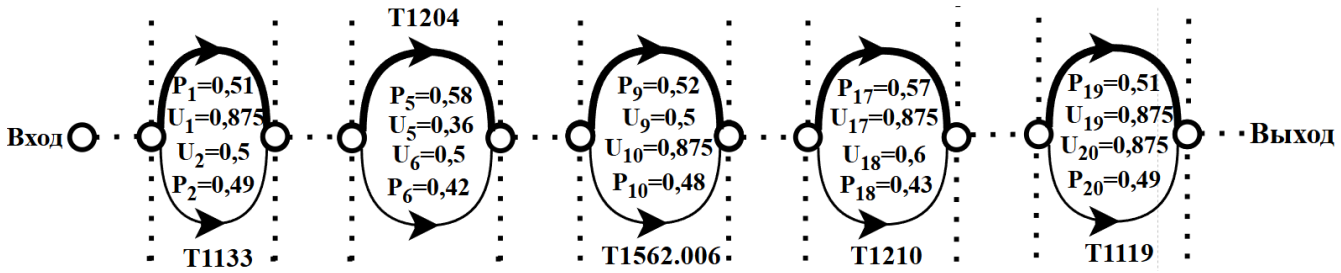


Рисунок 54 – Сценарий с наибольшим значением вероятности реализации для подсценария 2 шаблона атаки CAPEC-305

Далее перейдём к исследованию подсценария 3. На рисунке 55 изображён данный подсценарий, а в таблице 50 приведены риски для каждого возможного сценария.

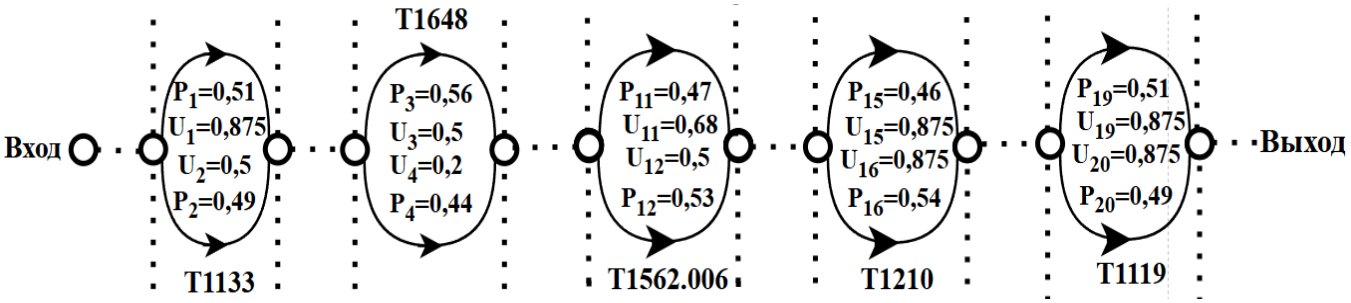


Рисунок 55 – Подсценарий 3 шаблона атаки CAPEC-305

Таблица 50 - Расчёт рисков для подсценария 3 шаблона атаки CAPEC-305

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.11679925042506792
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.1101760075352176
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.13314456251941975
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.12559443891999883
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.1467516036415692
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.13842987630294457
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	**0.16728855703072593**
T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.15780225688860383

Продолжение таблицы 50

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.08300375866702484
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.07829693004936246
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.09461960667528907
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.08925408733443857
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.10517164168419758
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.09920775642411508
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.11988974390272518
T1133 (CVE-2025-47966) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.1130912508389437
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.10118512063549294
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.0954472958774683
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.11534533459296886
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.1088045377604549
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.12850857960764672
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.12122134503145264
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.14649253783378638
T1133 (CVE-2025-32044) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.13818550113541117
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.07115892416125683
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	**0.06712377122332934**
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.08111716292975171
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.07651731600724099
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-22218)	0.09132503067935727
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846)	0.08614633425869431
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218)	0.10410538777110083
T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-29846)	0.09820196572994305

По результатам расчётов можно заметить, что максимальным риском обладает сценарий, изображённый на рисунке 56. Это T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218), где Risk = 0.16728855703072593.

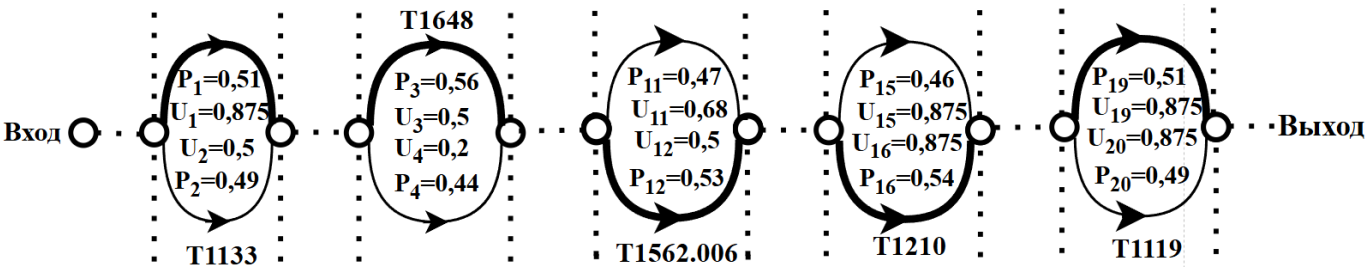


Рисунок 56 – Сценарий с максимальным риском подсценария 3 шаблона атаки CAPEC-305

Сценарием с минимальным риском является сценарий на рисунке 57. Это T1133 (CVE-2025-32044) -> T1648 (CVE-2024-49723) -> T1562.006 (CVE-2025-29805) -> T1210 (CVE-2023-32191) -> T1119 (CVE-2025-29846), где Risk = 0.06712377122332934.

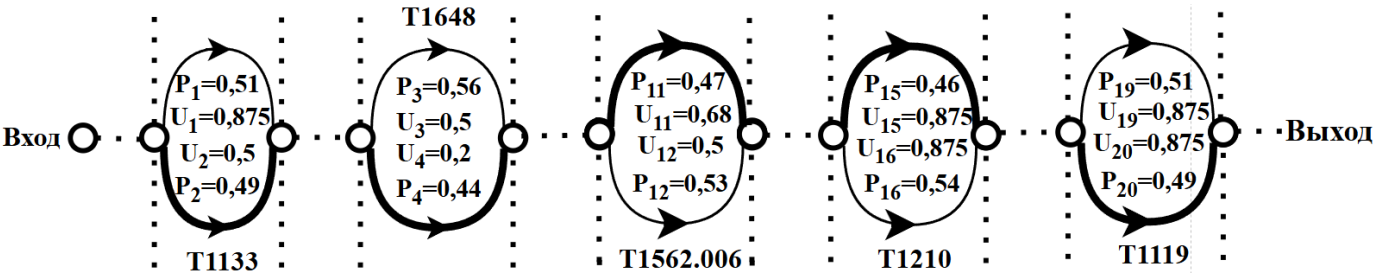


Рисунок 57 – Сценарий с минимальным риском подсценария 3 шаблона атаки CAPEC-305

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 58. P_3 = 0.50857557 × 0.563452574 × 0.532415635 × 0.532697973 × 0.514590231 = 0.04182213925768148.

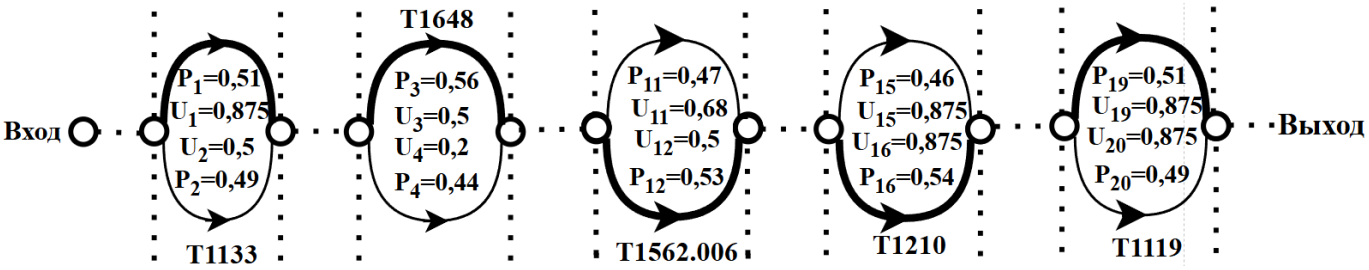


Рисунок 58 – Сценарий с наибольшим значением вероятности реализации для подсценария 3 шаблона атаки CAPEC-305

Перейдём к рассмотрению четвёртого подсценария шаблона атаки CAPEC-305, изображённого на рисунке 59. В таблице 51 приведены результаты расчётов рисков для всех возможных сценариев в рамках данного подсценария.

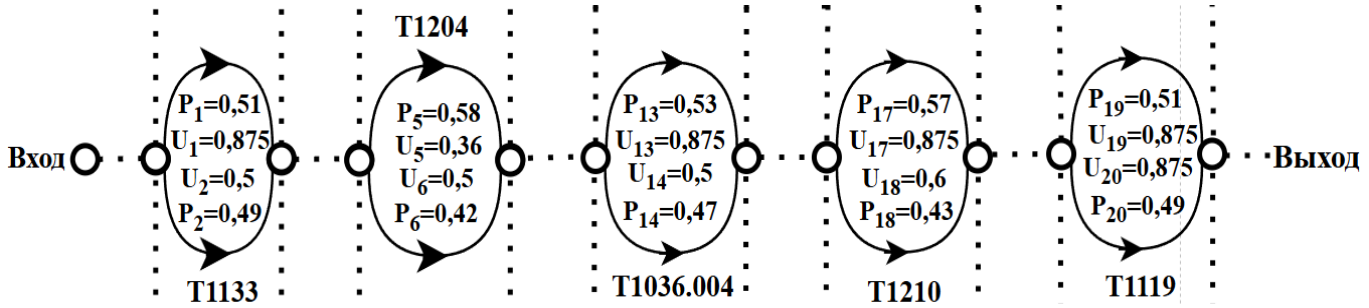


Рисунок 59 – Подсценарий 4 шаблона атаки CAPEC-305

Таблица 51 – Результаты расчёта рисков подсценария 4 шаблона атаки CAPEC-305

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	**0.16161427491491542**
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.15244974180932633
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.11117753986326409
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.10487308287633487
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.1603117176945352
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.15122104767297367
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.11119934125511699
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.10489364799387049

Продолжение таблицы 51

Сценарий в формате «техника (уязвимость)»	Риск
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.11839566609215973
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.11168189651932274
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.0817161116255882
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.0770823005922065
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.11700079501766218
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.11036612329770355
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.08137484797248629
T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.07676038870767969
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.13936013961993385
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.13145755419659302
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.0948781785579551
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.08949799658547684
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.13985628674812212
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.13192556670125308
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.0962098051255275
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.09075411165649842
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.10256812190708679
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.09675187238772676
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.0701214848898714
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	**0.06614516120172804**
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218)	0.1024561613473652
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-29846)	0.09664626068708106
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-22218)	0.07071474314670874
T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2024-8884) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846)	0.06670477803092656

При изучении полученных результатов можно выявить сценарий с максимальным риском. Он изображён на рисунке 60. Это T1133 (CVE-2025-47966) -> T1204 (CVE-2025-5064) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2024-42256) -> T1119 (CVE-2025-22218), где Risk = 0.16161427491491542.

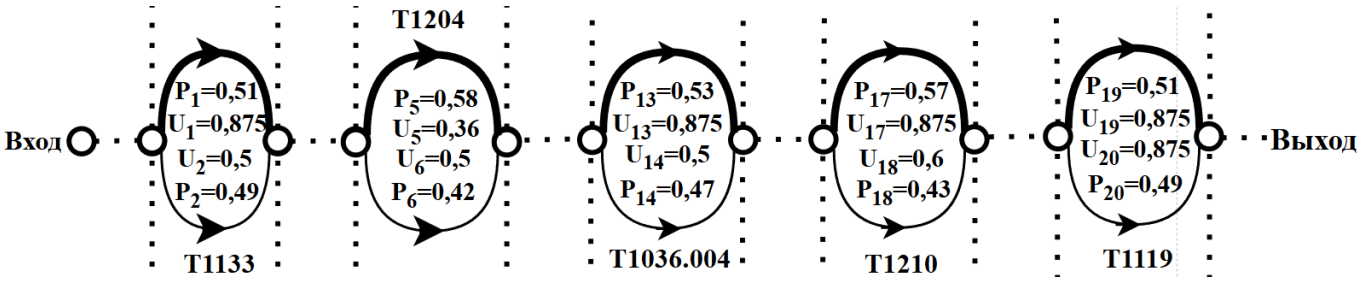


Рисунок 60 – Сценарий с максимальным риском для подсценария 4 шаблона атаки CAPEC-305

По итогам расчётов также можно выделить и изобразить на рисунке 61. путь с минимальным риском. Это T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1036.004 (CVE-2025-24204) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846), где Risk = 0.06614516120172804.

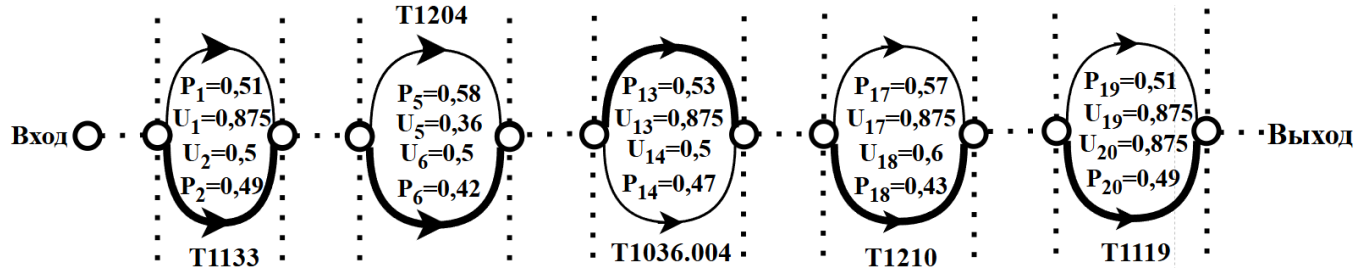


Рисунок 61 – Сценарий с минимальным риском подсценария 4 шаблона атаки CAPEC-305

Наибольшей вероятностью реализации обладает сценарий, изображённый на рисунке 62. P_4 = 0.50857557 × 0.586754972 × 0.527544949 × 0.572458036 × × 0.514590231 = 0.04637425392106612.

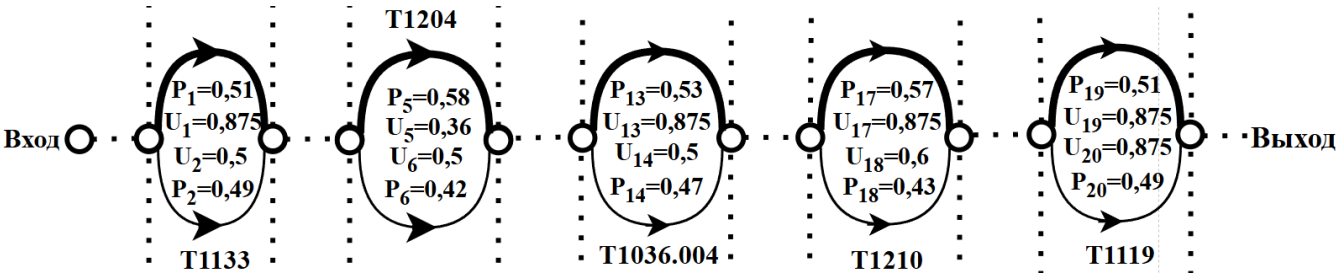


Рисунок 62 – Сценарий с наибольшим значением вероятности реализации для подсценария 4 шаблона атаки CAPEC-305

Теперь представляется возможным проанализировать все экстремальные значения параметров риска и вероятностей реализации сценариев для подведения итогов в рамках всего множества сценариев CAPEC-305.

Сценарий с наибольшим риском изображён на рисунке 63 – подсценарий 3 - T1133 (CVE-2025-47966) -> T1648 (CVE-2025-24226) -> T1562.006 (CVE-2025-3035) -> T1210 (CVE-2024-30300) -> T1119 (CVE-2025-22218), где Risk = 0.16728855703072593.

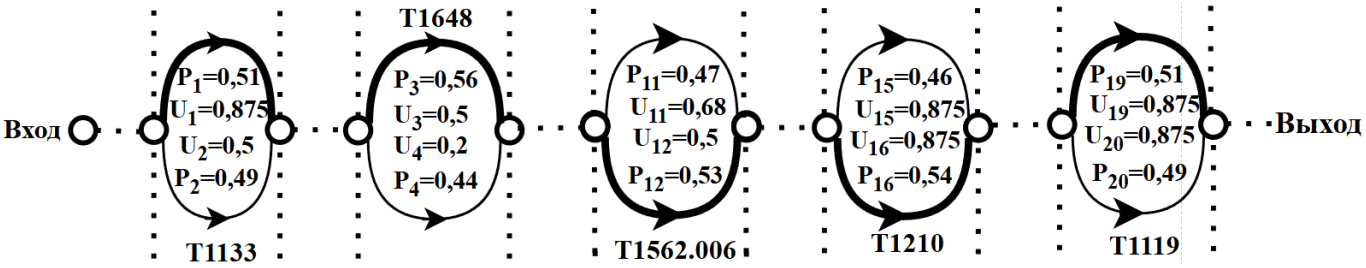


Рисунок 63 – Сценарий всего множества сценариев шаблона атаки CAPEC-306 с наибольшим значением риска

Сценарий с наименьшим риском изображён на рисунке 64 – подсценарий 2 - T1133 (CVE-2025-32044) -> T1204 (CVE-2025-5054) -> T1562.006 (CVE-2024-31817) -> T1210 (CVE-2025-31225) -> T1119 (CVE-2025-29846), где Risk = 0.06318027186099273.

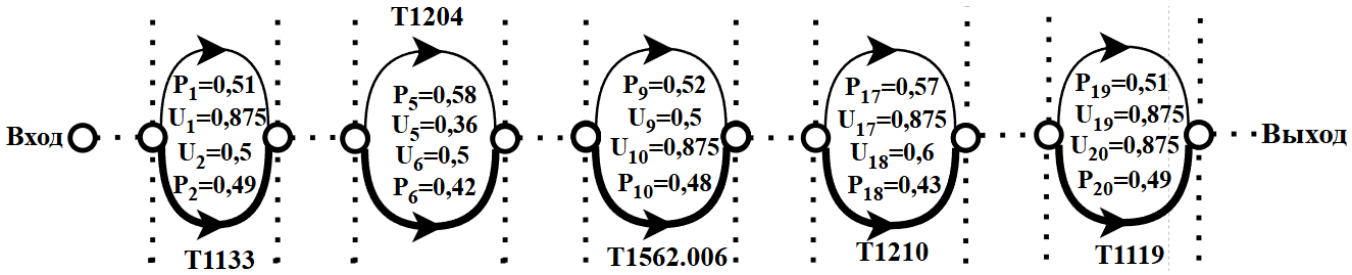


Рисунок 64 - Сценарий всего множества сценариев шаблона атаки CAPEC-306 с наименьшим значением риска

Сценарий с наибольшей вероятностью реализации изображён на рисунке 65 – подсценарий 4 - P = 0.50857557 × 0.586754972 × 0.527544949 × 0.572458036 × × 0.514590231 = 0.04637425392106612.

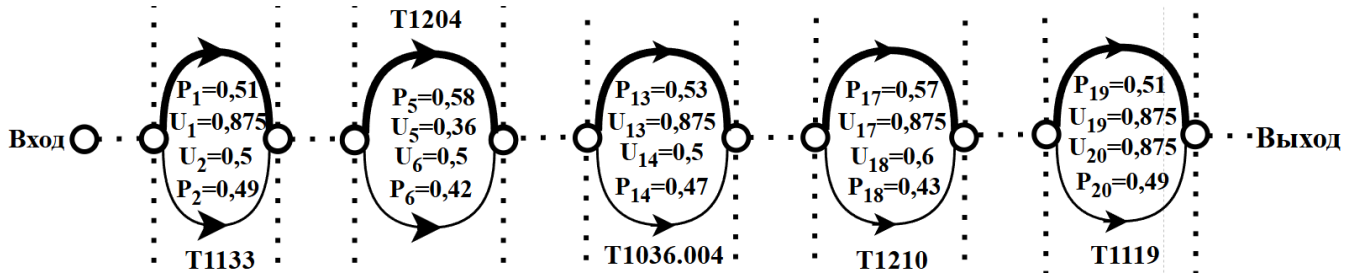


Рисунок 65 – Сценарий с наибольшим значением вероятности реализации для всего множества сценариев CAPEC-305

3.3 Формирование сценариев CAPEC-306 в виде последовательности реализации техник MITRE ATT&CK

3.3.1 Оценка критичности группы уязвимостей, связанной с CAPEC-306

Далее приступим к рассмотрению шаблона атаки CAPEC-306. В начале необходимо произвести расчёт критичностей для группы уязвимостей, связанных с данным шаблоном атак, для чего в таблицах 52-53 приведём оценки риск-калькуляторов и нормализуем их.

Таблица 52 – Оценки риск-калькуляторов для группы уязвимостей, связанных с CAPEC-306

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2023-40723	8.1	9.2	0.64	6.125
CVE-2024-29958	7.5	8.7	0.245	3.625
CVE-2024-29966	7.5	8.7	0.291	5.5
CVE-2024-29156	8.4	8.6	0.11	6.5
CVE-2024-24919	7.5	8.7	0.94327	4.5
CVE-2023-24838	9.8	9.3	0.1354	6.25
CVE-2023-1174	9.8	9.3	0.71	6
CVE-2023-23397	9.8	9.3	0.93547	3.25
CVE-2024-48352	7.5	8.7	0.31	3.625
CVE-2023-1387	7.5	8.7	0.269	5
CVE-2023-33001	7.5	8.7	0.245	4
CVE-2024-50338	7.4	7.1	0.88	6.125
CVE-2024-52975	9	9.4	0.38	6.375
CVE-2024-12142	8.6	8.8	0.66	6.5
CVE-2024-13310	8.4	8.6	0.63	3.375
CVE-2024-11053	0.91	0.93	0.146	5.75
CVE-2024-52508	8.2	8.8	0.19	3.625
CVE-2024-42449	7.1	7.1	0.79	3.75
CVE-2024-48900	7.3	6.9	0.56	3.5

Таблица 53 – Нормализованные оценки риск-калькуляторов для группы уязвимостей, связанных с CAPEC-306

Уязвимость	$CVSS\ 3.1_{norm}$	$CVSS\ 4.0_{norm}$	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2023-40723	0.81	0.92	0.64	0.6125
CVE-2024-29958	0.75	0.87	0.939	0.3625
CVE-2024-29966	0.75	0.87	0.35	0.55
CVE-2024-29156	0.84	0.86	0.25	0.65
CVE-2024-24919	0.75	0.87	0.313	0.45
CVE-2023-24838	0.98	0.93	0.51	0.625
CVE-2023-1174	0.98	0.93	0.5	0.6
CVE-2023-23397	0.98	0.93	0.121	0.325
CVE-2024-48352	0.75	0.87	0.14	0.3625
CVE-2023-1387	0.75	0.87	0.53	0.5
CVE-2023-33001	0.75	0.87	0.449	0.4
CVE-2024-50338	0.74	0.71	0.88	0.6125
CVE-2024-52975	0.9	0.94	0.38	0.6375
CVE-2024-12142	0.86	0.88	0.66	0.65
CVE-2024-13310	0.84	0.86	0.63	0.3375
CVE-2024-11053	0.91	0.93	0.146	0.575
CVE-2024-52508	0.82	0.88	0.19	0.3625
CVE-2024-42449	0.71	0.71	0.79	0.375
CVE-2024-48900	0.73	0.69	0.56	0.35

Далее рассчитаем значения критичности для каждой уязвимости на основе данных таблицы 53 и сведём эти данные в таблице 54.

Таблица 54 – Значения критичностей для уязвимостей, связанных с шаблоном атаки CAPEC-306

Уязвимость	Значение критичности
CVE-2023-40723	0.756183881
CVE-2024-29958	0.763630678
CVE-2024-29966	0.660378679
CVE-2024-29156	0.694658189
CVE-2024-24919	0.636370372
CVE-2023-24838	0.786769502
CVE-2023-1174	0.780272388
CVE-2023-23397	0.697417737
CVE-2024-48352	0.606301544
CVE-2023-1387	0.680128664
CVE-2023-33001	0.648267113
CVE-2024-50338	0.741831559
CVE-2024-52975	0.749067128
CVE-2024-12142	0.770081165
CVE-2024-13310	0.699286467
CVE-2024-11053	0.715007168
CVE-2024-52508	0.635276761
CVE-2024-42449	0.665756149
CVE-2024-48900	0.601061561

3.3.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-306

Теперь произведём разложение шаблона атаки CAPEC-306 на тактики и техники. В таблице 55 приведём соотношение техник и тактик с уязвимостями, связанными с данным шаблоном атак, а также рассчитаем значения ущерба и вероятности успешной эксплуатации для каждой уязвимости.

Таблица 55 – Соотношение техник и тактик с уязвимостями для CAPEC-306

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Значения ущерба
1	2	3	4	5	6
CAPEC-306	T1584.006 «Веб-сервисы»	CVE-2023-40723	0.756183881	0.497550097	0.875
		CVE-2024-29958	0.763630678	0.502449903	0.5
		ИЛИ			
	T1586 «Компрометация учетных записей»	CVE-2024-29966	0.660378679	0.487351078	0.5
		CVE-2024-29156	0.694658189	0.512648922	0.875
	T1554 «Компрометация бинарных файлов ПО узла»	CVE-2024-24919	0.636370372	0.4471594	0.5
		CVE-2023-24838	0.786769502	0.5528406	0.875
		ИЛИ			
		CVE-2023-1174	0.780272388	0.528035191	0.875
		CVE-2023-23397	0.697417737	0.471964809	0.875
	T1056 «Перехват вводимых данных»	CVE-2024-48352	0.606301544	0.471305431	0.5
		CVE-2023-1387	0.680128664	0.528694569	0.5
		ИЛИ			
	T1212 «Эксплуатация уязвимостей для получения учетных данных»	CVE-2023-33001	0.648267113	0.303046689	0.5
		CVE-2024-50338	0.741831559	0.346785443	0.5
		CVE-2024-52975	0.749067128	0.350167868	0.875
	T1219 «ПО для удаленного доступа»	CVE-2024-12142	0.770081165	0.524090192	0.5
		CVE-2024-13310	0.699286467	0.475909808	0.875
		ИЛИ			
		CVE-2024-11053	0.715007168	0.529523571	0.75
		CVE-2024-52508	0.635276761	0.470476429	0.8
	T1537 «Перемещение данных между облачными учетными записями»	CVE-2024-42449	0.665756149	0.525534293	0.6
		CVE-2024-48900	0.601061561	0.474465707	0.488

Подготовку ресурсов потенциальный злоумышленник производит с помощью техник T1584.006 «Веб-сервисы» (эксплуатация CVE-2023-40723 или CVE-2024-29958) или T1586 «Компрометация учетных записей» (эксплуатация CVE-2024-29966 или CVE-2024-29156).

Закрепление в системе реализуется техникой T1554 «Компрометация бинарных файлов ПО узла» путём эксплуатации CVE-2024-24919, CVE-2023-24838 или CVE-2023-1174, CVE-2023-23397.

Учётные данные вероятный злоумышленник получает реализацией техник T1056 «Перехват вводимых данных» (эксплуатация CVE-2024-48352 или CVE-2023-1387) или T1212 «Эксплуатация уязвимостей для получения учетных данных» (эксплуатация CVE-2023-33001 или CVE-2024-50338 или CVE-2024-52975).

Организация управления производится техникой T1219 «ПО для удаленного доступа» с эксплуатацией уязвимостей CVE-2024-12142, CVE-2024-13310, CVE-2024-11053 или CVE-2024-52508.

Эксфильтрацию данных потенциальный нарушитель безопасности информации совершает техникой T1537 «Перемещение данных между облачными учетными записями» с эксплуатацией CVE-2024-42449 или CVE-2024-48900.

Визуализируем данные таблицы 55 с помощью рисунка 66.

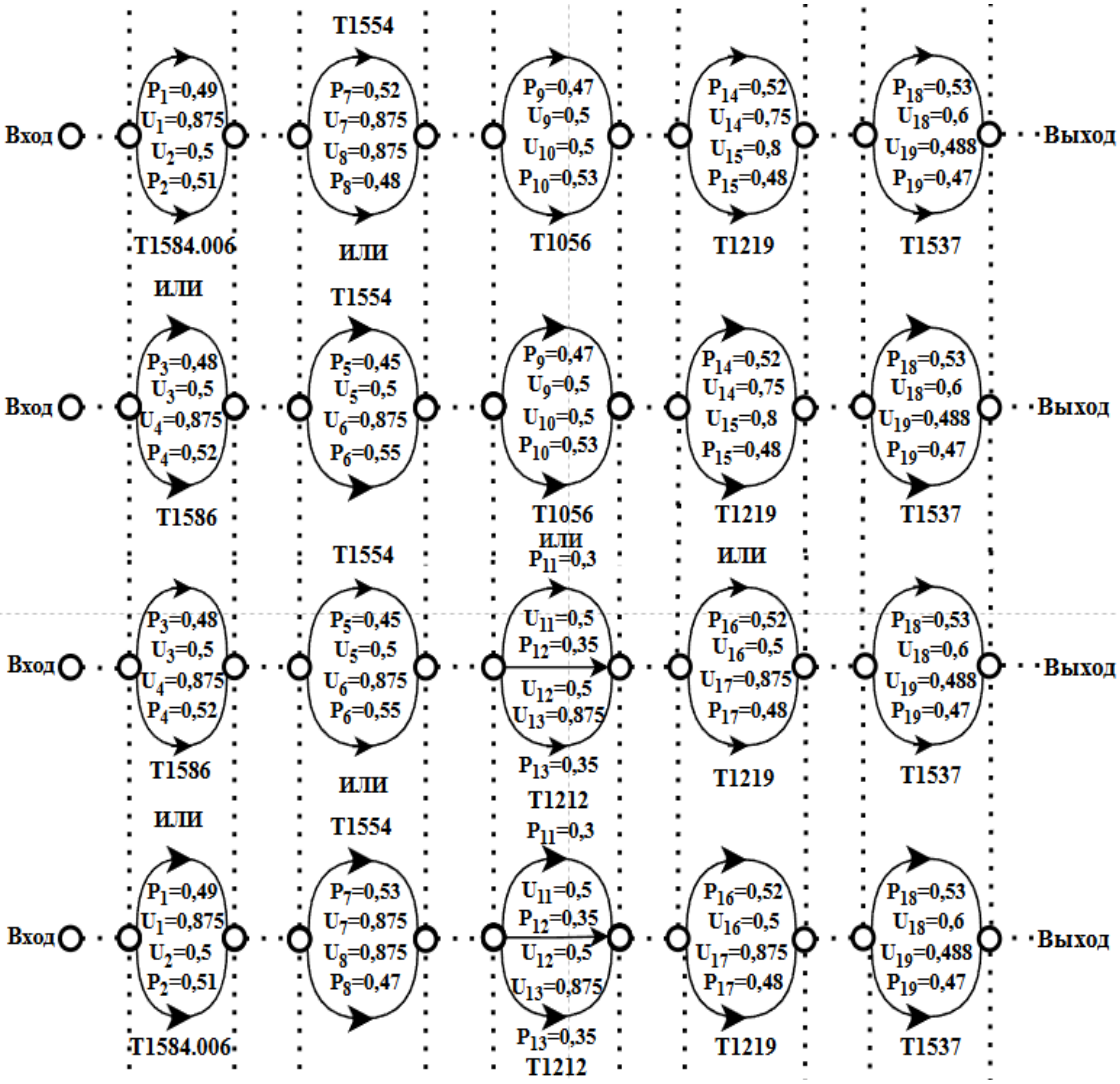


Рисунок 66 – Множество сценариев шаблона атаки CAPEC-306

После визуализации общего сценария шаблона атаки CAPEC-306 на рисунке 66 необходимо выделить микромодели и систематизировать для каждой из них вероятности успешной эксплуатации уязвимостей и значения ущерба от их эксплуатации. На рисунках 67-75 продемонстрированы микромодели, а в таблицах 56-64 представлены вышеупомянутые данные.

Таблица 56 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 1 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-40723	0.497550097	0.875
CVE-2024-29958	0.502449903	0.5

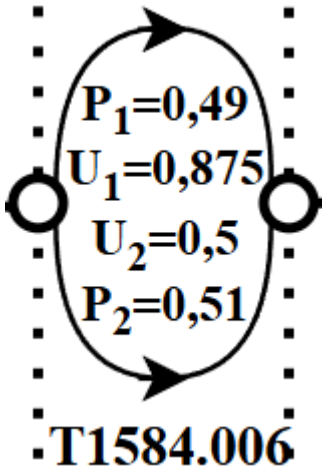


Рисунок 67 – Микромодель 1 шаблона атаки CAPEC-306

Таблица 57 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 2 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-29966	0.487351078	0.5
CVE-2024-29156	0.512648922	0.875

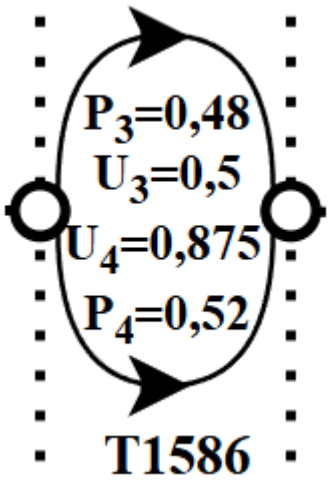


Рисунок 68 – Микромодель 2 шаблона атаки CAPEC-306

Таблица 58 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 3 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-1174	0.4471594	0.5
CVE-2023-23397	0.5528406	0.875

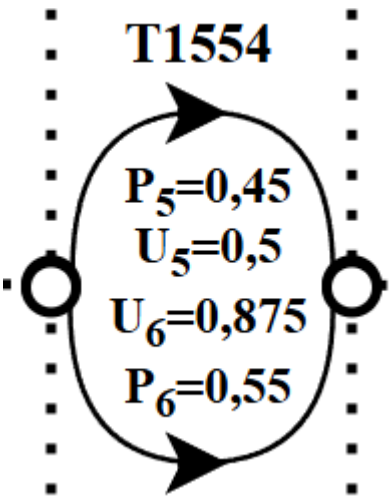


Рисунок 69 – Микромодель 3 шаблона атаки CAPEC-306

Таблица 59 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 4 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-24919	0.528035191	0.875
CVE-2023-24838	0.471964809	0.875

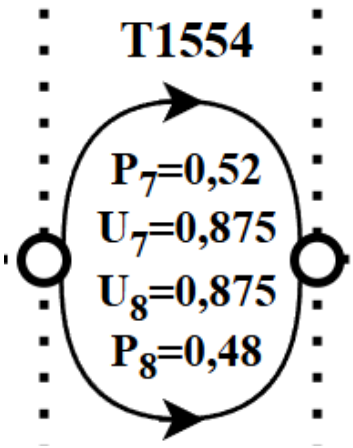


Рисунок 70 – Микромодель 4 шаблона атаки CAPEC-306

Таблица 60 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 5 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-48352	0.471305431	0.5
CVE-2023-1387	0.528694569	0.5

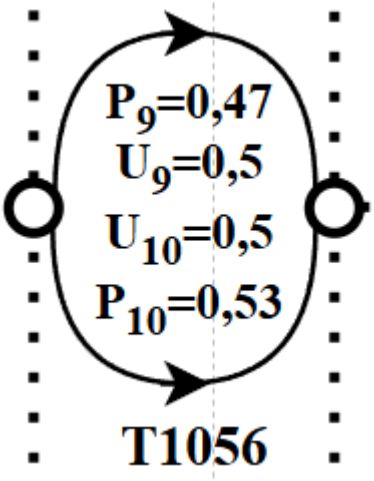


Рисунок 71 – Микромодель 5 шаблона атаки CAPEC-306

Таблица 61 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 6 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-33001	0.303046689	0.5
CVE-2024-50338	0.346785443	0.5
CVE-2024-52975	0.350167868	0.875

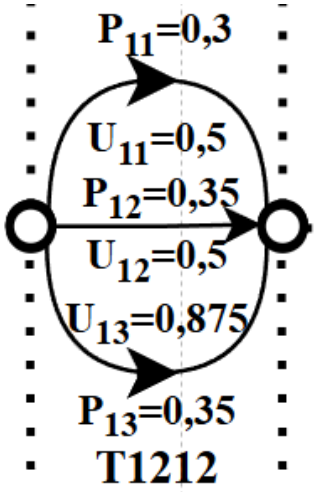


Рисунок 72 – Микромодель 6 шаблона атаки CAPEC-306

Таблица 62 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 7 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-11053	0.529523571	0.75
CVE-2024-52508	0.470476429	0.8

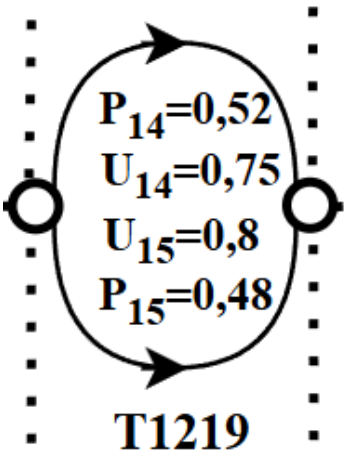


Рисунок 73 – Микромодель 7 шаблона атаки CAPEC-306

Таблица 63 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 8 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-12142	0.524090192	0.5

Продолжение таблицы 63

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-13310	0.475909808	0.875

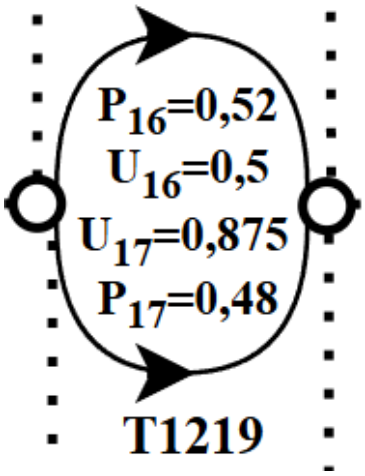


Рисунок 74 – Микромодель 8 шаблона атаки CAPEC-306

Таблица 64 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 9 для CAPEC-306

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-42449	0.525534293	0.6
CVE-2024-48900	0.474465707	0.488

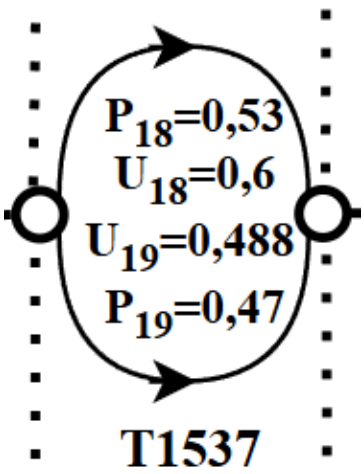


Рисунок 75 – Микромодель 9 шаблона атаки CAPEC-306

3.3.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-306

После проделанной работы становится возможным формирование подсценариев шаблона атаки CAPEC-306 и расчёт рисков для различных вариантов их реализации. Подсценарий 1 изображён на рисунке 76 и в таблице 65 приведены результаты расчётов рисков для его всевозможных сценариев.

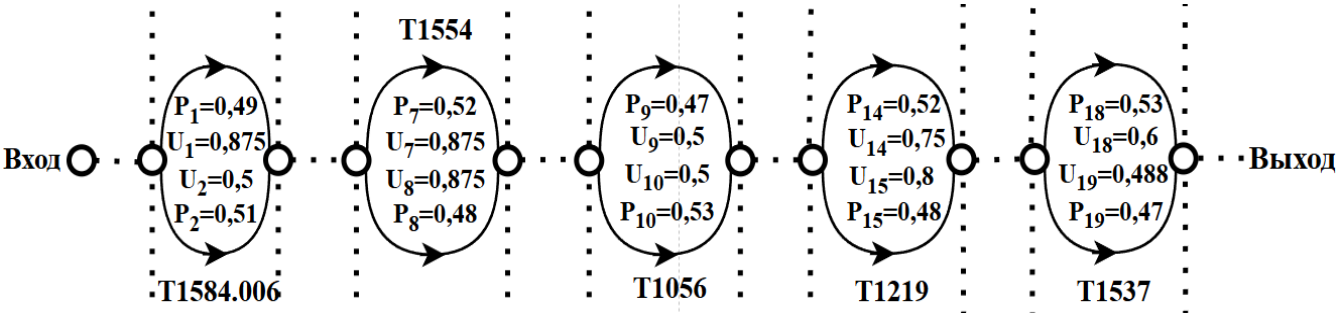


Рисунок 76 – Подсценарий 1 шаблона атаки CAPEC-306

Таблица 65 – Риски сценариев для подсценария 1 шаблона атаки CAPEC-306

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.12404834797470185
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.10850974132577167
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.1117464979935698
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.09779184810101062
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	**0.13915326146039467**
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.12172257552985917
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.12535346021499535
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.10969960365994018
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.11087604738572372
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.0969874360882459
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.09988049183251131

Продолжение таблицы 65

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.08740764194777027
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.12437701802128986
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.1087972413394282
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.11204257389704805
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.09805095071540293
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.1122210052175897
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.09779740340057436
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.10125309638049396
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.0882876523041643
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.1258857464476371
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.10970583540800699
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.11358231547898438
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.09903811671326145
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.10030461263955366
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.0874126073476948
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.0905013512515654
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	**0.07891266655519805**
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.11251833834306223
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.09805652073390968
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.101521369682379
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.08852157324926126

При анализе полученных результатов можно выделить пути с максимальным и минимальным рисками. На рисунке 77 изображён сценарий с наибольшим риском. Это T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1056 (CVE-2023-

1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449), где Risk = 0.13915326146039467.

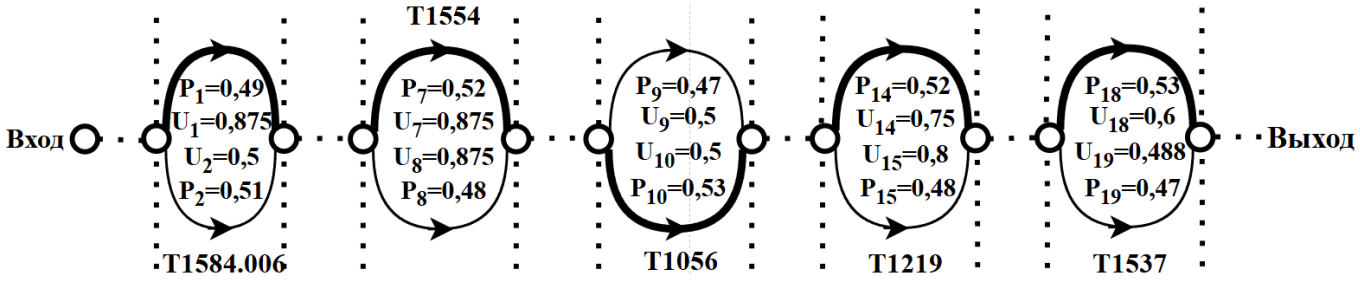


Рисунок 77 – Сценарий с максимальным риском подсценария 1 шаблона атаки CAPEC-306

Минимальным риском обладает сценарий на рисунке 78. Это T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900), где Risk = 0.07891266655519805.

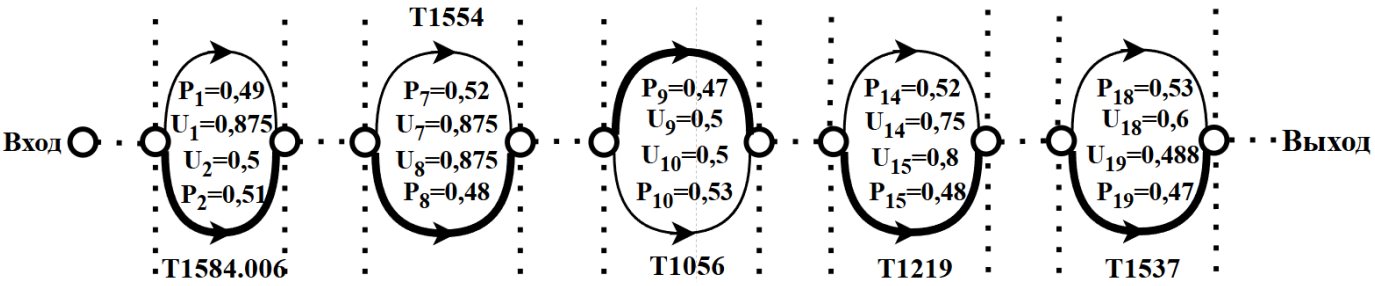


Рисунок 78 – Сценарий с минимальным риском подсценария 1 шаблона атаки CAPEC-306

Наибольшей вероятностью реализации обладает сценарий, проиллюстрированный на рисунке 79. P_1 = 0.502449903 × 0.528035191 × 0.528694569 × 0.529523571 × × 0.525534293 = 0.03903433998376344.

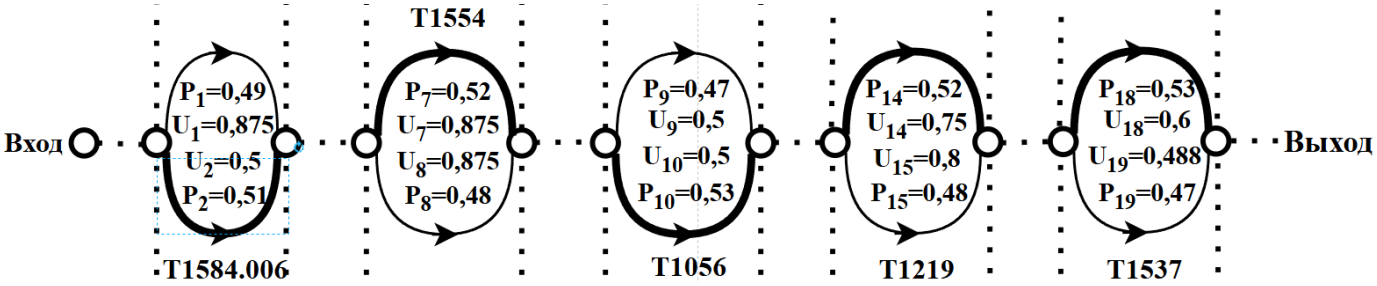


Рисунок 79 – Сценарий с наибольшим значением вероятности реализации для подсценария 1 шаблона атаки CAPEC-306

Перейдём к рассмотрению второго подсценария, изображённого на рисунке 80. В таблице 66 приведены результаты расчётов рисков для каждого сценария этого подсценария.

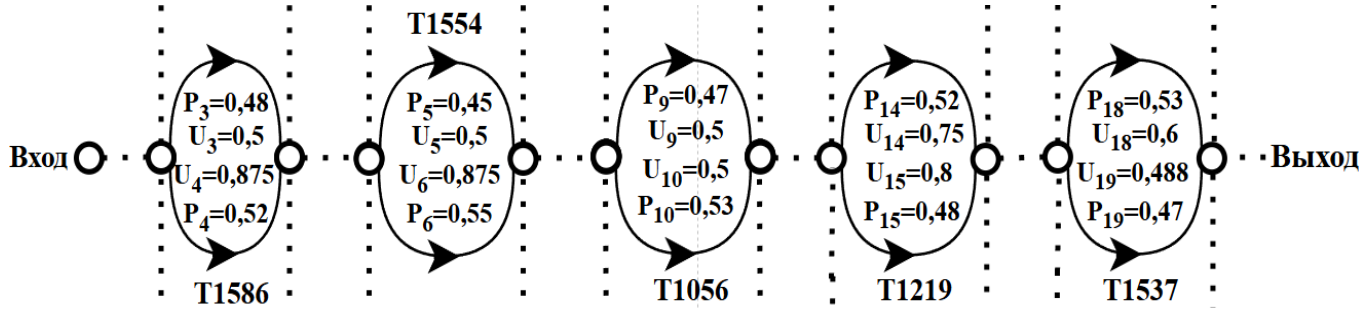


Рисунок 80 – Подсценарий 2 шаблона атаки CAPEC-306

Таблица 66 – Риски для подсценария 2 шаблона атаки CAPEC-306

Сценарий в формате «техника (уязвимость)»	Риск
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.08145879052778106
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.0706529515123009
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.07364506818161483
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	**0.06392080090594346**
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.09137772942265647
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.0792561029248437
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.08261255869392786
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.07170420296960801

Продолжение таблицы 66

Сценарий в формате «техника (уязвимость)»	Риск
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.11396208371509425
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.09931470362295582
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.10282401074338011
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.08965741131428806
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.12783882970381832
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.11140789172722555
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.11534451433644252
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.1005746662666046
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.09696185911824455
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.0844994930518614
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.08748530141478943
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.07628282145573888
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.10876854995536646
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.09478868716828419
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.0981380664915936
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.08557150153367492
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	0.1338169973151865
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.11705474519196045
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.1205463923230693
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.10549283153249926
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449)	**0.15011140349118254**
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-48900)	0.131308073253814
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-42449)	0.13522488548142794
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900)	0.11833830766882106

Полученные результаты позволяют выделить сценарии с максимальным и минимальным значениями риска. Сценарий с максимальным риском приведён на рисунке 81. Это T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449), где Risk = 0.15011140349118254.

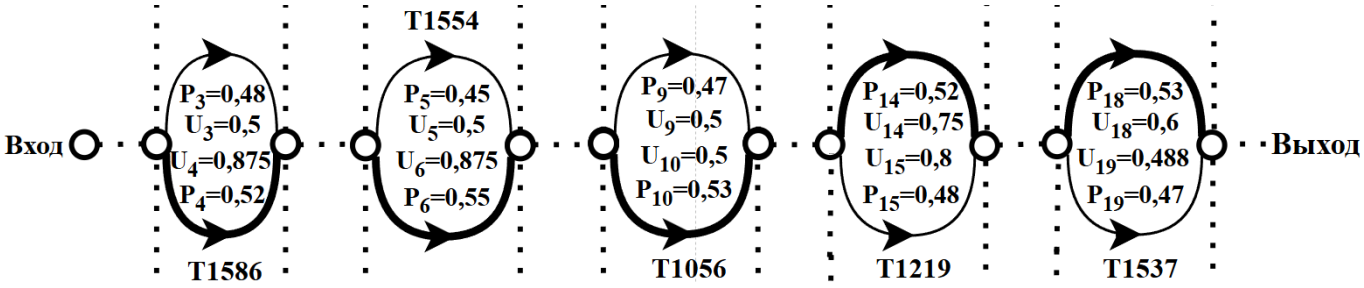


Рисунок 81 – Сценарий с наибольшим риском подсценария 2 шаблона атаки CAPEC-306

Минимальным риском обладает сценарий на рисунке 82. Это T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1056 (CVE-2024-48352) -> T1219 (CVE-2024-52508) -> T1537 (CVE-2024-48900), где Risk = 0.06392080090594346.

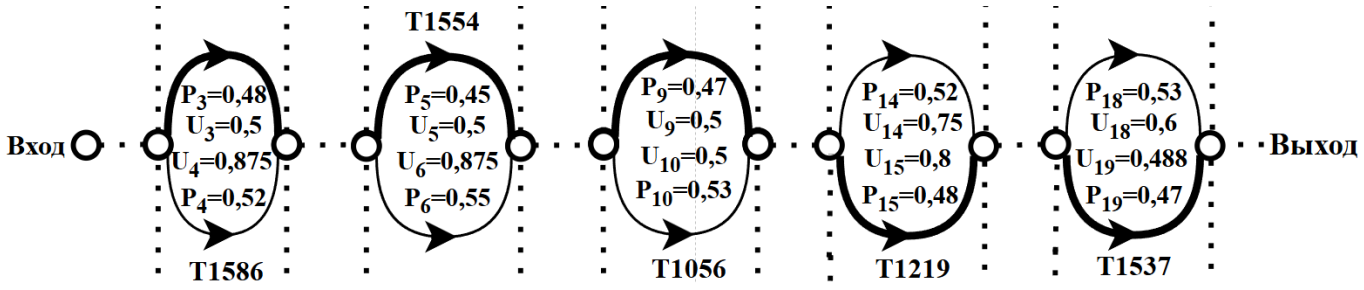


Рисунок 82 – Сценарий с минимальным риском подсценария 2 шаблона атаки CAPEC-306

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 83. P_2 = 0.512648922 × 0.5528406 × 0.528694569 × 0.529523571 × 0.525534293 = 0.04169761208088404.

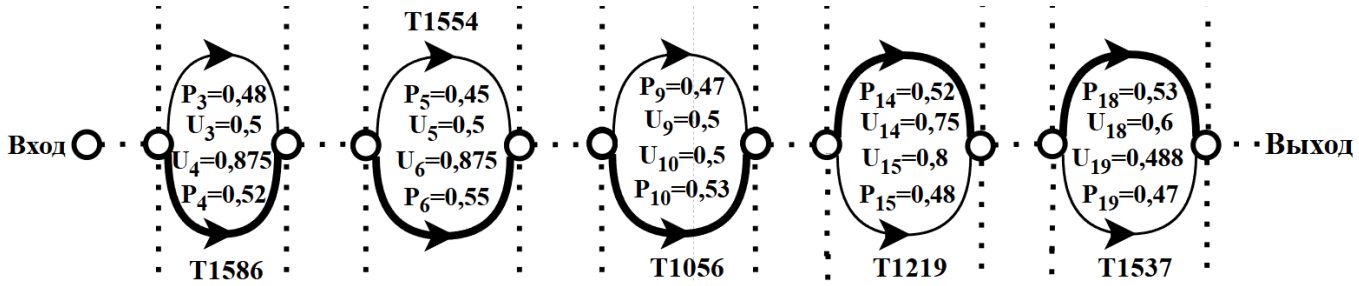


Рисунок 83 – Сценарий с наибольшим значением вероятности реализации для подсценария 2 шаблона атаки CAPEC-306

Перейдём к анализу третьего подсценария, изображённого на рисунке 84. В таблице 67 сведены результаты расчёта рисков для каждого сценария данного подсценария.

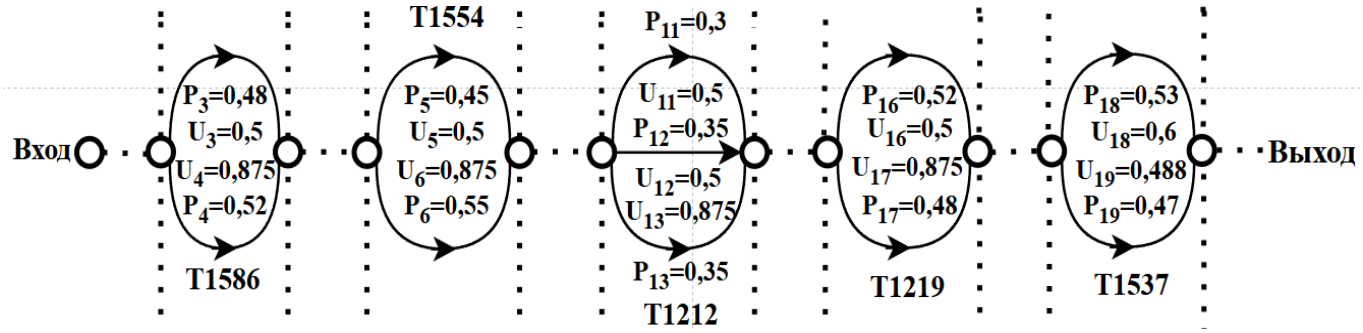


Рисунок 84 – Подсценарий 3 шаблона атаки CAPEC-306

Таблица 67 – Риски для сценариев третьего подсценария шаблона атаки CAPEC-306

Сценарий в формате «техника (уязвимость)»	Риск
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.047292718601415054
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	**0.040857809181083504**
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.0491390238627957
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.042693786188936024
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.054118480637371555
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.04675482020155486
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.05623126329173382

Продолжение таблицы 67

Сценарий в формате «техника (уязвимость)»	Риск
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.04885578392469241
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.06252801625945272
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.054326633847128054
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.0639368315511162
T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.055793925189429605
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.0669029806721921
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.05812776338814682
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.06841036804616146
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.05969771826896609
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07655909347495488
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.0665173483454811
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07828404219483538
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.06831389494571448
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.0870502559727112
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.07596365587148578
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.0878962092780091
T1586 (CVE-2024-29966) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.07696895634715607
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.056922769179487374
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.04945658960212251
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.05820529295780681
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.05079234741747243
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.06513843722178163
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.056594663320810104
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.06660606776442232

Продолжение таблицы 67

Сценарий в формате «техника (уязвимость)»	Риск
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.058123211173503636
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.0740645869281802
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06463182366103266
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07478434566314658
T1586 (CVE-2024-29156) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.06548715904904764
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07924674288704679
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06915398741038585
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.08001686174919474
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.0700691689618869
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.09068443192392583
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.07913498820416774
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.09156570210593608
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.08018225798563271
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	**0.101819190516565**
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.089161033161108
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.10176673533335275
T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.08936776634545955

Замечаем, что сценарий с максимальным риском это T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449), где Risk = 0.101819190516565. Изобразим его на рисунке 85.

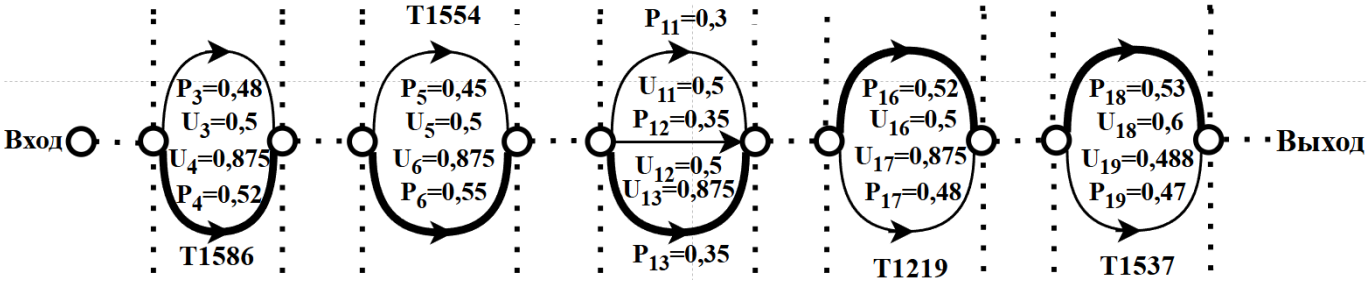


Рисунок 85 – Сценарий с максимальным риском для подсценария 3 шаблона атаки CAPEC-306

Минимальным риском обладает сценарий, изображённый на рисунке 86. Это T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900), где Risk = 0.040857809181083504.

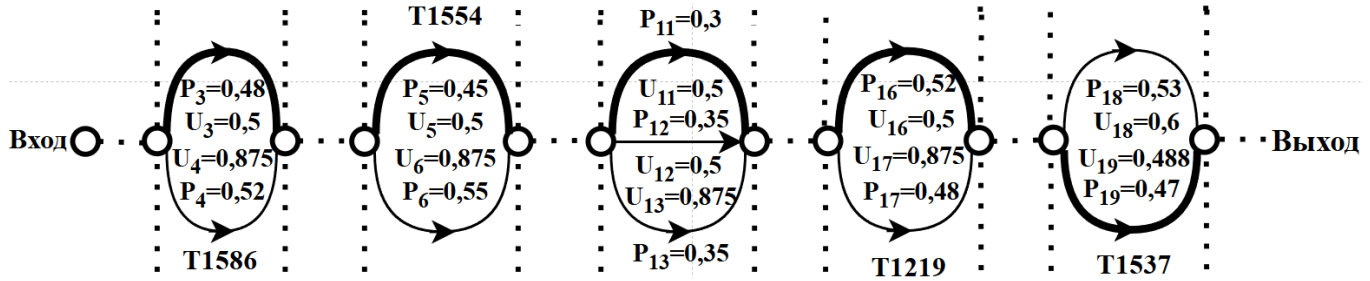


Рисунок 86 – Сценарий с минимальным риском для подсценария 3 шаблона атаки CAPEC-306

Сценарий, имеющий наибольшую вероятность реализации, изображён на рисунке 87. P_3 = 0.512648922 × 0.5528406 × 0.350167868 × 0.524090192 × 0.525534293 = 0.0273340108769302.

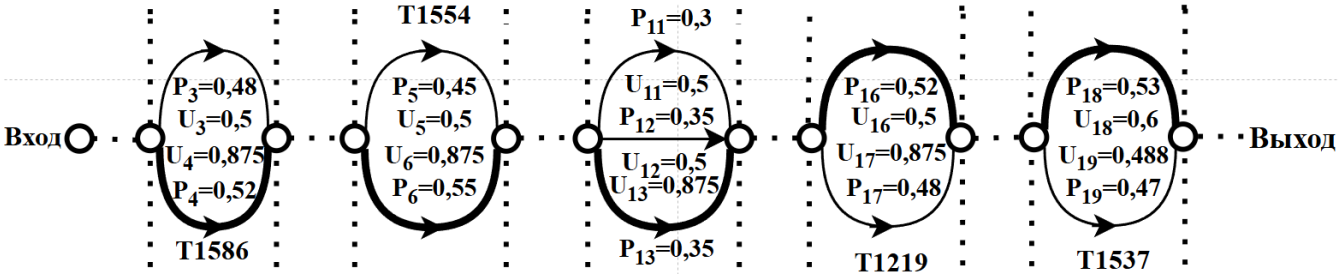


Рисунок 88 – Сценарий с наибольшим значением вероятности реализации для подсценария 3 шаблона атаки CAPEC-306

Приступим к исследованию последнего подсценария для CAPEC-306. Он изображён на рисунке 89. В таблице 68 приведены данные расчёта рисков для каждого сценария данного подсценария.

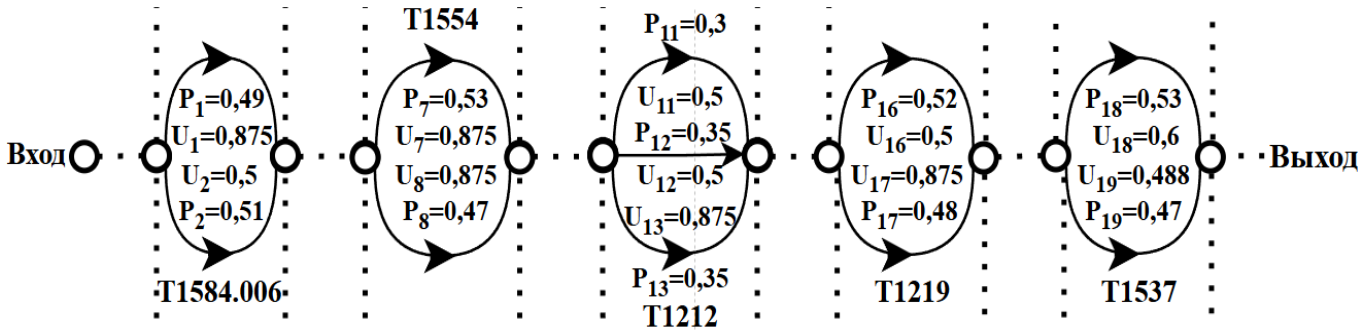


Рисунок 89 – Подсценарий 4 шаблона атаки CAPEC-306

Таблица 68 – Риски для подсценария 4 шаблона атаки CAPEC-306

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07346172560097101
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06410574191794506
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07417562573705459
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.06495411515780511
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.08406446260852295
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.0733581290170712
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.0848814000110283

Продолжение таблицы 68

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.07432894803768164
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	**0.09438638311358907**
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.08265227205257172
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.09433775716209755
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.08284391370127764
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.0656610579806464
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.05729855652765809
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.06629915132577681
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.05805684370422483
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07513792397734183
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06556846198938163
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07586811338840778
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.06643619281763995
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.08436379248519801
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.07387568945704615
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.08432032996925343
T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.07404698128696499
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.06588085702132479

Продолжение таблицы 68

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.05723970487215698
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.06736521498359273
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.05878567445369128
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07538944663196694
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06550111626951391
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07708804210322669
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.06727021577020799
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.08572032829908896
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.07480310594542153
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.08655335738378882
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.07579304774226935
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.05888517778889072
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	**0.05116160217663209**
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.060211916487541976
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.05254341015213243
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.06738408043010902
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.05854576050297361
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.06890230743623553
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-50338) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.060127004939288235

Продолжение таблицы 68

Сценарий в формате «техника (уязвимость)»	Риск
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449)	0.07661795854264726
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900)	0.06686000140119004
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-42449)	0.07736253091121847
T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-13310) -> T1537 (CVE-2024-48900)	0.0677448244187347

По итогам расчётов получаем сценарий с максимальным риском, изобразим его на рисунке 90. Это T1584.006 (CVE-2023-40723) -> T1554 (CVE-2023-1174) -> T1212 (CVE-2024-52975) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-42449), где Risk = 0.09438638311358907.

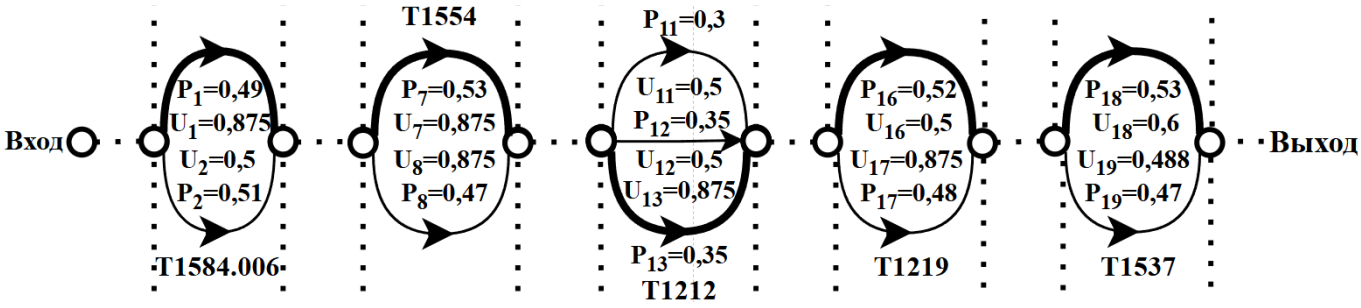


Рисунок 90 – Сценарий с максимальным риском для подсценария 4 шаблона атаки CAPEC-306

Минимальным риском обладает сценарий на рисунке 91. Это T1584.006 (CVE-2024-29958) -> T1554 (CVE-2023-23397) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900), где Risk = 0.05116160217663209.

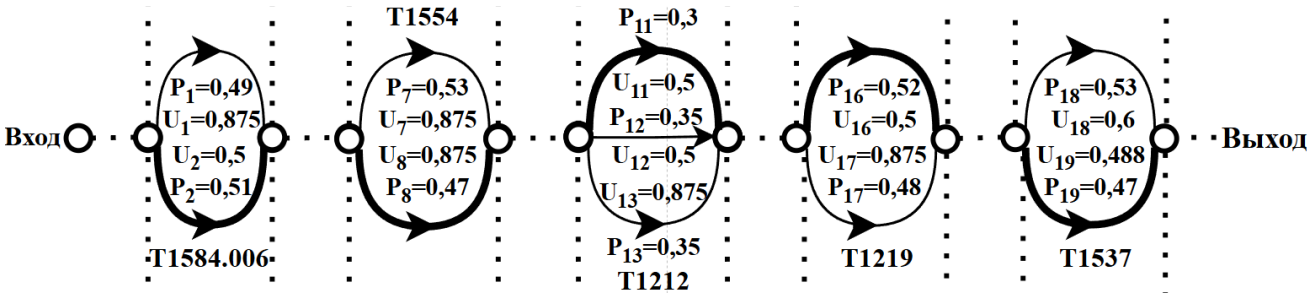


Рисунок 91 – Сценарий с минимальным риском для подсценария 4 шаблона атаки CAPEC-306

Наибольшей вероятностью реализации обладает сценарий, изображённый на рисунке 92. P_4 = 0.502449903 × 0.528035191 × 0.350167868 × 0.524090192 × × 0.525534293 = 0.025588157701220585.

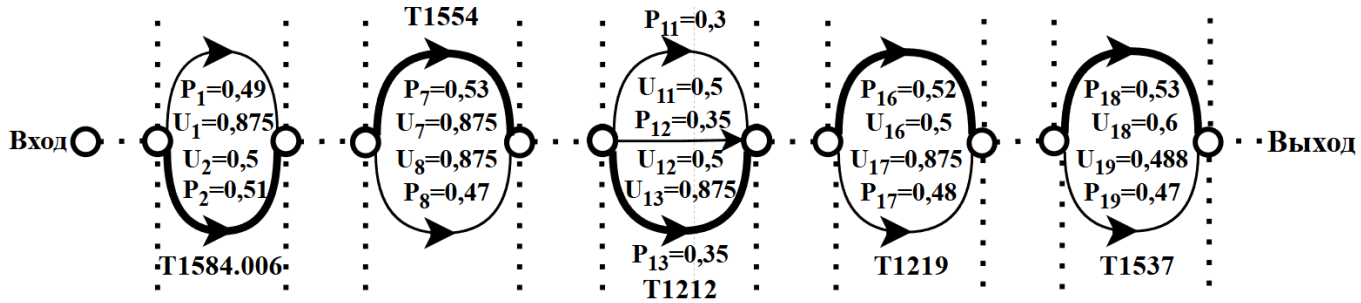


Рисунок 92 – Сценарий с наибольшим значением вероятности реализации для подсценария 4 шаблона атаки CAPEC-306

По итогам исследования подсценариев шаблона атаки CAPEC-306 можно выделить определённые сценарии в контексте всего множества сценариев.

Сценарий с наибольшим риском изображён на рисунке 93 – подсценарий 2 - T1586 (CVE-2024-29156) -> T1554 (CVE-2023-24838) -> T1056 (CVE-2023-1387) -> T1219 (CVE-2024-11053) -> T1537 (CVE-2024-42449), где Risk = 0.15011140349118254.

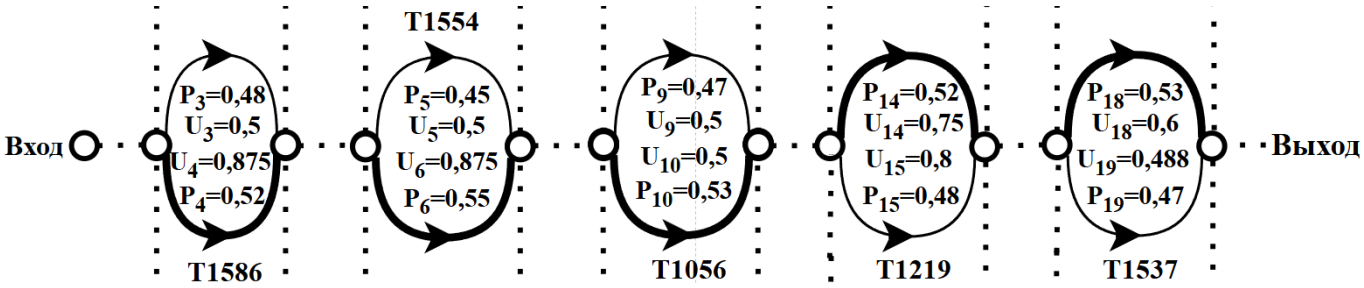


Рисунок 93 – Сценарий всего множества сценариев шаблона атаки CAPEC-306 с наибольшим значением риска

Сценарий с наименьшим риском изображён на рисунке 94 – подсценарий 3 - T1586 (CVE-2024-29966) -> T1554 (CVE-2024-24919) -> T1212 (CVE-2023-33001) -> T1219 (CVE-2024-12142) -> T1537 (CVE-2024-48900), где Risk = 0.040857809181083504.

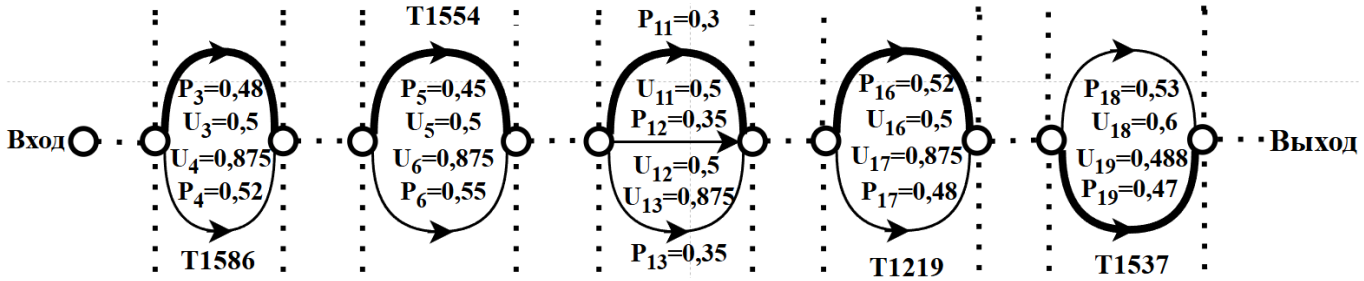


Рисунок 94 – Сценарий всего множества сценариев шаблона атаки CAPEC-306 с наименьшим значением риска

Сценарий с наибольшим значением вероятности реализации изображён на рисунке 95 – подсценарий 2 - P = 0.512648922 × 0.5528406 × 0.528694569 × × 0.529523571 × 0.525534293 = 0.04169761208088404.

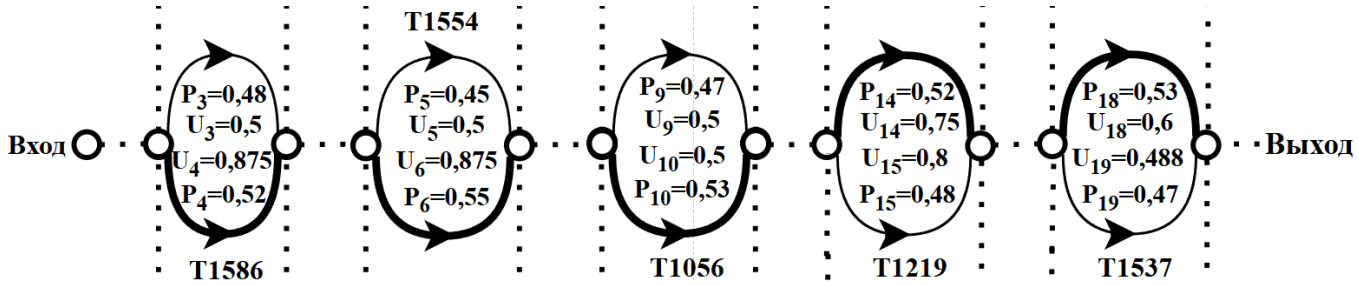


Рисунок 95 – Сценарий всего множества сценариев шаблона атаки CAPEC-306 с наибольшим значением вероятности исполнения

3.4 Формирование сценариев CAPEC-307 в виде последовательности реализации техник MITRE ATT&CK

3.4.1 Оценка критичности группы уязвимостей, связанной с CAPEC-307

Приступим к исследованию шаблона атаки CAPEC-307. Для начала приведём оценки риск-калькуляторов для группы уязвимостей, связанной с данным шаблоном атаки, необходимые для расчёта критичностей уязвимостей далее. В таблицах 69-70 приведены оценки риск-калькуляторов и нормализация этих оценок соответственно.

Таблица 69 – Оценки риск-калькуляторов для уязвимостей, связанных с шаблоном атаки CAPEC-307

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2024-20491	8.6	9.2	0.73	3.125
CVE-2024-43610	7.4	7.1	0.167	6.625
CVE-2024-44408	7.5	8.7	0.451	6.125
CVE-2024-45309	7.5	8.7	0.81849	6.625
CVE-2024-39593	6.9	6.5	0.123	6.375
CVE-2024-20490	8.6	9.2	0.73	3.5
CVE-2024-43609	6.5	7.1	0.16726	3.75
CVE-2024-7885	7.5	8.7	0.28035	6.375
CVE-2024-42019	9	9.1	0.155	6.25
CVE-2024-38650	9.9	9.4	0.193	3.5
CVE-2024-33003	9.1	9.3	0.153	6.375
CVE-2024-44000	7.5	8.7	0.92012	6.25
CVE-2024-42010	7.5	8.7	0.282	5.875
CVE-2024-21147	7.4	9.1	0.307	6
CVE-2024-39884	7.5	8.7	0.114	4.125
CVE-2024-27784	8.8	8.7	0.179	6.625
CVE-2024-38200	7.5	8.7	0.5572	4.375

Продолжение таблицы 69

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2024-41672	7.5	8.7	0.324	6.5
CVE-2024-22260	6.8	6.4	0.124	4
CVE-2024-21136	8.6	9.2	0.3124	6.375
CVE-2024-38020	6.5	6.8	0.511	3.25

Таблица 70 – Нормализованные оценки риск-калькуляторов уязвимостей, связанных с шаблоном атаки CAPEC-307

Уязвимость	$CVSS\ 3.1_{norm}$	$CVSS\ 4.0_{norm}$	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2024-20491	0.86	0.92	0.73	0.3125
CVE-2024-43610	0.74	0.71	0.167	0.6625
CVE-2024-44408	0.75	0.87	0.451	0.6125
CVE-2024-45309	0.75	0.87	0.81849	0.6625
CVE-2024-39593	0.69	0.65	0.123	0.6375
CVE-2024-20490	0.86	0.92	0.73	0.35
CVE-2024-43609	0.65	0.71	0.16726	0.375
CVE-2024-7885	0.75	0.87	0.28035	0.6375
CVE-2024-42019	0.9	0.91	0.155	0.625
CVE-2024-38650	0.99	0.94	0.193	0.35
CVE-2024-33003	0.91	0.93	0.153	0.6375
CVE-2024-44000	0.75	0.87	0.92012	0.625
CVE-2024-42010	0.75	0.87	0.282	0.5875
CVE-2024-21147	0.74	0.91	0.307	0.6
CVE-2024-39884	0.75	0.87	0.114	0.4125
CVE-2024-27784	0.88	0.87	0.179	0.6625
CVE-2024-38200	0.75	0.87	0.5572	0.4375
CVE-2024-41672	0.75	0.87	0.324	0.65
CVE-2024-22260	0.68	0.64	0.124	0.4
CVE-2024-21136	0.86	0.92	0.3124	0.6375
CVE-2024-38020	0.65	0.68	0.511	0.325

Теперь рассчитаем значения критичности и сведём эти данные в таблицу 71.

Таблица 71 – Значения критичностей для уязвимостей, связанных с шаблоном атак CAPEC-307

Уязвимость	Значение критичности
CVE-2024-20491	0.744405174
CVE-2024-43610	0.616136196
CVE-2024-44408	0.688831846
CVE-2024-45309	0.77913929
CVE-2024-39593	0.574485694
CVE-2024-20490	0.748565294

Продолжение таблицы 71

Уязвимость	Значение критичности
CVE-2024-43609	0.523259235
CVE-2024-7885	0.671640226
CVE-2024-42019	0.716371063
CVE-2024-38650	0.711239938
CVE-2024-33003	0.728494209
CVE-2024-44000	0.799475737
CVE-2024-42010	0.660318152
CVE-2024-21147	0.676378038
CVE-2024-39884	0.61289319
CVE-2024-27784	0.707503931
CVE-2024-38200	0.674773682
CVE-2024-41672	0.67949908
CVE-2024-22260	0.511706947
CVE-2024-21136	0.722841616
CVE-2024-38020	0.55938493

3.4.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-307

После проделанной работы по расчёту значения критичности для группы уязвимостей необходимо сделать разложение шаблона атаки CAPEC-307 на тактики и техники. В таблице 72 приведём соотношение техник и тактик с уязвимостями, связанными с данным шаблоном атак, а также сделаем расчёт значений ущерба и вероятностей успешной эксплуатации для каждой уязвимости.

Таблица 72 – Соотношение тактик и техник с уязвимостями с указанием их параметров для шаблона атаки CAPEC-307

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Значения ущерба
1	2	3	4	5	6
CAPEC-307	T1091 «Распространение через съемные носители»	CVE-2024-20491	0.744405174	0.547138948	0.5
		CVE-2024-43610	0.616136196	0.452861052	0.5
	T1098.004 «Изменение авторизованных SSH-ключей»	CVE-2024-44408	0.688831846	0.337256502	0.5
		CVE-2024-45309	0.77913929	0.381471607	0.5
		CVE-2024-39593	0.574485694	0.281271891	0.6
	T1205.001 «Простукивание портов»	CVE-2024-20490	0.748565294	0.588575922	0.5
		CVE-2024-43609	0.523259235	0.411424078	0.5
		ИЛИ			
	T1211 «Эксплуатация уязвимостей для предотвращения обнаружения»	CVE-2024-7885	0.671640226	0.483886717	0.5
		CVE-2024-42019	0.716371063	0.516113283	0.875
	T1016 «Изучение конфигурации сети»	CVE-2024-38650	0.711239938	0.494007828	0.875
		CVE-2024-33003	0.728494209	0.505992172	0.75
		ИЛИ			
		CVE-2024-44000	0.799475737	0.547663436	0.5
		CVE-2024-42010	0.660318152	0.452336564	0.5
	T1010 «Изучение открытых приложений»	CVE-2024-21147	0.676378038	0.524620439	0.75
		CVE-2024-39884	0.61289319	0.475379561	0.5
		ИЛИ			
		CVE-2024-27784	0.707503931	0.511839246	0.875
		CVE-2024-38200	0.674773682	0.488160754	0.5
	T1486 «Шифрование данных»	CVE-2024-41672	0.67949908	0.570429518	0.5
		CVE-2024-22260	0.511706947	0.429570482	0.75
		ИЛИ			
		CVE-2024-21136	0.722841616	0.563739394	0.5
		CVE-2024-38020	0.55938493	0.436260606	0.5

Первоначальный доступ реализуется с помощью техники T1091 «Распространение через съемные носители». Эксплуатация уязвимостей CVE-2024-20491 и CVE-2024-43610 приводят к исполнению этой техники.

Закрепление в системе происходит реализацией техники T1098.004 «Изменение авторизованных SSH-ключей» эксплуатацией уязвимостей CVE-2024-44408, CVE-2024-45309 и CVE-2024-39593.

Предотвращение обнаружения: предполагаемый злоумышленник, эксплуатируя уязвимости CVE-2024-20490, CVE-2024-43609 или CVE-2024-7885, CVE-2024-42019 выполняет техники T1205.001 «Простукивание портов» или T1211 «Эксплуатация уязвимостей для предотвращения обнаружения».

Предотвращение обнаружения происходит реализацией техники T1016 «Изучение конфигурации сети» или T1010 «Изучение открытых приложений» с эксплуатацией пар уязвимостей CVE-2024-38650, CVE-2024-33003 или CVE-2024-44000, CVE-2024-42010 для T1016 или CVE-2024-21147, CVE-2024-39884 или CVE-2024-21136, CVE-2024-38020 для T1010.

Шифрование данных потенциальный злоумышленник производит реализацией техники T1486 «Шифрование данных» с эксплуатацией уязвимостей CVE-2024-41672, CVE-2024-22260 или CVE-2024-21136, CVE-2024-38020.

Визуализируем данные таблицы 72 с помощью рисунка 96, сформировав множество сценариев для шаблона атаки CAPEC-307.

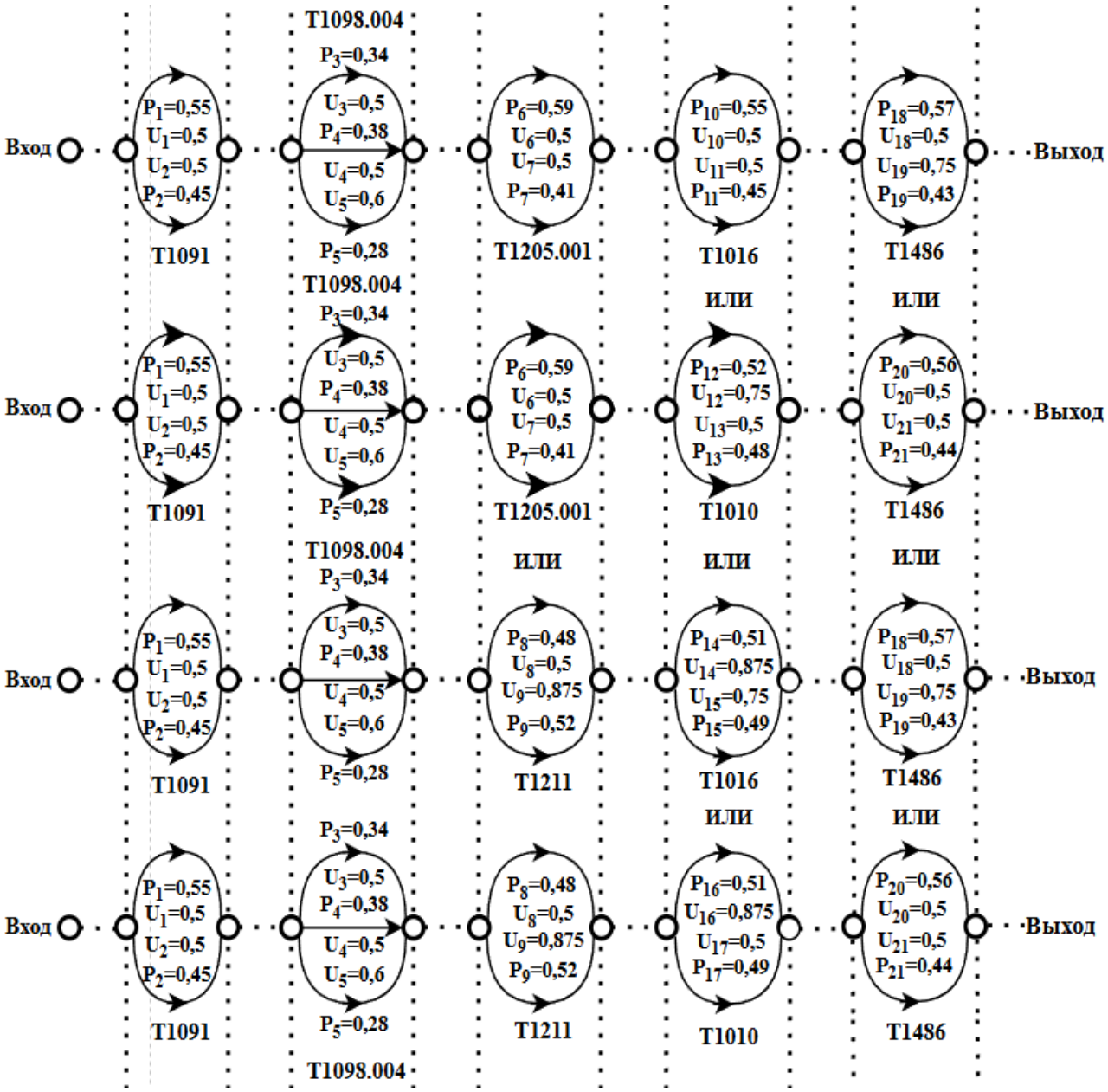


Рисунок 96 – Множество сценариев шаблона атаки CAPEC-307

Теперь необходимо выделить микромодели. На рисунках 97-106 изображены все «уникальные» микромодели сценариев атаки, а в таблицах 73-82 приведены параметры уязвимостей, связанных с данными микромоделями.

Таблица 73 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 1 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-20491	0.547138948	0.5

Продолжение таблицы 73

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-43610	0.452861052	0.5

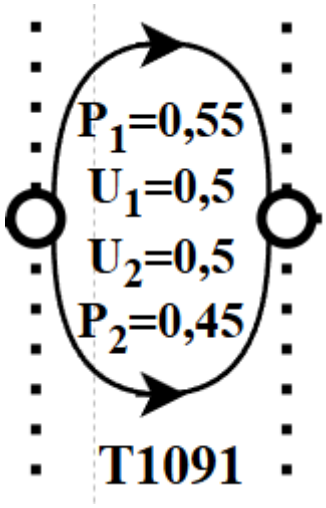


Рисунок 97 – Микромодель 1 шаблона атаки CAPEC-307

Таблица 74 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 2 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-44408	0.337256502	0.5
CVE-2024-45309	0.381471607	0.5
CVE-2024-39593	0.281271891	0.6

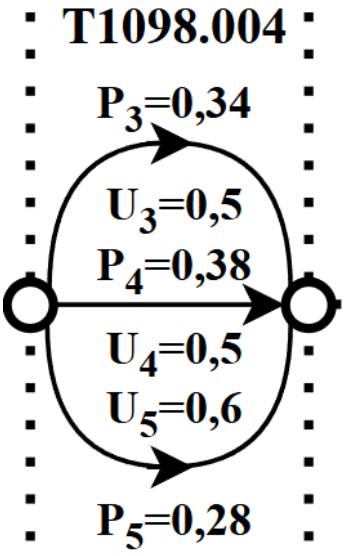


Рисунок 98 – Микромодель 2 шаблона атаки CAPEC-307

Таблица 75 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 3 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-20490	0.588575922	0.5
CVE-2024-43609	0.411424078	0.5

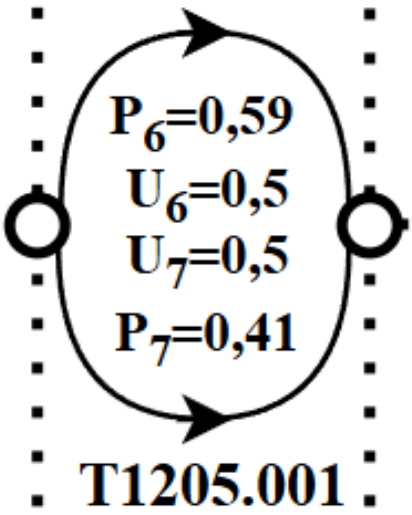


Рисунок 99 – Микромодель 3 шаблона атаки CAPEC-307

Таблица 76 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 4 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-7885	0.483886717	0.5
CVE-2024-42019	0.516113283	0.875

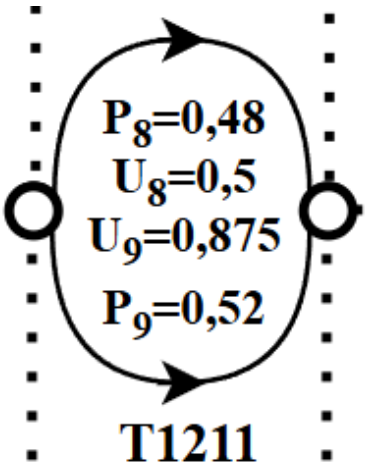


Рисунок 100 – Микромодель 4 шаблона атаки CAPEC-307

Таблица 77 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 5 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-44000	0.547663436	0.5
CVE-2024-42010	0.452336564	0.5

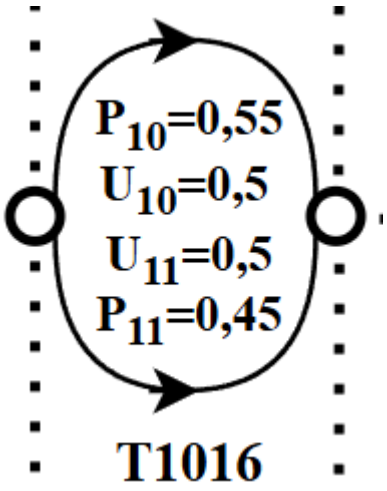


Рисунок 101 – Микромодель 5 шаблона атаки CAPEC-307

Таблица 78 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 6 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-21147	0.524620439	0.75
CVE-2024-39884	0.475379561	0.5

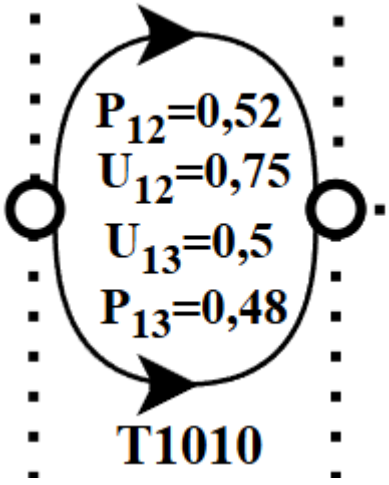


Рисунок 102 – Микромодель 6 шаблона атаки CAPEC-307

Таблица 79 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 7 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-38650	0.494007828	0.875
CVE-2024-33003	0.505992172	0.75

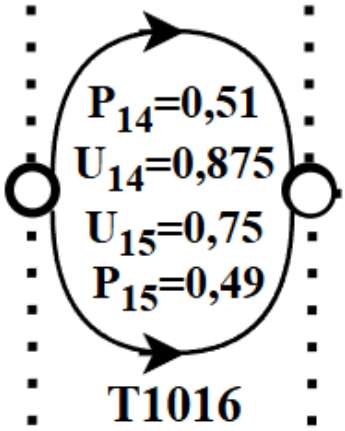


Рисунок 103 – Микромодель 7 шаблона атаки CAPEC-307

Таблица 80 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 8 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-27784	0.511839246	0.875
CVE-2024-38200	0.488160754	0.5

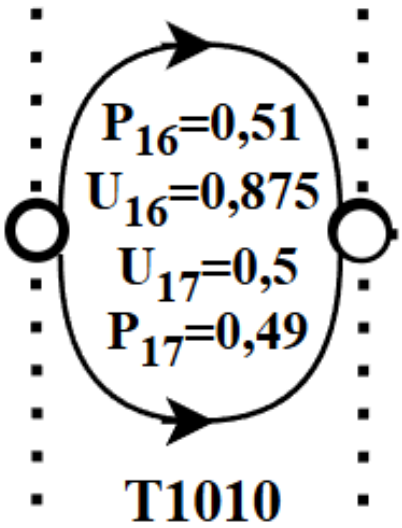


Рисунок 104 – Микромодель 8 шаблона атаки CAPEC-307

Таблица 81 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 9 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-41672	0.570429518	0.5
CVE-2024-22260	0.429570482	0.75

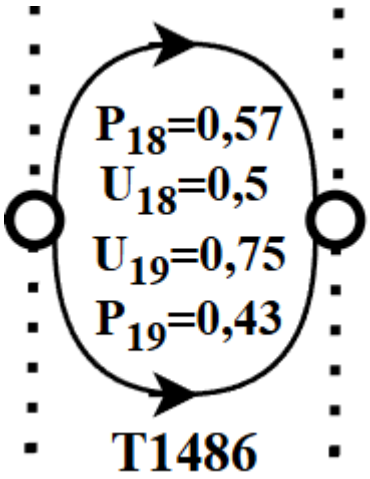


Рисунок 105 – Микромодель 9 шаблона атаки CAPEC-307

Таблица 82 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 10 для CAPEC-307

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-21136	0.563739394	0.5
CVE-2024-38020	0.436260606	0.5

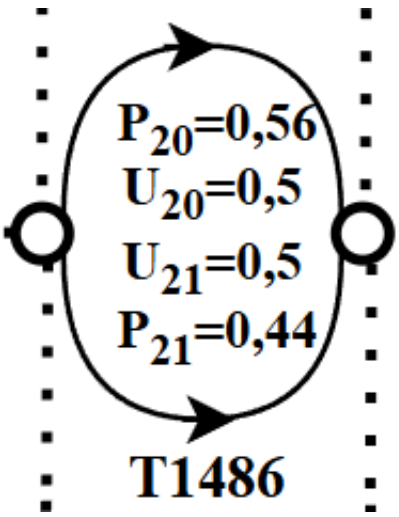


Рисунок 106 – Микромодель 10 шаблона атаки CAPEC-307

3.4.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-307

После разработки и анализа микромоделей представляется возможным формирование подсценариев основного сценария шаблона атаки CAPEC-307. На рисунке 107 изображён первый подсценарий, а в таблице 83 приведён расчёт рисков для каждого сценария этого подсценария.

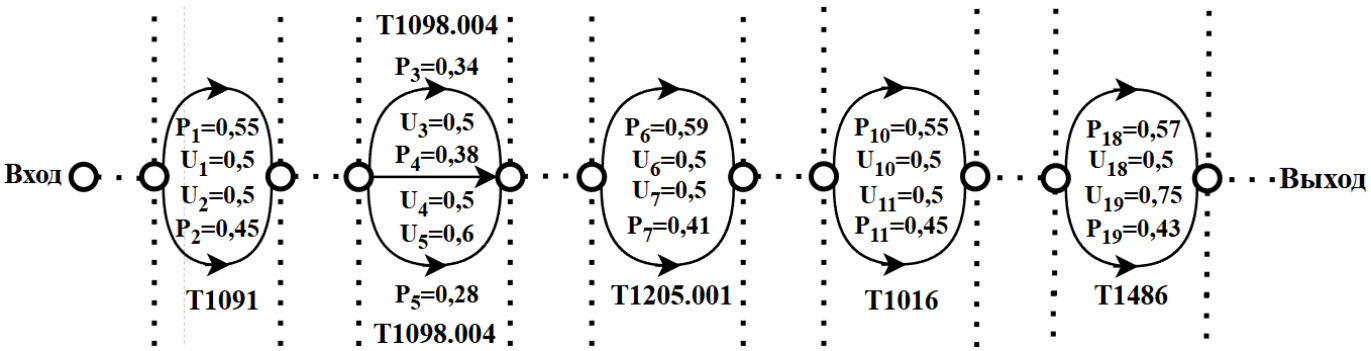


Рисунок 107 – Подсценарий 1 шаблона атаки CAPEC-307

Таблица 83 – Риски для подсценария 1 шаблона CAPEC-307

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.08482350231011107
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.0702653680862125
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.07005903454435053
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.05803490443045136
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.05929299844968569
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.0491166274385934
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.048972396959486166

Продолжение таблицы 83

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.04056733575845559
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	**0.09594405903434972**
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.07947731984806626
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.07924393550313794
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.06564341420814387
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.06706644725399573
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.055555930540430364
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.055392791112970456
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.04588580700954616
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.07357250468027485
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.06073226712737489
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.06076639736078609
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.05016114502178836
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.051428369345072805
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.042452835859856874
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.04247669344438975

Продолжение таблицы 83

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.03506345073017371
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.07020750511528441
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.0581578932134245
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.05798711314892341
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.04803486933102351
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.049076180287130684
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.040653306904653894
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.04053392888059306
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.033577149672063586
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.07941187090823905
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.06578252710413107
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.06558935737941872
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.05433235145082704
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.05551018067415486
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.04598304917122849
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.04584802041297205

Продолжение таблицы 83

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.037979191410464255
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.06089517478069244
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.05026744756918312
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.05029569679812962
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	0.041517842930259896
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672)	0.04256671094132057
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-22260)	0.03513775792813439
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-41672)	0.035157504595538035
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260)	**0.029021642934504883**

По результатам расчётов замечаем, что наибольшим риском обладает сценарий T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1016 (CVE-2024-44000) -> T1486 (CVE-2024-41672), где Risk = 0.09594405903434972. Изобразим его на рисунке 108.

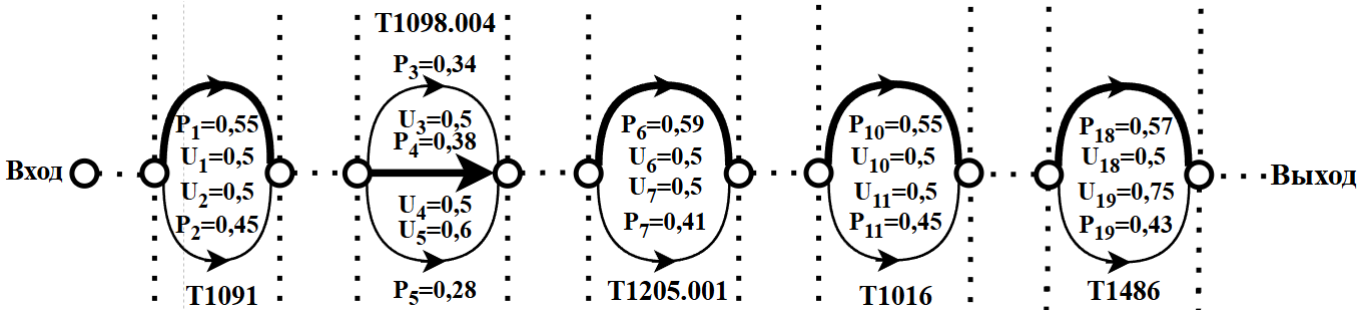


Рисунок 108 – Сценарий с максимальным риском подсценария 1 шаблона атаки CAPEC-307

Минимальный риск имеет сценарий на рисунке 109. Это T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260), где Risk = 0.029021642934504883.

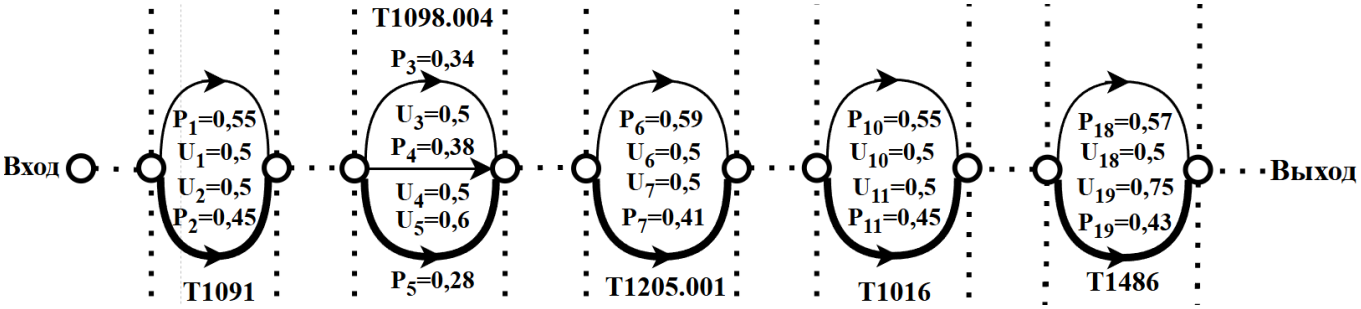


Рисунок 109 – Сценарий с наименьшим риском подсценария 1 шаблона атаки CAPEC-307

Сценарий, имеющий наибольшее значение вероятности реализации, изображён на рисунке 110. P_1 = 0.547138948 × 0.381471607 × 0.588575922 × 0.547663436 × × 0.570429518 = 0.038377623613739885.

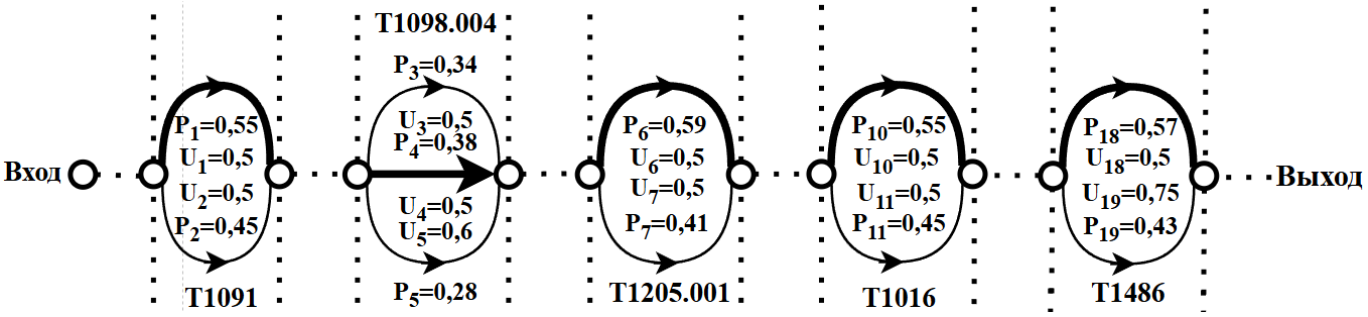


Рисунок 110 – Сценарий с наибольшим значением вероятности реализации для подсценария 1 шаблона атаки CAPEC-307

Приступим к анализу второго подсценария шаблона атаки CAPEC-307, изображённого на рисунке 111. В таблице 84 приведены результаты расчёта рисков для данного подсценария.

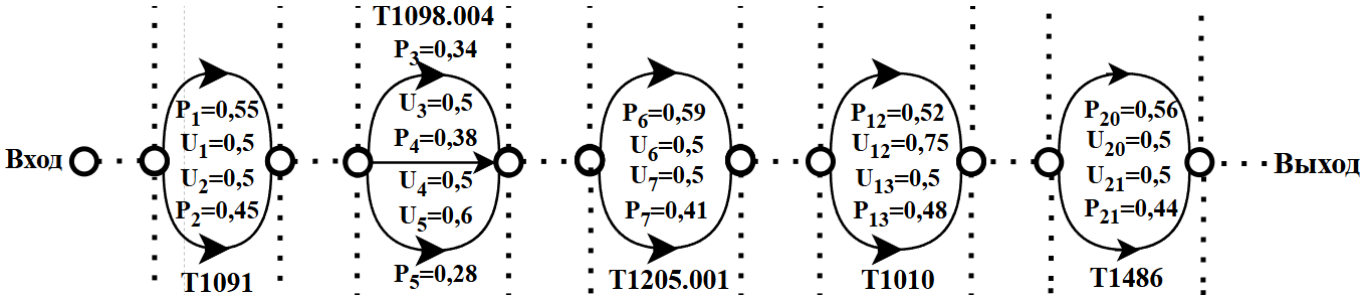


Рисунок 111 – Подсценарий 2 шаблона атаки CAPEC-307

Таблица 84 – Риски подсценария 2 шаблона атаки CAPEC-307

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.0883317304595804
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.06835721375775489
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.07276446693933371
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.05631018655088116
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.0617453066020553

Продолжение таблицы 84

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.047782796736515545
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.0508635379101982
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.03936173009759017
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	**0.09991222398288109**
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.07731900208765513
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.08230405632282221
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.06369258183800536
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.06984025865924964
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.05404723155799362
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.057531865002587036
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.04452214366686394
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.07634751508755214
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.05908299748640529
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.0631129809387002
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.04884119790781164
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.05336814645042043

Продолжение таблицы 84

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.04129996973664957
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.044116993274720316
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.03414078637358348
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.07311122801096226
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.05657853429605555
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.060226370589808356
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.04660733879933602
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.05110592950123761
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.03954930950666044
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.04209920600727227
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.03257928276846916
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.08269627857044305
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.063996110591282
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.06812218663369678
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.05271766837508193
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.0578060346900764

Продолжение таблицы 84

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.044734315168951544
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.047618508979904585
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.036850501855099416
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.0631920211977575
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.048902364737168844
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.05223793891338133
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	0.04042533682956122
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136)	0.04417224369270721
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-38020)	0.034183542975462396
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-21136)	0.03651516321127767
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020)	**0.028257963520535705**

При анализе результатов замечаем сценарий с максимальным риском. Нанесём его на рисунок 112. Это T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1205.001 (CVE-2024-20490) -> T1010 (CVE-2024-21147) -> T1486 (CVE-2024-21136), где Risk = 0.09991222398288109.

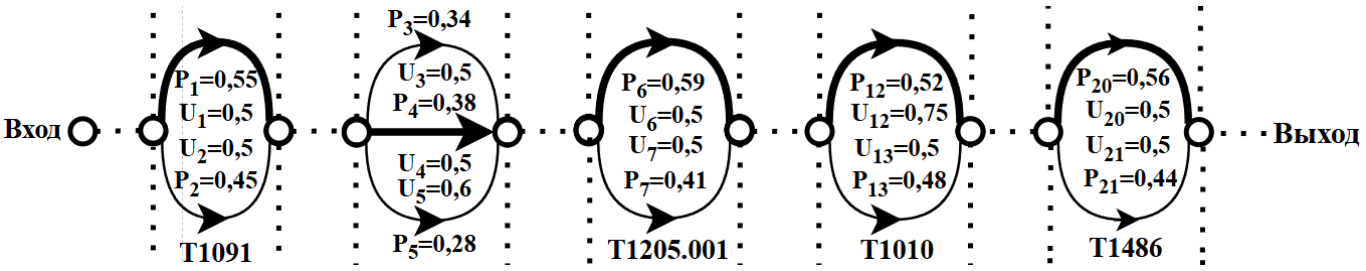


Рисунок 112 – Сценарий с максимальным риском подсценария 2 шаблона атаки CAPEC-307

Минимальный риск имеет сценарий T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1010 (CVE-2024-39884) -> T1486 (CVE-2024-38020), где Risk = 0.028257963520535705. Он изображён на рисунке 113.

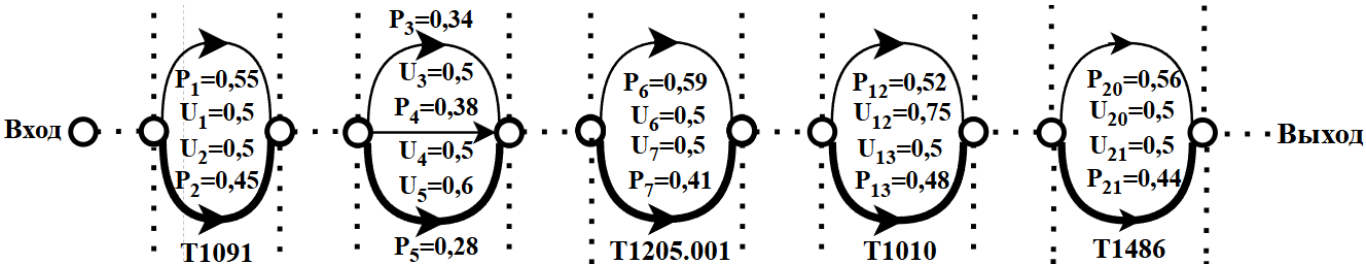


Рисунок 113 – Сценарий с минимальным риском подсценария 2 для шаблона атаки CAPEC-307

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 114. P_2 = 0.547138948 × 0.381471607 × 0.588575922 × 0.524620439 × × 0.563739394 = 0.03633171781195676.

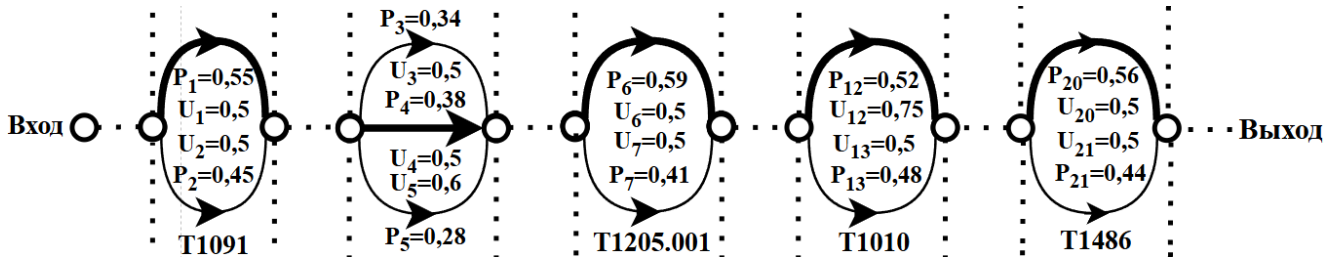


Рисунок 114 – Сценарий с наибольшим значением вероятности реализации для подсценария 2 шаблона атаки CAPEC-307

Перейдём к рассмотрению третьего подсценария, изображённого на рисунке 115. В таблице 85 приведены результаты расчёта рисков сценариев данного подсценария.

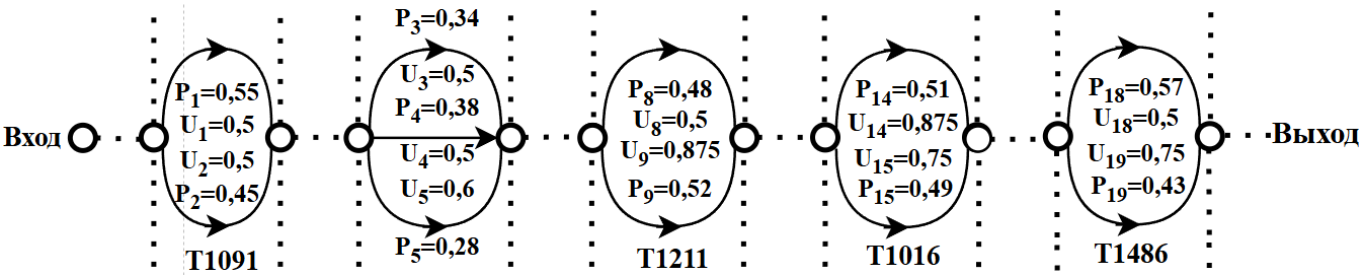


Рисунок 115 – Подсценарий 3 шаблона атаки CAPEC-307

Таблица 85 – Риски подсценария 3 шаблона атаки CAPEC-307

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.07087289052741019
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.05822388049177069
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.0723394718312628
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.0592133928709919
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.08590111665490122
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.06986425063060442
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.08722122488472188
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.07073580575943439
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.08016448988202529
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.06585716546681053

Продолжение таблицы 85

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.08182334337620287
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.06697640520039438
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.0971629511043189
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.07902361496920059
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	**0.09865612856674663**
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.08000943298490147
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.06125736528297585
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.05017733455841363
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.06242958620040744
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.050964250945356136
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.07393405196734443
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.05999320153140269
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.07498072392892735
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.060679188371681465
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.05866073303654451
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.04819128279463217

Продолжение таблицы 85

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.05987460668698372
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.04901029160155254
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.07109943497627459
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.05782589258801437
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.0721920744308331
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.05854726944111665
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.06635129038742335
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.05450927108014596
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.06772430567217538
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.05543565382998266
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.08042073483046289
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.06540700043125998
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.08165662183673339
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.06622295145303016
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.05070206569318607
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	**0.04153124283647077**

Продолжение таблицы 85

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.051672300401910336
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.04218256510868236
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-41672)	0.06119442360106719
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260)	0.04965573088457785
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672)	0.06206074278260959
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-22260)	0.05022351485112303

Проанализируем полученные результаты. Максимальный риск имеет сценарий T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1016 (CVE-2024-38650) -> T1486 (CVE-2024-41672), где Risk = 0.09865612856674663. Он изображён на рисунке 116.

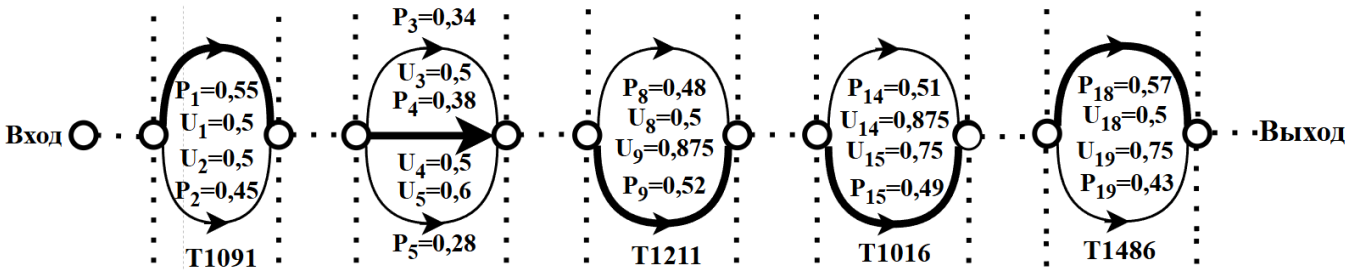


Рисунок 116 – Сценарий с наибольшим риском подсценария 3 шаблона атаки CAPEC-307

Минимальным риском обладает сценарий на рисунке 117. Это T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1016 (CVE-2024-33003) -> T1486 (CVE-2024-22260), где Risk = 0.04153124283647077.

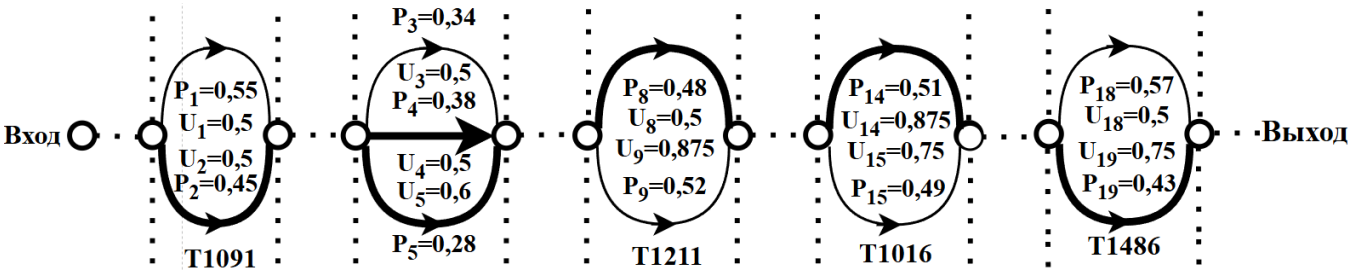


Рисунок 117 – Сценарий с наименьшим риском подсценария 3 шаблона атаки CAPEC-307

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 118. P_3 = 0.547138948 × 0.381471607 × 0.516113283 × 0.505992172 × × 0.570429518 = 0.031092144353382048.

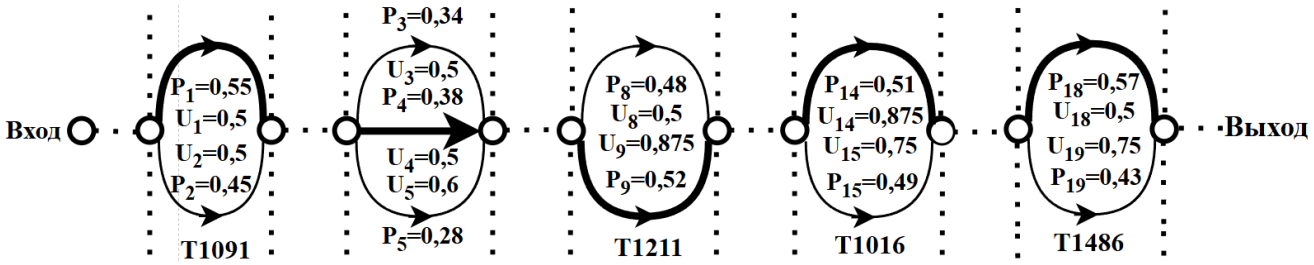


Рисунок 118 – Сценарий с наибольшим значением вероятности реализации для подсценария 3 шаблона атаки CAPEC-307

Приступим к анализу последнего подсценария в рамках данного шаблона атаки. Он изображён на рисунке 119. В таблице 86 приведены результаты расчёта рисков для четвёртого подсценария.

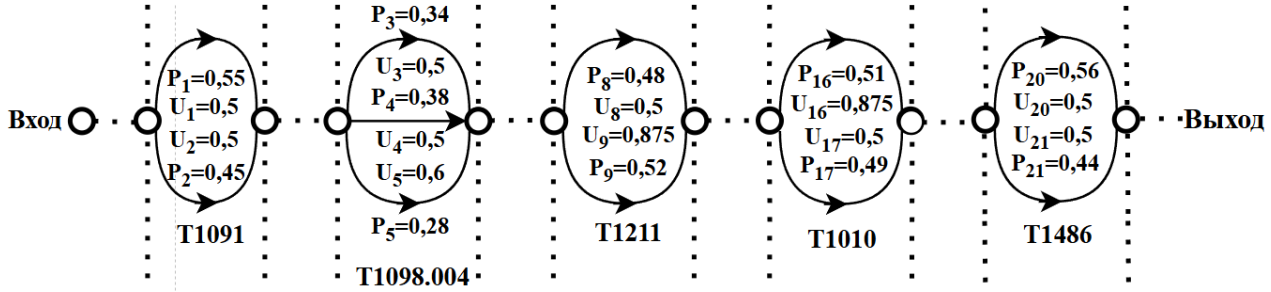


Рисунок 119 – Подсценарий 4 шаблона атаки CAPEC-307

Таблица 86 – Риски подсценария 4 шаблона атаки CAPEC-307

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.0740715579355857
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.057321704135408935
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.061430339708804654
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.04753905352966868
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.08930963758390832
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.06911398605220806
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.07534979813953831
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.058310894977711386
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.08378250996234753
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.06483671171004729
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.06948399888009756
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.05377153305474814
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	**0.10101833698589775**
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.07817498897474597
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.08522833040418382
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.065955587752481

Продолжение таблицы 86

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.06392439140175842
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.0494691235488012
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.05328221345086057
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.04123346882707613
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.07677605180071916
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.05941462888944238
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.06502752368870164
T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.05032280375125308
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.06130823581944724
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.04744456107919782
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.05084523477434226
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.039347565862794455
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.07392063127260218
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.057204906625503586
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.06236622155704944
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-44408) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.04826330375345146

Продолжение таблицы 86

Сценарий в формате «техника (уязвимость)»	Риск
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.06934588688931934
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.05366465242615617
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.057511162283420195
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.044506122468229076
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.08361179646586624
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.06470460177730185
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.07054257699644201
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.054590734152719964
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.05290953467026821
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.040945064162802185
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.04410111786859171
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	**0.034128500884274285**
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136)	0.06354671644921936
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-38020)	0.04917685250047756
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-21136)	0.0538225854588958
T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020)	0.04165164613063154

Замечаем, что максимальный риск имеет сценарий T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136), где Risk = 0.10101833698589775. Он продемонстрирован на рисунке 120.

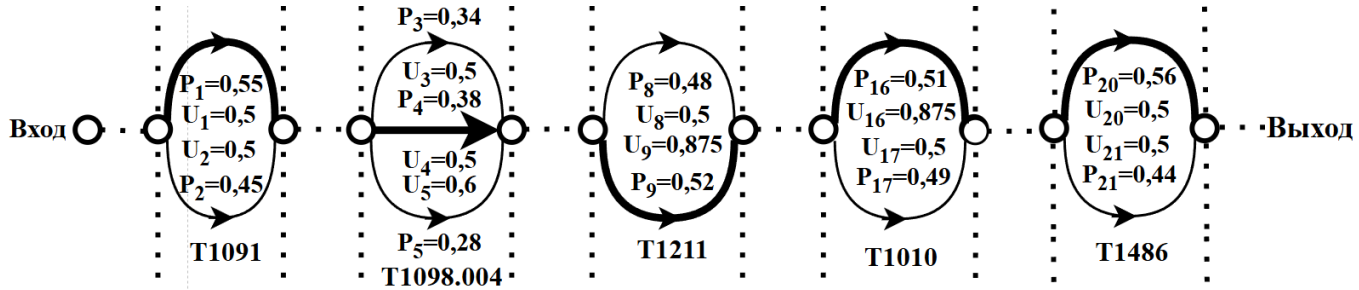


Рисунок 120 – Сценарий с максимальным риском подсценария 4 шаблона атаки CAPEC-307

Минимальным риском обладает сценарий на рисунке 121. Это T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1211 (CVE-2024-7885) -> T1010 (CVE-2024-38200) -> T1486 (CVE-2024-38020), где Risk = 0.034128500884274285.

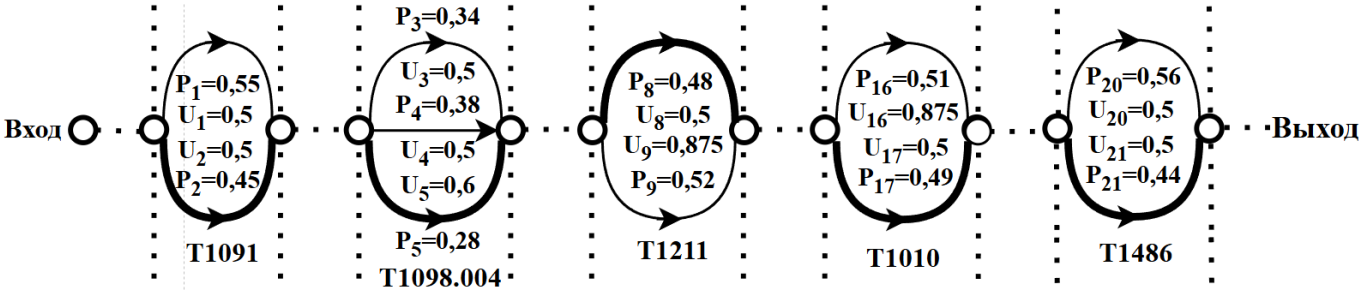


Рисунок 121 – Сценарий с минимальным риском подсценария 3 шаблона атаки CAPEC-307

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 122. P_4 = 0.547138948 × 0.381471607 × 0.516113283 × 0.511839246 × × 0.563739394 = 0.03108256522643008.

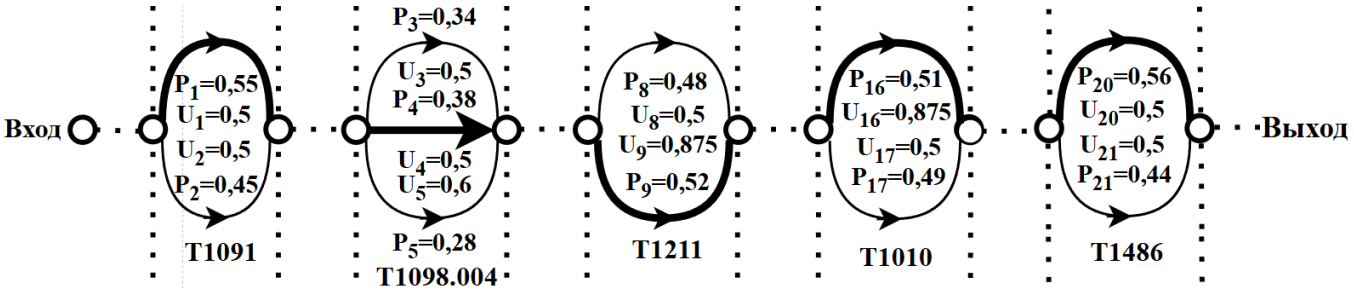


Рисунок 122 - Сценарий с наибольшим значением вероятности реализации для подсценария 3 шаблона атаки CAPEC-307

После анализа полученных после иследования подсценариев шаблона атаки CAPEC-307 можно выделить определённые сценарии для всего множества сценариев.

Сценарий с наибольшим риском изображён на рисунке 123 – подсценарий 4 - T1091 (CVE-2024-20491) -> T1098.004 (CVE-2024-45309) -> T1211 (CVE-2024-42019) -> T1010 (CVE-2024-27784) -> T1486 (CVE-2024-21136), где Risk = 0.10101833698589775.

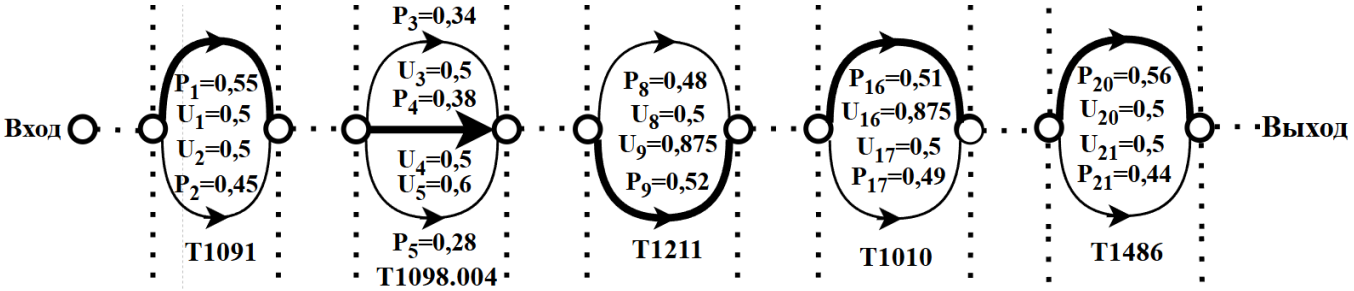


Рисунок 123 – Сценарий с наибольшим значением риска для всего множества сценариев CAPEC-307

Сценарий с наименьшим риском изображён на рисунке 124 – подсценарий 2 - T1091 (CVE-2024-43610) -> T1098.004 (CVE-2024-39593) -> T1205.001 (CVE-2024-43609) -> T1016 (CVE-2024-42010) -> T1486 (CVE-2024-22260), где Risk = 0.029021642934504883.

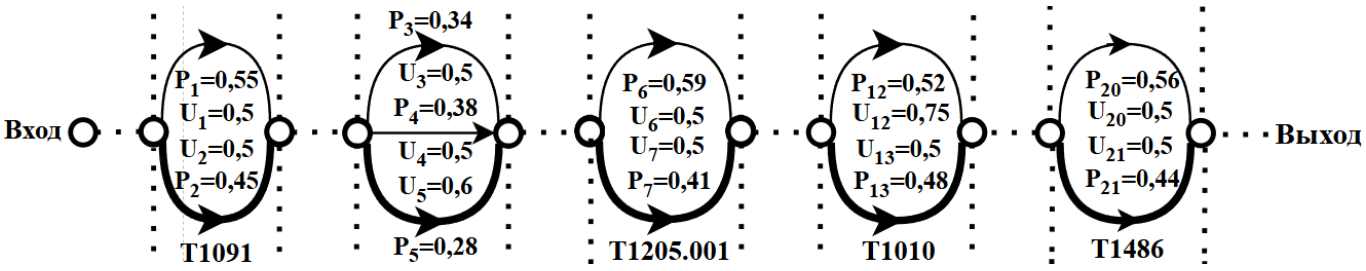


Рисунок 124 - Сценарий с наименьшим значением риска для всего множества сценариев CAPEC-307

Сценарий, имеющий наибольшую вероятность реализации злоумышленником, изображён на рисунке 125 – подсценарий 1 - P_1 = 0.547138948 × 0.381471607 × × 0.588575922 × 0.547663436 × 0.570429518 = 0.038377623613739885.

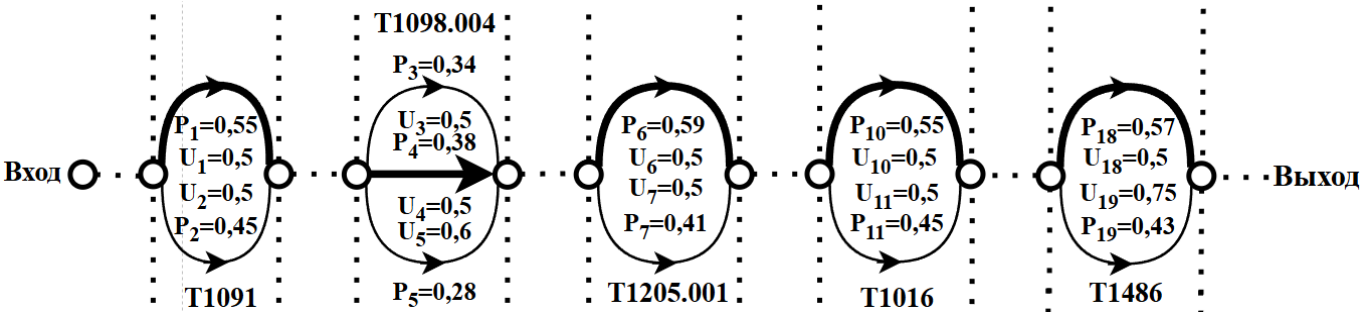


Рисунок 125 - Сценарий с наибольшим значением вероятности реализации для всего множества сценариев CAPEC-307

3.5 Формирование сценариев CAPEC-308 в виде последовательности реализации техник MITRE ATT&CK

3.5.1 Оценка критичности группы уязвимостей, связанной с CAPEC-308

Перейдём к рассмотрению последнего в рамках данного исследования шаблона атаки - CAPEC-308. Для начала работы приведём в таблицах 87-88 оценки риск-калькуляторов для группы уязвимостей, связанных с CAPEC-308, и приведённые в допустимую область значений оценки.

Таблица 87 – Оценки риск-калькуляторов для группы уязвимостей, связанных с CAPEC-308

Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CVE-2024-55875	9.8	9.3	0.0122	7.2
CVE-2024-54134	7.4	8.3	0.0843	6.9
CVE-2023-50968	8.3	6.9	0.8153	8.8
CVE-2023-50224	6.5	7.1	0.1223	4.5
CVE-2023-42922	5.5	6.8	0.2143	6.875
CVE-2023-47146	4.4	5.9	0.3921	3
CVE-2023-34064	4.6	5.1	0.3512	5.625
CVE-2023-36009	5.5	6.8	0.132	3.125
CVE-2023-35636	6.5	7.1	0.11064	4.25
CVE-2023-35643	7.5	8.7	0.729	3.75
CVE-2023-43804	8.1	8.6	0.554	4.875
CVE-2023-21825	5.3	6.9	0.0261	6.375
CVE-2024-53243	4.3	5.3	0.512	3.125
CVE-2024-39600	5	5.6	0.2935	5
CVE-2024-43432	5.3	6.9	0.3853	6.25

Таблица 88 – Нормализованные оценки риск-калькуляторов для уязвимостей, связанных с шаблоном атаки CAPEC-308

Уязвимость	CVSS 3.1_{norm}	CVSS 4.0_{norm}	$EPSS_{norm}$	$OWASP_{norm}$
CVE-2024-55875	0.98	0.93	0.0122	0.72
CVE-2024-54134	0.74	0.83	0.0843	0.69
CVE-2023-50968	0.83	0.69	0.8153	0.88
CVE-2023-50224	0.65	0.71	0.1223	0.45
CVE-2023-42922	0.55	0.68	0.2143	0.6875
CVE-2023-47146	0.44	0.59	0.3921	0.3
CVE-2023-34064	0.46	0.51	0.3512	0.5625
CVE-2023-36009	0.55	0.68	0.132	0.3125
CVE-2023-35636	0.65	0.71	0.11064	0.425
CVE-2023-35643	0.75	0.87	0.729	0.375
CVE-2023-43804	0.81	0.86	0.554	0.4875
CVE-2023-21825	0.53	0.69	0.0261	0.6375
CVE-2024-53243	0.43	0.53	0.512	0.3125
CVE-2024-39600	0.5	0.56	0.2935	0.5
CVE-2024-43432	0.53	0.69	0.3853	0.625

После получения нормализованных оценок риск-калькуляторов становится возможным расчёт значений критичностей для каждой уязвимости. Приведём эти данные в таблице 89.

Таблица 89 – Значения критичностей уязвимостей, связанных с шаблоном атаки CAPEC-308

Уязвимость	Значение критичности
CVE-2024-55875	0.765481685
CVE-2024-54134	0.6556879
CVE-2023-50968	0.806863385
CVE-2023-50224	0.534803069
CVE-2023-42922	0.566454045
CVE-2023-47146	0.443125944
CVE-2023-34064	0.477348848
CVE-2023-36009	0.469036313
CVE-2023-35636	0.529024151
CVE-2023-35643	0.705596556
CVE-2023-43804	0.696468278
CVE-2023-21825	0.539464424
CVE-2024-53243	0.454312736
CVE-2024-39600	0.474273721
CVE-2024-43432	0.569227786

3.5.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущерба, расчёт вероятностей успешной эксплуатации уязвимостей и значений ущерба для шаблона атак CAPEC-308

После вычисления значений критичности для каждой уязвимости рассматриваемой группы проведём соотношение тактик и техник с уязвимостями с приведением значений ущерба и вероятностей успешной эксплуатации уязвимостей, а также критичности. для систематизации имеющихся данных сведём упомянутые данные в таблицу 90.

Таблица 90 – Соотношение тактик и техник с уязвимостями для шаблона атаки CAPEC-308

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Значения ущерба
CAPEC-308	T1190 «Недостатки в общедоступном приложении»	CVE-2024-55875	0.765481685	0.538627967	0.875
		CVE-2024-54134	0.6556879	0.461372033	0.5
	T1059 «Интерпретаторы командной строки и сценариев»	CVE-2023-42922	0.566454045	0.380955719	0.5
		CVE-2023-47146	0.443125944	0.298014225	0.5
		CVE-2023-34064	0.477348848	0.321030056	0.5
		ИЛИ			
	T1203 «Эксплуатация для выполнения клиентом»	CVE-2023-50224	0.534803069	0.398611046	0.5
		CVE-2023-50968	0.806863385	0.601388954	0.5
	T1555 «Учетные данные из хранилищ паролей»	CVE-2023-36009	0.469036313	0.469947793	0.5
		CVE-2023-35636	0.529024151	0.530052207	0.5
		ИЛИ			
		CVE-2023-35643	0.705596556	0.503255298	0.5
		CVE-2023-43804	0.696468278	0.496744702	0.75
	T1046 «Изучение сетевых служб»	CVE-2023-21825	0.539464424	0.542842446	0.2
		CVE-2024-53243	0.454312736	0.457157554	0.2
	T1021 «Службы удаленного доступа»	CVE-2024-39600	0.474273721	0.454502191	0.5
		CVE-2024-43432	0.569227786	0.545497809	0.2

Первоначальный доступ реализуется техникой T1190 «Недостатки в общедоступном приложении». К этой технике приводит эксплуатация уязвимостей CVE-2024-55875 и CVE-2024-54134.

Тактика «Выполнение»: реализация производится эксплуатацией уязвимостей, приводящим к техникам T1059 «Интерпретаторы командной строки и сценариев» и T1203 «Эксплуатация уязвимостей в клиентском ПО». Сами уязвимости имеют идентификаторы CVE-2023-42922, CVE-2023-47146, CVE-2023-34064 CVE-2023-50224 и CVE-2023-50968 соответственно.

Получение учётных данных происходит посредством техники T1555 «Учётные данные из хранилищ паролей». К ней приводит эксплуатация следующих уязвимостей: CVE-2023-36009, CVE-2023-35636 и CVE-2023-35643, CVE-2023-43804 соответственно.

Тактика «Обнаружение» реализуется посредством техники T1046 «Изучение сетевых служб», эксплуатация уязвимостей CVE-2023-21825 или CVE-2024-53243 приводят к ней.

Перемещение внутри периметра реализуется техникой T1021 «Службы удалённого доступа» и приводит к ней эксплуатация уязвимости CVE-2024-39600 и CVE-2024-43432.

Визуализируем данные таблицы 90 с помощью рисунка 126.

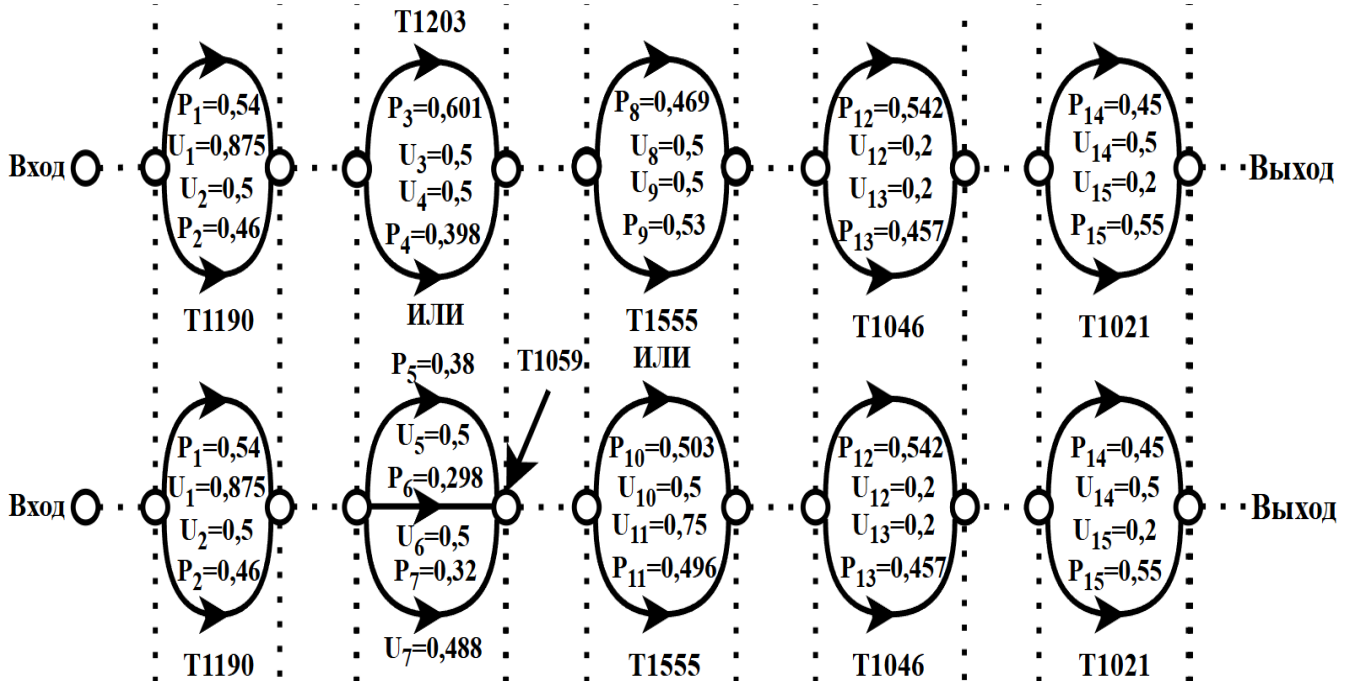


Рисунок 126 – Множество сценариев шаблона атаки CAPEC-308

Далее необходимо выделить микромодели разработанного общего сценария шаблона атаки CAPEC-308. На рисунках 127-133 изображены данные микромодели, а в таблицах 91-97 приведены необходимые для расчёта рисков параметры.

Таблица 91 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 1 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-55875	0.538627967	0.875
CVE-2024-54134	0.461372033	0.5

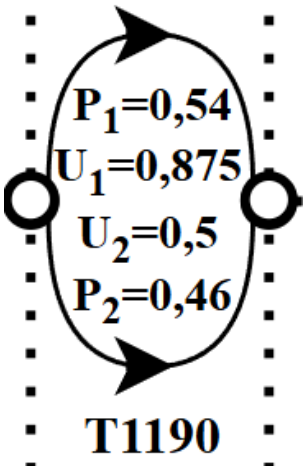


Рисунок 127 – Микромодель 1 шаблона атаки CAPEC-308

Таблица 92 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 2 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-50224	0.398611046	0.5
CVE-2023-50968	0.601388954	0.5

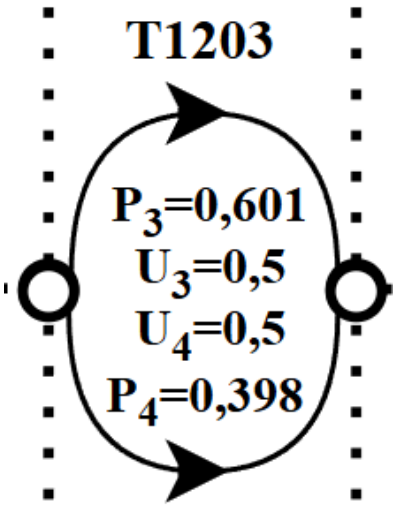


Рисунок 128 – Микромодель 2 шаблона атаки CAPEC-308

Таблица 93 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 3 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-42922	0.380955719	0.5
CVE-2023-47146	0.298014225	0.5
CVE-2023-34064	0.321030056	0.5

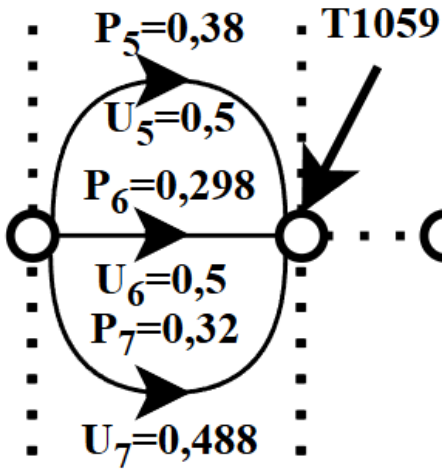


Рисунок 129 – Микромодель 3 шаблона атаки CAPEC-308

Таблица 94 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 4 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-36009	0.469947793	0.5
CVE-2023-35636	0.530052207	0.5

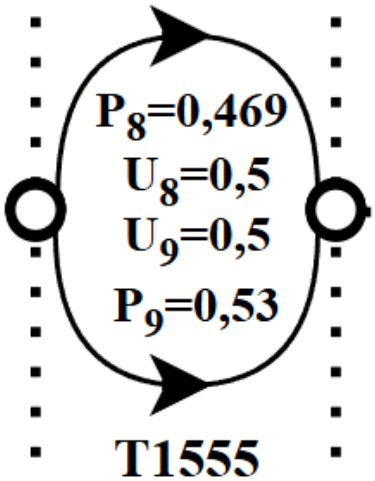


Рисунок 130 – Микромодель 4 шаблона атаки CAPEC-308

Таблица 95 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 5 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-35643	0.503255298	0.5
CVE-2023-43804	0.496744702	0.75

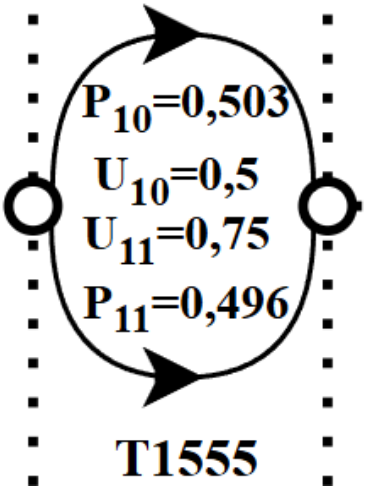


Рисунок 131 – Микромодель 5 шаблона атаки CAPEC-308

Таблица 96 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 6 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2023-21825	0.542842446	0.2
CVE-2024-53243	0.457157554	0.2

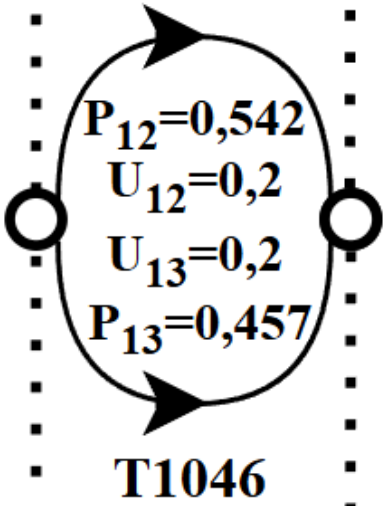


Рисунок 132 – Микромодель 6 шаблона атаки CAPEC-308

Таблица 97 - Вероятности эксплуатации уязвимостей и значения ущерба для микромодели 7 для CAPEC-308

Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб
CVE-2024-39600	0.454502191	0.5
CVE-2024-43432	0.545497809	0.2

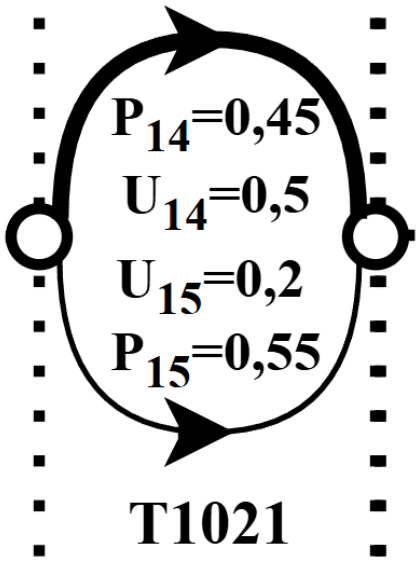


Рисунок 133 – Микромодель 7 шаблона атаки CAPEC-308

3.5.3 Расчёт рисков успешности реализации различных вариантов сформированных сценариев шаблона атак CAPEC-308

Теперь возможно приступить к формированию подсценариев для CAPEC-308. На рисунке 134 изображён первый подсценарий. Для него в таблице 98 приведены результаты расчётов рисков.

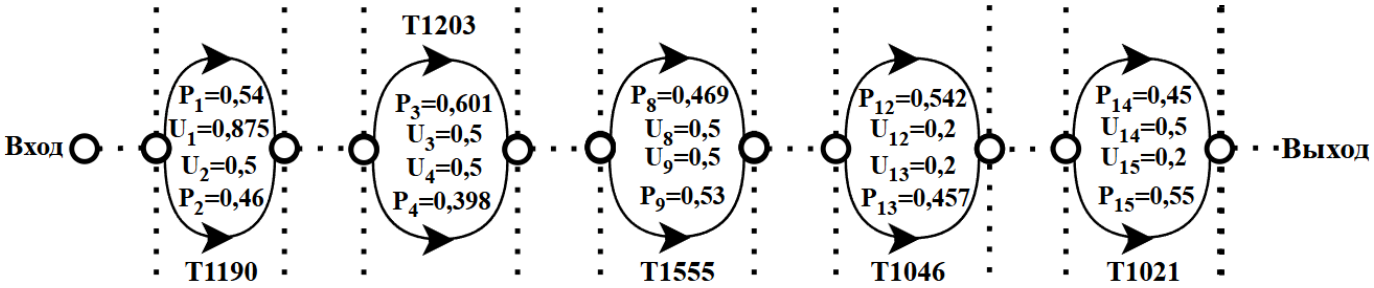


Рисунок 134 – Подсценарий 1 шаблона атаки CAPEC-308

Таблица 98 – Риски для подсценария 1 шаблона атаки CAPEC-308

Сценарий в формате «техника (уязвимость)»	Риск
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.09671213570203326
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.10255153634403734
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.0814466218060951
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.08636430304859069
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.10908122505545255
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	**0.11566746132244887**
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.09186331393413957
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.09740994663405586
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.06410248362007896
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.06797293980727778
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.05398423581836188
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.05724376037551851
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.07230093091852058
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.07666640273194292
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.06088860031891066
T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.0645650048281485
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.0707764519262142
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.0733629416337451
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.0596047525056408
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.0617829780973459
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.07982847266423751
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.08274576390015898
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.06722795826238444
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.06968477006025828

Продолжение таблицы 98

Сценарий в формате «техника (уязвимость)»	Риск
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.0469118618604973
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.04862623217097546
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	**0.03950706541052399**
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.04095083117269583
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.05291169845675967
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.0548453297669172
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04455985861591566
T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.04618827615511714

При анализе полученных результатов замечаем сценарий с максимальным риском. Это T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432), где Risk = 0.11566746132244887. Изобразим его на рисунке 135.

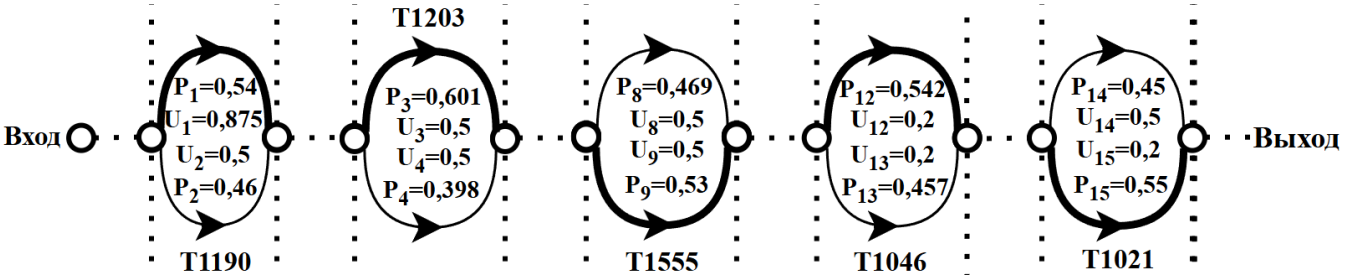


Рисунок 135 – Сценарий с максимальным риском подсценария 1 шаблона атаки CAPEC-308

Минимальным риском обладает сценарий, изображённый на рисунке 136. Это T1190 (CVE-2024-54134) -> T1203 (CVE-2023-50224) -> T1555 (CVE-2023-36009) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600), где Risk = 0.03950706541052399.

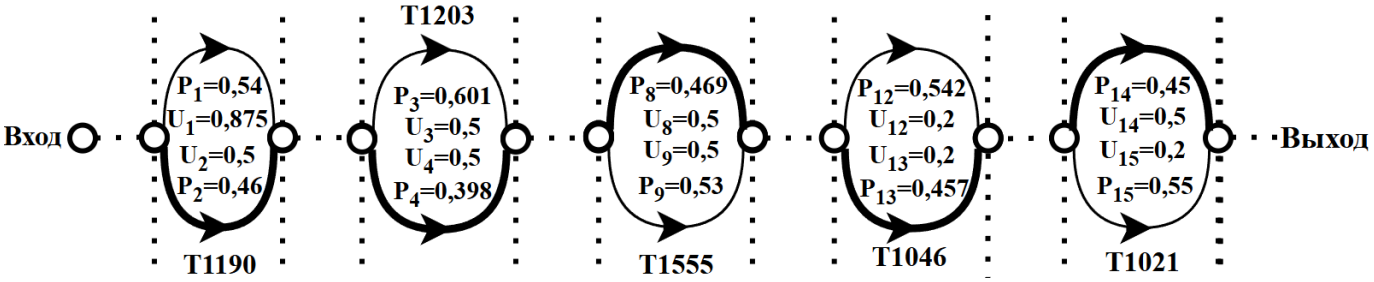


Рисунок 136 – Сценарий с минимальным риском подсценария 1 шаблона атаки CAPEC-308

Наибольшей вероятностью реализации имеет сценарий, проиллюстрированный на рисунке 137. P_1 = 0.538627967 × 0.601388954 × 0.530052207 × 0.542842446 × × 0.545497809 = 0.05084284014173576.

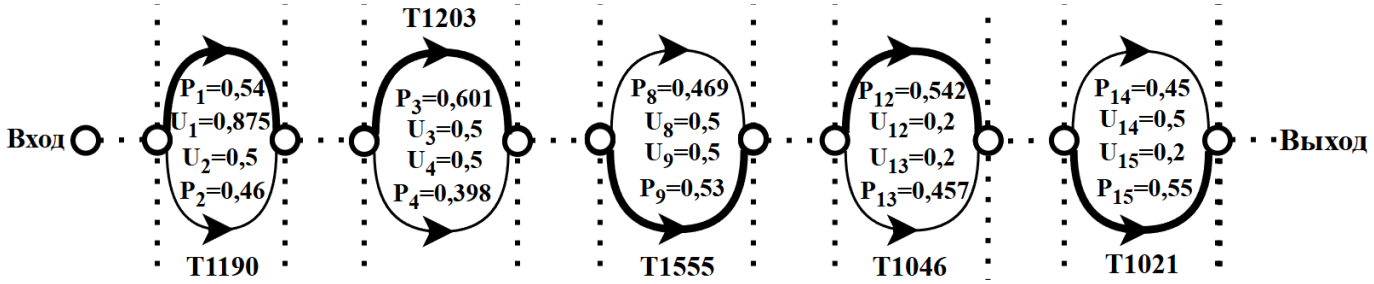


Рисунок 137 – Сценарий с наибольшим значением вероятности реализации для подсценария 1 шаблона атаки CAPEC-308

Приступим к анализу второго подсценария шаблона атаки CAPEC-308. На рисунке 138 изображён данный сценарий, а в таблице 99 приведены расчёты рисков для данного подсценария.

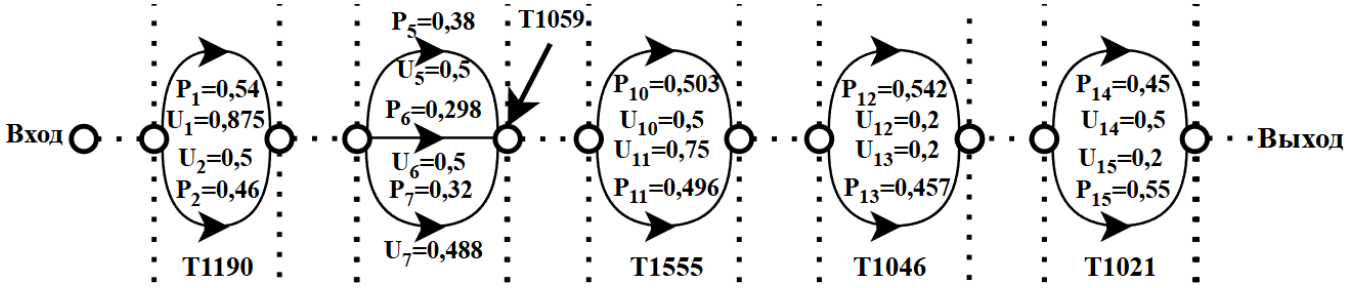


Рисунок 138 – Подсценарий 2 шаблона атаки CAPEC-308

Таблица 99 – Риски для подсценария 2 шаблона атаки CAPEC-308

Сценарий в формате «техника (уязвимость)»	Риск
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.06560527585347592
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.06956646942196403
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.05524982001623049
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.05858575952507751
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.07104358570134568
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	**0.0762122586493518**
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.059829720586397496
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.06418254505645828
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.0513217270781669
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.054420491508024346
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04322085605315828
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.045830496433372454
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.055576010748922815
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.05961936273461255
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04680362289697453
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.05020875253884296
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.05528533719462766
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.05862342120202006
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04655883067029214
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.04937001526190019
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.05986818193991676
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.0642238046099208
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.050418296910553904
T1190 (CVE-2024-55875) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.054086406913075695

Продолжение таблицы 99

Сценарий в формате «техника (уязвимость)»	Риск
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.048011644235170584
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.04976620553735856
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04043325278596358
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.04191086559822939
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.052775805573986034
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.05558585319762103
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.04444541572672638
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.046811911765697684
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.0375585723854695
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.0389311314536444
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	**0.03163014463956119**
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.03278605230844558
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.04128548283293295
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.043483728253605254
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.03476878141473229
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.03662004508619223
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.04045924517927734
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.04193780787043579
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.03407296113105482
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.03531814029548157
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-39600)	0.04447398732675764
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432)	0.04684200466049456
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600)	0.03745399685073175
T1190 (CVE-2024-54134) -> T1059 (CVE-2023-34064) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-43432)	0.039448234810747086

Максимальным риском обладает сценарий на рисунке 139. Это T1190 (CVE-2024-55875) -> T1059 (CVE-2023-42922) -> T1555 (CVE-2023-43804) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432), где Risk = 0.0762122586493518.

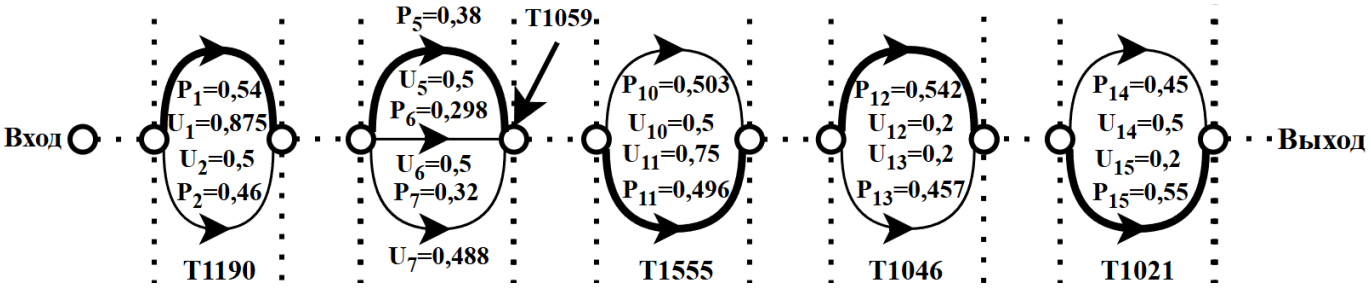


Рисунок 139 – Сценарий с максимальным значением риска подсценария 2 шаблона атаки CAPEC-308

Минимальный риск имеет сценарий T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600), где Risk = 0.03163014463956119. Нанесём его на подсценарий и визуализируем с помощью рисунка 140.

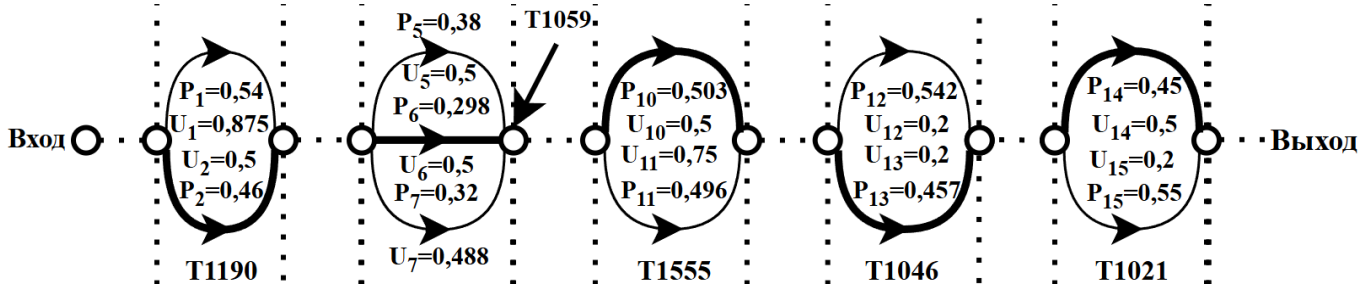


Рисунок 140 – Сценарий с минимальным риском подсценария 2 шаблона атаки CAPEC-308

Наибольшую вероятность реализации имеет сценарий, изображённый на рисунке 141. P_2 = 0.538627967 × 0.380955719 × 0.503255298 × 0.542842446 × × 0.545497809 = 0.03057866787778638.

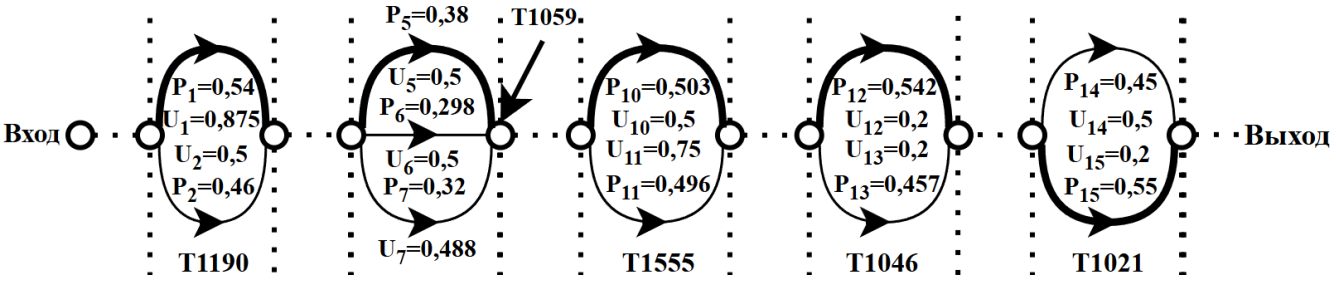


Рисунок 141 – Сценарий с наибольшим значением вероятности реализации для подсценария 2 шаблона атаки CAPEC-308

В результате анализа подсценариев шаблона атаки CAPEC-308 можно выделить определённые сценарии в контексте всего множества сценариев.

Сценарий с наибольшим риском изображён на рисунке 142 – подсценарий 1 - T1190 (CVE-2024-55875) -> T1203 (CVE-2023-50968) -> T1555 (CVE-2023-35636) -> T1046 (CVE-2023-21825) -> T1021 (CVE-2024-43432), где Risk = 0.11566746132244887.

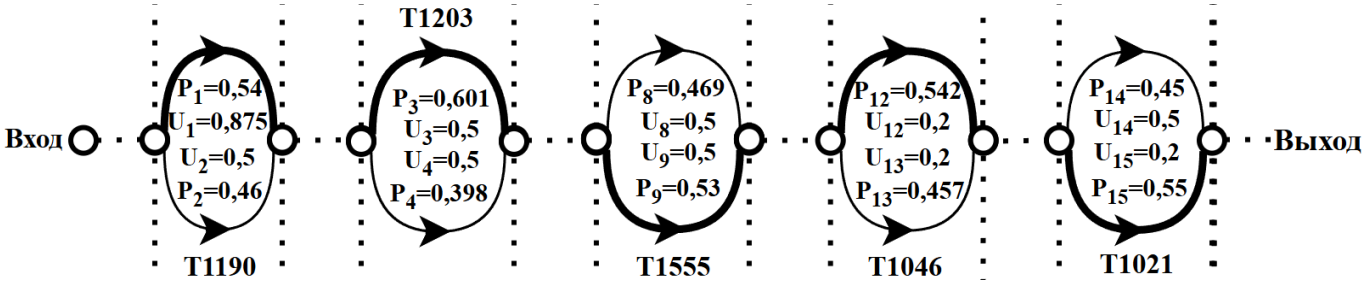


Рисунок 142 – Сценарий с наибольшим значением риска всего множества сценариев CAPEC-308

Сценарий с наименьшим риском изображён на рисунке 143 – подсценарий 2 - T1190 (CVE-2024-54134) -> T1059 (CVE-2023-47146) -> T1555 (CVE-2023-35643) -> T1046 (CVE-2024-53243) -> T1021 (CVE-2024-39600), где Risk = 0.03163014463956119.

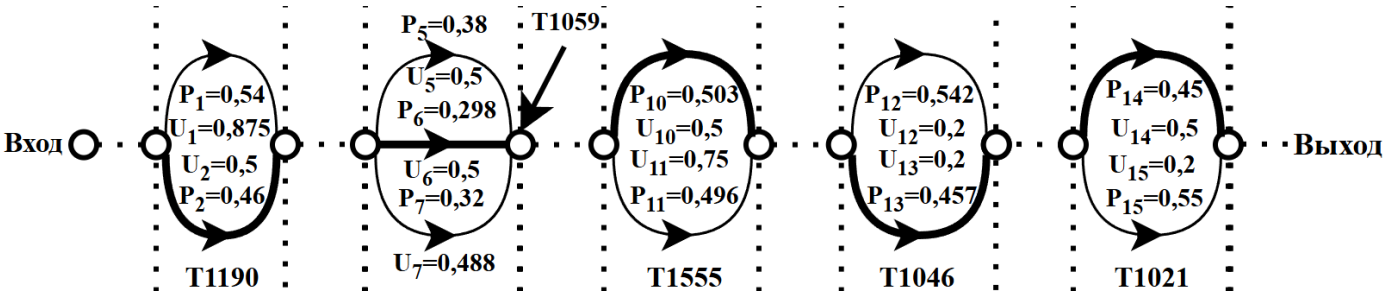


Рисунок 143 – Сценарий с наименьшим значением риска всего множества сценариев шаблона атаки CAPEC-308

Сценарий, имеющий наибольшее значение вероятности реализации, изображён на рисунке 144 – подсценарий 1 - P = 0.538627967 × 0.601388954 × 0.530052207 × × 0.542842446 × 0.545497809 = 0.05084284014173576.

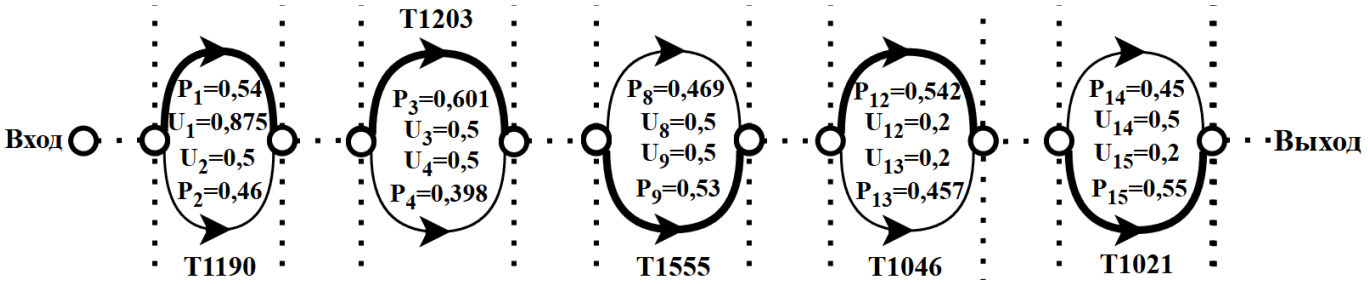


Рисунок 144 – Сценарий с наибольшей вероятностью реализации для всего множества сценариев шаблона атаки CAPEC-308

4 Разработка организационно-правовых регламентов для заданных шаблонов атак CAPEC

После проведения оценки рисков представляется возможным приступить к процессу разработки и формирования организационно-правовых регламентов, благодаря которым задача по повышению защищённости автоматизированных информационных систем становится выполнимой из-за систематизированности и стандартизированности знаний. В таблицах 100-104 представлены организационно-правовые регламенты для шаблонов атак CAPEC-300, CAPEC-305, CAPEC-306, CAPEC-307 и CAPEC-308.

Таблица 100 – Организационно-правовой регламент шаблона атаки CAPEC-300

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Сбор информации об атакуемой сети, в особенности о Jitsi Meet, macOS Sonoma, iPadOS, iOS, watchOS, tvOS или Safari путём активного сканирования или фишинга для получения информации о топологии сети или особенностях её функционирования, что говорит о применении техники T1590, эксплуатирующей уязвимости CVE-2024-33530 или CVE-2024-23280.	1) отследить IP-адрес, с которого производится атака, заблокировать трафик с него созданием соответствующих правил безопасности на межсетевом экране (NGFW, WAF); 2) использовать технику rate limiting для ограничения трафика в единицу времени для предотвращения дальнейшего сбора информации о сети сканированием; 3) для устройств с ОС семейства iOS применить контроль доступа на уровне сети с помощью Cisco ISE или NAC; 4) в случае сбора информации о сети посредством фишинга выявить и заблокировать подозрительные домены или URL с помощью средства фильтрации электронной почты Proofpoint или Mimecast.	1) изменить скомпрометированные в результате фишинга учётные данные; 2) настроить SIEM-системы для своевременного выявления попыток сканирования сети; 3) внедрить средства Endpoint Detection and Response (EDR) для выявления подозрительного трафика (Kandji или Jamf Protect); 4) обновить Jitsi Meet всех версий, в которых данные передаются с помощью HTTP POST запросов вместо веб-сокетов (версии 2.0.9364 и ниже), до версии 2.0.9457 для устранения уязвимости CVE-2024-33530; 5) для устранения уязвимости CVE-2024-23280 обновить продукты Apple до следующих версий: Safari 17.4, macOS Sonoma 14.4, iOS 17.4, iPadOS 17.4, wacthOS 10.4, tvOS 17.4.

Продолжение таблицы 100

1	2	3	4
Первоначальный доступ	Попытки получения доступа к системе путём внедрения вредоносного контента или манипуляции сетевым трафиком через скомпрометированные каналы передачи данных в Oracle WebLogic Server или OpenSSL API, что говорит о применении техники T1659, эксплуатирующей уязвимости CVE-2024-21183 или CVE-2024-5535.	1) ограничить доступ к Oracle WebLogic и OpenSSL только доверенным подсетям; 2) отключить или изолировать критически важные или уязвимые службы и процессы до устранения уязвимостей; 3) проверить активные соединения командой «netstat –anp | grep ESTABLISHED» для выявления подозрительной активности. Также для этого возможна проверка файлов логгирования событий access.log и diagnostic.log; 4) проверить сеть на предмет возможной эксплуатации вредоносных WAR/JSP-файлов; 5) выявить подозрительные или многократные SSL/TLS-соединения для отслеживания источника атаки.	1) в случае неиспользования транспортного протокола T3 для WebLogic отключить его для всех соединений; 2) отключить устаревшие версии протоколов SSL/TLS (SSLv3, TLS 1.0/1.1); 3) настроить средства SIEM на выявление аномальных запросов к WebLogic и SSL/TLS трафика в будущем; 4) для устранения уязвимости CVE-2024-5535 обновить Debian GNU/Linux 11 и 12 версии, РЕД ОС 7.3, АЛЬТ СП 10, OpenSSL (3.0-3.0.15, 3.1-3.1.7, 3.2-3.2.3, 1.0.2-1.0.2zk, 1.1.1-1.1.1za), Astra Linux Special Edition 1.8, ОСОН Основа Onyx до новых версий; 5) установить патч от Oracle с их официального сайта, содержащий 386 критически важных обновлений безопасности, для устранения уязвимости CVE-2024-21183.
	Попытки получения доступа к сети посредством использования служб удалённого доступа с возможностью внешнего подключения к Oracle Process Manufacturing Financials или RUGGEDCOM (например VPN, Citrix, служба удалённого доступа Windows или VNC), что говорит о применении техники T1133, эксплуатирующей уязвимости CVE-2024-21152 или CVE-2023-52237.	1) проверить активные удалённые подключения с помощью команд «netstat –ano | findstr ESTABLISHED» (на Windows) или «ss -tulnp» (на Linux) для выявления источников атаки и дальнейшей их блокировки; 2) с помощью средств регистрации системных событий выявить наличие множественных неудачных попыток авторизации для установления и изоляции скомпрометированных учётных записей; 3) отследить подозрительные IP-адреса, с которых может производиться атака и заблокировать трафик с них созданием соответствующих правил безопасности; 4) отключить возможность удалённых подключений до устранения последствий инцидента безопасности для предотвращения увеличения масштабов атаки.	1) для удалённых подключений включить механизм multi-factor authentication; 2) использовать принцип наименьших привилегий для учётных записей для ограничения возможностей злоумышленников после получения доступа к сети; 3) настроить IPS/IDS или SIEM на выявления аномальной активности при авторизации (например, брутфорс (перебор) учётных данных); 4) включить TLS-шифрование для всех соединений, если до этого TLS не использовался; 5) внедрить 386 обновлений безопасности от Oracle установкой официального патча разработчика для устранения уязвимости CVE-2024-21152; 6) установить новые версии Siemens для RUGGEDCOM или использовать их официальные рекомендации по использованию мер в тех продуктах Siemens, где опция обновления недоступна.

Продолжение таблицы 100

1	2	3	4
Закрепление	Попытки несанкционированной модификации бинарных файлов системы, позволяющих пользоваться большим спектром команд, служб, программ и т. п., для внедрения вредоносного контента (бэкдоры, вредоносные программные коды и т. п.) в Hitachi EH-VIEW, Keycloak, операционных системах семейства iOS или Apache Commons VFS, что говорит о применении техники T1554, эксплуатирующей уязвимости CVE-2024-39986, CVE-2024-4540, CVE-2024-54560 или CVE-2025-30474.	1) изолировать уязвимые сервисы от сети; 2) провести проверку целостности бинарных файлов (mdm5sum или shasum) для выявления скомпрометированных и модифицированных файлов; 3) восстановить целостность изменённых бинарных файлов для предотвращения эксплуатации внедрённого злоумышленниками в них вредоносного кода; 4) проверить службы и процессы для выявления бэкдоров и уязвимых мест; 5) проанализировать логи аутентификации Keycloak и Apache.	1) использовать Mobile Device Management для проверки устанавливаемых приложений для предотвращения внедрения модифицированных вредоносных бинарных файлов (для iOS); 2) перевести iOS-устройства в режим восстановления; 3) ограничить доступ доступ к бинарным файлам с помощью SELinux или AppArmor; 4) для Apache Commons VFS отключить неиспользуемые процессы VFS; 5) настроить SIEM-системы или другие средства контроля целостности на детектирование нарушения целостности бинарных файлов; 6) обновить Red Hat Single Sign On (версии 7, 7.6 for RHEL 7, 7.6 for RHEL 8, 7.6 for RHEL 9), Red Hat Enterprise Linux 8 based Middleware Containers, Red Hat Build of Keycloak (версии 22 и 24) до новейших версий для устранения уязвимости CVE-2024-4540; 7) обновить macOS Sequoia 15.0 версии и ниже, iOS 18 версии и ниже, iPadOS 18 версии и ниже, tvOS 18 версии и ниже, watchOS 11 версии и ниже до более актуальных версий для устранения уязвимости CVE-2024-54560; 8) обновить Apache Commons VFS ниже версии 2.10.0 до версии 2.10.0, где была устранена уязвимость CVE-2025-30474; 9) дезинтегрировать из систем и не использовать Hitachi EH-VIEW из-за его неактуальности и остановки технической поддержки разработчиком.

Продолжение таблицы 100

1	2	3	4
Повышение привилегий	Обход защитных механизмов, контролирующих процессы или цифровые подписи эксплуатацией вредоносного кода в сертифицированных или доверенных бинарных файлах ПО Zoom Workplace Apps, ядра Linux или Windows File Explorer, что говорит о применении техники T1218, эксплуатирующей уязвимости CVE-2024-39822, CVE-2024-41066 или CVE-2025-24071.	1) проверить целостность бинарных файлов через sigcheck (для Windows или команды «rpm –V» (для Linux) или другими средствами контроля целостности для выявления изменённых файлов; 2) восстановить резервными копиями модифицированные файлы и изолировать к ним доступ с помощью механизмов разграничения доступа (дискреционный или мандатный); 3) проверить целостность файлов реестра Windows на предмет наличия вредоносных записей, позволяющих обойти механизмы защиты и восстановить их в случае компрометации. Для Linux: проверить LD_PRELOAD и cron-задачи для той же цели; 4) использовать rkhunter или Lynis для выявления маскирующего вредоносные процессы и программы ПО.	1) включить Microsoft Defender Application Control (WDAC) для блокирования выполнения неподписанных файлов; 2) отключить автозапуск библиотек с расширением dll; 3) для Zoom Workplace Apps включить Endpoint Protection; 4) использовать Secure Boot и dm-verify для контроля целостности ядра Linux; 5) обновить Red Hat Enterprise Linux 8/9/9.2 Extended Update Support/9.4 Extended Update Support, Debian GNU/Linux 11/12, Linux (от 6.2 до 6.6.41 включительно, от 6.7 до 6.9.10 включительно, от 4.5 до 6.1.100 включительно) и Astra Linux Special Edition 1.8 до более актуальных версий для устранения уязвимости CVE-2024-41066; 6) установить патчи для Windows 10 или 11, Windows Server 2012, 2016, 2019, 2022 или 2025 для устранения уязвимости CVE-2025-24071; 7) обновить Zoom Rooms Controller for Android/Linux/macOS/Windows версий 6.1.0 и ниже, Zoom Rooms Client for iPad/macOS/Windows версий 6.1.0 и ниже, Zoom Workplace Desktop App for Linux/Android/iOS версий 6.0.12 и ниже, Zoom Meeting SDK for Android/iOS версий 6.0.12 и ниже до новейших версий для устранения CVE-2024-39822.

Продолжение таблицы 100

1	2	3	4
Повышение привилегий	Манипуляции (действия, направленные на нарушение политик безопасности – итеративное обновление паролей или продление срока действия известных злоумышленнику учётных данных) с скомпрометированными учётными записями для расширения доступа к атакуемой системе, продуктам Dahua или HTTP-клиентам, что говорит о применении техники T1098, эксплуатирующей уязвимости CVE-2024-13131 или CVE-2024-45336.	1) провести инвентаризацию всех устройств Dahua в сети для выявления всех возможных точек проведения атаки; 2) заблокировать доступ к интерфейсам устройств Dahua (например с помощью команды «iptables -A INPUT -s <IP-адрес устройства> -j DROP»); 3) с помощью журналов регистрации системных событий отследить аномальные попытки аутентификация для идентификации скомпрометированных учётных записей и заблокировать их; 4) остановить все активные сессии через RADIUS или Active Directory; 5) ограничить доступ к файлу /web_caps/webCapsConfig, содержащий сведения о веб-интерфейсах или ПО для видеонаблюдения.	1) изменить учётные данные всех скомпрометированных учётных записей, использовавшихся для совершения атаки; 2) проверить контрольные суммы и восстановить целостность (в случае её нарушения) ПО, эксплуатируемого устройствами Dahua; 3) создать правила безопасности для фильтрации трафика к устройствам Dahua (пример команды, создающей правило – «iptables -A INPUT -p tcp --dport 80 -s <IP-адрес устройства> -j ACCEPT»; 4) задать более строгие параметры валидности учётных записей SIEM-системам или другим средствам управления учётными записями для снижения риска компрометации учётных данных; 5) внедрить Endpoint Detection and Response или IPS/IDS (Snort) для защиты от вторжений; 6) обновить прошивки Dahua IPC-HDW1200S 20241222, Dahua IPC-HFW1200S 20241222, Dahua IPC-HFW2300R-Z 20241222, Dahua IPC-HFW5220E-Z 20241222 для устранения уязвимости CVE-2024-13131; 7) обновить openSUSE Tumbleweed, Debian GNU/Linux 11 и 12 версий, РЕД ОС 7.3, SUSE Linux Enterprise Server for SAP Applications 15SP3/15SP4/15 SP6, SUSE Enterprise Storage 7.1, Suse Linux Enterprise Server 15SP3-LTSS/15 SP4-LTSS/15 SP6/15 SP5-LTSS, SUSE Linux Enterprise High Performance Computing 15 SP3-LTSS/15 SP4-ESPOS/15 SP4-LTSS/15 SP6/15 SP5-LTSS/15 SP5-ESPOS, SUSE Linux Enterprise Module for Package Hub 15 SP6, OpenSUSE Leap 15.6, SUSE Linux Enterprise Module for Development Tools 15 SP6, Cryostat 3, GO 1.23.5 и ниже для устранения уязвимости CVE-2024-45336.

Продолжение таблицы 100

1	2	3	4
Получение учётных данных	Кража или подделка сертификатов, используемых для аутентификации в атакуемой системе, для получения доступа к удалённым системам или ресурсам umatiGateway или Jira Core Data Center, что говорит о применении техники T1649, эксплуатирующей уязвимости CVE-2025-27615 или CVE-2024-21685.	1) удалить все подозрительные сертификаты для umatiGateway; 2) отключить подозрительные сертификаты в настройках SSL для Jira; 3) блокировать входящий трафик в межсетевом экране командой вида «iptables -A INPUT -p tcp --dport <port> -j DROP»; 4) провести процедуру проверки целостности всех сертификатов и восстановить сертификаты с нарушенной целостностью; 5) ограничить доступ к /ssl-certificates в настройках web.xml.	1) сгенерировать новые сертификаты для umatiGetaway с помощью команды «openssl req -x509 -newkey rsa:4096 -keyout umati_new.key -out umati_new.crt -days 365 -nodes»; 2) использовать криптографический стандарт pkcs#12 для усиления защиты сертификатов; 3) отключить старые протоколы аутентификации (например, NTLM) и не нужные функции сертификатов; 4) в дальнейшем проводить регулярный аудит систем на наличие ненужных сертификатов аутентификации. Доступные шаблоны сертификатов можно проверить с помощью оснастки Certificate Authority MMC (certsrv.msc); 5) обновить umatiGetaway согласно рекомендациям разработчика на Github для устранения уязвимости CVE-2025-27615; 6) обновить Jira Data Center и Jira Server до актуальных версий для устранения уязвимости CVE-2024-21685.

Продолжение таблицы 100

1	2	3	4
Получение учётных данных	Подделка учётных данных веб-приложений или интернет-служб для получения несанкционированного доступа к Gradio, или Windows Hello, что говорит о применении техники T1606, эксплуатирующей уязвимости CVE-2024-34510, CVE-2024-53991 или CVE-2025-47969.	1) закрыть доступ к атакуемому сетевому интерфейсу командой «iptables -A INPUT -p tcp --dport <порт Gradio> -j DROP»; 2) сбросить биометрические данные через GPO для Windows Hello командой «Get-WindowsHelloContainer -All | Reset-WindowsHelloContainer»; 3) временно запретить аутентификацию по биометрии командой «Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Biometrics" -Name "Enabled" -Value 0»; 4) провести проверку целостности файлов реестра Windows командой «reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v "LastLoggedOnUser"»; 5) провести поиск инъекций командой «grep -r "{% raw %}" /path/to/gradio/templates/»; 6) проверить dll-библиотеки на наличие поддельных командой «Get-ChildItem -Path "$env:WINDIR\System32" -Recurse -Include *.dll \| Get-AuthenticodeSignature \| Where-Object {$_.Status -ne "Valid"}».	1) настроить браузеры/приложения на периодическое удаление постоянных аутентификационных данных (например, файлы cookie); 2) ограничить доступ к серверам AD FS только для привилегированных пользователей; 3) уменьшить количество привилегированных пользователей и запретить пользователям обращаться к API sts:GetFederationToken без необходимости; 4) для Gradio включить Oauth 2.0 и добавить Capctha для усиления аутентификации; 5) для Windows Hello включить защиту TPM 2.0 командой «Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\TPM" -Name "RequireTPM" -Value 1» и включить аутентификацию и по биометрии, и по PIN-коду командой «Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\PassportForWork" -Name "RequireSecurityDevice" -Value 1»; 6) обновить Windows 11 22H2/11 23H2/11 24H2, Windows Server 2025 и Windows 2025 Server Core Installation патчами безопасности от разработчика для устранения уязвимости CVE-2025-47969; 7) обновить Discourse версий 3.3.3 и ниже или 3.4.0.beta4 и ниже для устранения уязвимости CVE-2024-53991; 8) обновить Gradio уязвимых версий 4.20 и ниже до более актуальных для устранения уязвимости CVE-2024-34510.

Таблица 101 – Организационно-правовой регламент шаблона атаки CAPEC-305

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный доступ	Использование служб удалённого доступа для подключения к внутренним ресурсам атакуемой системы и Moodle (например, использование открытой службы, не требующей аутентификации), что говорит о применении техники T1133, эксплуатирующей уязвимости CVE-2025-47966 или CVE-2025-32044.	1) блокировать неавторизованные подключения в межсетевом экране с помощью команды «iptables -A INPUT -p tcp --dport 80 -j DROP»; 2) для Moodle отключить возможность удалённого доступа командой «php admin/cli/maintenance.php --disable»; 3) проверить целостность Moodle командой «git -C /var/www/moodle status»; 4) проанализировать активные процессы командой «ps aux | grep -E 'ssh|vnc|rdp'» и проверить целостность файлов командой «find /var/www/moodle -mtime -1 -type f -ls» для установления целей атаки.	1) внедрить сетевые прокси-серверы, шлюзы и межсетевые экраны для запрета прямого удалённого доступа к внутренним системам; 2) применить механизм двухфакторной аутентификации для затруднения использования злоумышленниками скомпрометированных учётных данных; 3) отключить ненужные службы, через которые удалённо возможно получить доступ к сети; 4) обновить Microsoft Power Automate for Desktop официальным патчем от разработчика для устранения CVE-2025-47966; 5) обновить РЕД ОС 7.3 и Moodle версий от 4.5.0 до 4.5.3 до актуальных версий для устранения уязвимости CVE-2025-32044.
Выполнение	Использование бессерверных вычислений и служб автоматизации для выполнения вредоносного кода в Xcode или ServiceList.java для их компрометации и дальнейшего несанкционированного использования ресурсов, что говорит о применении техники T1648, эксплуатирующей уязвимости CVE-2025-24226 или CVE-2024-49723.	1) приостановить все процессы для Xcode Cloud командой «xcrun xcodebuild cloud -suspendAll» и удалить API-токены CI/CD командой «rm ~/Library/Developer/Xcode/CloudTokens/*»; 2) для Java остановить уязвимые процессы командой «systemctl stop spring-boot-app» и заблокировать входящий трафик командой «iptables -A INPUT -p tcp --dport 8080 -j DROP»; 3) проверить подозрительные скрипты для Xcode командой «find ~/Library/Developer/Xcode -name "*.sh" -mtime -1»; 4) для Java провести аудит классов командой «javap -c ServiceList.class | grep "invokedynamic"».	1) включить Mandatory Code Review для Xcode изменением значения false на true для проверки кода программы несколькими разработчиками перед его включением в основной проект; 2) внедрить средства отслеживания аномальной активности AWS Lambda или Google Cloud Functions; 3) запретить создание, изменение и запуск бессерверных ресурсов у пользователей, не имеющих необходимости в этом; 4) обновить Xcode Cloud версий 16.3 и ниже до более актуальной версии для устранения уязвимости CVE-2025-24226; 5) установить последнее обновление ОС Android для устранения CVE-2024-49723.

Продолжение таблицы 101

1	2	3	4
Выполнение	Использование легитимного пользователя атакуемой системы для выполнения вредоносных операций с использованием методов социальной инженерии в Canonical apport или API Background Fetch в Google Chrome, что говорит о применении техники T1204, эксплуатирующей уязвимости CVE-2025-5064 или CVE-2025-5054.	1) отследить трафик на выявление подозрительной активности для установления источника атаки и заблокировать учётную запись, с которой такая активности исходит; 2) изолировать уязвимые системы командой «sudo iptables -A OUTPUT -p tcp -m owner --uid-owner apport -j DROP»; 3) проверить файлы Ubuntu на наличие модифицированных командой «sudo debsums -c | grep -v "OK"»; 4) проверить дамп памяти процесса Google Chrome командой «pgrep chrome | xargs -I {} gcore -o /tmp/chrome_dump {}» для установления факта нарушения целостности.	1) разработать обучающую программу о техниках фишинга для распознания вредоносных событий для пользователей; 2) заблокировать с помощью политик безопасности неиспользуемые и с неизвестными расширениями файлы, устанавливаемыми при переходе пользователем по вредоносной ссылке; 3) использовать IPS/IDS системы для отслеживания подозрительной активности при переходах по ссылкам; 4) включить правила Attack Surface Reduction в Windows для предотвращения выполнения потенциально вредоносных исполняемых файлов, не соответствующих критериям распространённости, возраста или списка доверенных файлов; 5) обновить Google Chrome версий 137.0.7151.55 и ниже до актуальной для устранения CVE-2025-5064; 6) обновить Ubuntu 16.04 LTS/18,04 LTS/20.04 LTS/22.04 LTS/24.10/25.04 и Apport версий 2.32.0 и ниже до новейших версий для устранения уязвимости CVE-2025-5054 согласно рекомендациям разработчика.

Продолжение таблцы 101

1	2	3	4
Предотвращение обнаружений	Маскировка злоумышленником своих вредоносных задач и служб заданием имён, идентичные именам легитимных задач и служб в reNgine или macOS Sequoia, что говорит о применении техники T1036.004, эксплуатирующей уязвимости CVE-2024-45245, CVE-2025-24899, CVE-2025-24204 или CVE-2024-8884.	1) провести поиск подозрительных процессов и остановить reNgine командами «ps aux | grep -E 'rengine|scan|engine' | grep -vE 'python|nginx'» и «sudo systemctl stop rengine» соответственно; 2) для macOS провести поиск поддельных launchd демонов и агентов и блокировать их выполнение командами вида «sudo launchctl list | grep -E '(System|User)' | awk '{print $3}' | xargs -I {} sh -c 'echo {}; codesign -dv {}'» и «sudo spctl --master-enable» соответственно; 3) проверить целостность хешей reNgine и подписей macOS командами «find /opt/rengine -type f -exec sha256sum {} \; | grep -v -f known_hashes.txt» и «codesign --verify --verbose /path/to/suspicious_binary» соответственно; 4) проанализировать логи macOS командой «sudo sysdiagnose -f /tmp/» и для Linux командой «sudo gcore -o /tmp/rengine_dump <PID>» для выявления подозрительной активности.	1) внедрить механизмы отслеживания нетипичных изменений в именах, описаниях и типах запускаемых служб; 2) использовать средства выявления изменений в запланированных заданиях, касающихся их запуска; 3) обновить приложение для системного мониторинга System Monitor до последней версии для устранения уязвимости CVE-2024-8884; 4) обновить macOS Sequoia версий 15.4 и ниже патчем безопасности от Apple для устранения уязвимости CVE-2025-24204; 5) обновить платформу для управления и мониторинга терминалами Vynamic View версий 5.9.5 и ниже до более актуальных версий для устранения CVE-2024-45245; 6) обновить средство для исследования веб-приложений reNgine версий 2.2.0 и ниже согласно рекомендациям разработчика на Github для устранения уязвимости CVE-2025-24899.

Продолжение таблицы 101

1	2	3	4
Предотвращение обнаружений	Использование функционала командной строки Windows или манипуляции ключами реестра Windows для ограничения/полного отключения журналирования событий Windows в TOTOLINK EX200, Brocade SANnav server или Outlook для сокрытия вредоносных действий, что говорит о применении техники T1562.006, эксплуатирующей уязвимости CVE-2024-31817, CVE-2024-29960, CVE-2025-3035 или CVE-2025-29805.	1) изолировать уязвимые устройства от сети разделением виртуальными подсетями VLAN или созданием правил ACL; 2) проанализировать системные логи для установления учётных записей с исходящей подозрительной активностью для выявления источника атаки. Заблокировать подозрительные учётные записи для остановки такой активности; 3) проверить реестр на нарушения целостности вручную или через GPO; 4) включить аудит командой «auditpol /set /category:* /success:enable /failure:enable».	1) защитить перенаправляющие устройства событий, политики межсетевого экрана и другие механизмы соответствующими разрешения и средствами контроля доступа; 2) внедрить автоматический периодический перезапуск механизмов переадресации, а также соответствующее управление изменениями в правилах межсетевого экрана; 3) защитить процессы отслеживания и пересылки событий, политики межсетевого экрана и другие механизмы от изменений с учётных записей уровня «пользователь» редактированием политик безопасности; 4) настроить переадресацию логов с помощью SIEM-систем (Splunk, ELK, Graylog); 5) включить Windows Defender Attack Surface Reduction для защиты от изменений файлов реестра; 6) обновить Microsoft Outlook версий 4.2509.0 и ниже установкой патчей разработчика для устранения уязвимости CVE-2025-29805; 7) обновить Firefox версий 137 и ниже и SUSE/OpenSUSE до актуальных версий для устранения уязвимости CVE-2025-3035; 8) обновить ПО для управления сетью Brocade SANnav версий 2.3.1 и ниже и 2.3.0a и ниже до новейших для устранения CVE-2024-29960; 9) обновить прошивку роутера TOTOLINK EX200 версии 4.0.3c.7646_B20201211 для устранения уязвимости CVE-2024-31817.

Продолжение таблицы 101

1	2	3	4
Перемещение внутри периметра	Эксплуатация уязвимостей в удалённых службах для получения несанкционированного доступа к RKE, Adobe Framemaker Publishing Server, ядру Linux или iOS, что говорит о применении техники T1210, эксплуатирующей уязвимости CVE-2023-32191, CVE-2024-30300, CVE-2024-42256 или CVE-2025-31225.	1) для RKE проверить поды и деплойменты (объекты Kubernets) и отключить скомпрометированные объекты командами «kubectl get pods --all-namespaces -o wide | grep -v "Running"» и «kubectl cordon <node-name>, kubectl drain <node-name> --delete-emptydir-data --force» соответственно; 2) остановить службу Adobe FrameMaker Publishing Server командой systemctl stop framemaker-publishing, проверить целостность файлов по пути /opt/adobe/fmserver/; 3) обновить ядро Linux командой «apt upgrade linux-image»; 4) перевести устройства на ОС iOS в режим DFU и восстановить их прошивку; 5) провести глубокую проверку пакетов для поиска аномального трафика эксплойтов и известных полезных нагрузок.	1) внедрить средства сканирования процессов, сервисов и приложений для выявления уязвимостей (например, ScanOVAL); 2) ограничить разрешения и доступ для учётных записей для уменьшения последствий последующих атак данного типа; 3) внедрить средства безопасности (например, Exploit Guard или Enhanced Mitigation Experience Toolkit), защищающие от различных видов вредоносной активности, связанной с эксплуатацией уязвимостей; 4) сегментировать сеть для ограничения доступа к критическим системам и сервисам; 5) обновить ПО управления кластерами Kubernets Rancher версий 2.8.5 и ниже, 1.4.19 и ниже, 1.5.10 и ниже, 2.7.14 и ниже до актуальных для устранения уязвимости CVE-2023-32191; 6) обновить сервер автоматизации процесса публикации и управления содержимым документов Adobe FrameMaker Publishing Server версий 2022.2 и ниже, 2020 Update 3 и ниже для устранения уязвимости CVE-2024-30300; 7) обновить ядро Linux версии 6.10 до более новой для устранения уязвимости CVE-2024-42256; 8) обновить iPadOS версий 18.5 и ниже и iOS версий 18.5 и ниже до более новых для устранения уязвимости модуля Call History CVE-2025-31225.

Продолжение таблицы 101

1	2	3	4
Сбор данных	Использование автоматизированных техник сбора данных для компрометации данных об Ivanti EPM 2022 SU5 или VMware Aria Operations for Logs, что говорит о применении техники T1119, эксплуатирующей уязвимости CVE-2025-22218 или CVE-2025-29846.	1) установить с помощью средств обнаружения вторжений IP-адреса атакующих и заблокировать исходящий с них трафик созданием правил безопасности; 2) для Ivanti EPM 2022 SU5 проверить запущенные процессы и остановить их командой «Stop-Service -Name "IvantiEPM*" -Force»; 3) остановить процессы, связанные с VMware Aria командой «systemctl stop vmware-aria-log-service»; 4) проверить логи Ivanti командой «Get-Content -Path "C:\ProgramData\Ivanti\EPM\logs*.log" | Select-String -Pattern "scan|collect|exploit"» и искать в них подозрительные SQL-запросы; 5) проверить логи VMware Aria командой «grep -r "automat*|exploit" /var/log/vmware/aria/» и, если произошла утечка конфиденциальных данных, проанализировать индексы Elasticsearch.	1) для Ivanti удалить временные файлы и восстановить целостность файлов реестра для очистки системы; 2) для VMware Aria пересоздать Elasticsearch индексы; 3) ограничить API-доступ через API Gataway для Ivanti; 4) автоматизировать процесс обновления ПО с помощью WSUS или Ansible; 5) обновить VMware Cloud Foundation версий KB92148 и ниже и VMware Aria Operations for Logs версий 8.18.3 и ниже для устранения уязвимости CVE-2025-22218; 6) обновить ОС Synology Router Manager версий 1.3.1-9346-13 и ниже для устранения уязвимости CVE-2025-29846.

Таблица 102 – Организационно-правовой регламент шаблона атаки CAPEC-306

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Подготовка ресурсов	Компрометация злоумышленником легитимных учётных данных доступа к веб-сервисам для компрометации Fortinet FortiSIEM или Brocade SANnav, что говорит о применении техники T1584.006, эксплуатирующей уязвимости CVE-2023-40723 или CVE-2024-29958.	1) отследить с помощью системных логов скомпрометированные учётные записи и заблокировать их в Active Directory или LDAP; 2) остановить сессии JWT и OAuth-токенов с помощью команды «fs-cli -c "kill-session <session-id>"» для FortiSIEM и «sancli --revoke-token <compromised-token>» для Brocade SANnav; 3) ограничить доступ к уязвимому ПО только для доверенных IP-адресов созданием правил безопасности в межсетевом экране; 4) проверить целостность конфигурации командами «fsm-diff-config --last 7d» для FortiSIEM и «sancli --audit-config-changes» для Brocade SANnav и искать в них попытки экспорта данных.	1) удалить скомпрометированные учётные записи; 2) ограничить права для FortiSIEM по принципу наименьших привилегий; 3) для разграничения доступа к Brocade SANnav использовать механизм ролевых политик; 4) включить автоматическую периодическую смену паролей (например, через CyberArk); 5) настроить SIEM-системы на выявление множественных неудачных попыток аутентификации; 6) обновить FortiSIEM версий от 6.6.0 до 6.6.3, от 6.5.0 до 6.5.1, от 6.4.0 до 6.4.2, от 6.7.0 до 6.7.4, 6.1-6.3, 5.1-5.4 до более новых для устранения уязвимости CVE-2023-40723; 7) обновить ПО для управления сетью Brocade SANnav версий 2.3.1 и ниже, 2.3.0a и ниже до актуальных для устранения уязвимости CVE-2024-29958.

Продолжение таблицы 102

1	2	3	4
Подготовка ресурсов	Компрометация учётных записей посредством фишинга, покупки на сторонних сайтах или у легитимного пользователя атакуемой системы, подбора для дальнейшего фишинга или сбора сведений в Brocade SANnav OVA или OpenStack Murano, что говорит о применении техники T1586, эксплуатирующей уязвимости CVE-2024-29966 или CVE-2024-29156.	1) отключить скомпрометированные учётные записи командами «sancli --disable-user <username>» и «openstack user set <username> --disable»; 2) ограничить доступ по SSH, RDP или к веб-интерфейсу созданием ACL только для доверенных IP-адресов или через VPN/ZTNA, если настроен удалённый доступ; 3) проверить файл SSH authorized_keys на целостность и восстановить его из бэкапов для предотвращения дальнейших попыток аутентификации по учётным данным, добавленными злоумышленниками.	1) удалить скомпрометированные учётные записи командой «userdel <имя_пользователя>»; 2) для OpenStack настроить RBAC (ролевые политики) командой «openstack role remove <user> admin»; 3) внедрить PAM-решения (например, CyberArk, HashiCorp Vault) для управления привилегированным доступом; 4) разработать программу обучения сотрудников выявления фишинга для уменьшения рисков компрометации учётных данных с помощью переходов по фишинговым ссылкам; 5) обновить Brocade SANnav 2.3.1 и ниже и Brocade SANnav 2.3.0a и ниже до более актуальных для устранения уязвимости CVE-2024-29966; 6) обновить Murano 16.0.0 и ниже до новых для устранения уязвимости компонента YAQL интерфейса для управления конфигурацией сервисов в облачной платформе OpenStack Murano CVE-2024-29156.

Продолжение таблицы 102

1	2	3	4
Закрепление	Компрометация бинарных файлов Check Point Security Gateways, HGiga PowerStation, macOS с Docker или Microsoft Outlook для внедрения в них вредоносного контента и его использования в незаконных целях, что говорит о применении техники T1554, эксплуатирующей уязвимости CVE-2024-24919, CVE-2023-24838, CVE-2023-1174 или CVE-2023-23397.	1) выявить вредоносные процессы с помощью файлов записи системных логов и остановить их; 2) проверить целостность бинарных файлов и восстановить, если целостность нарушена; 3) проверить DNS-запросы командой «tshark -r c2_traffic.pcap -Y "dns && dns.flags.response == 0"»; 4) произвести поиск вредоносного ПО, способного сохранять функциональность после перезагрузки устройства (персистентность) командами «crontab -l | grep -v "#"», «cpconfig -l | grep "Startup Scripts"» для Check Point Security Gateways, « launchctl list | grep -i "docker"» для macOS, « Get-ScheduledTask | Where-Object { $_.TaskName -like "*Outlook*" }» для Outlook; 5) выявить недавно созданные файлы и процессы, с помощью которых злоумышленники могут осуществлять изменения в бинарных файлах.	1) усилить контроль за правильностью подписей приложений разработчиками; 2) внедрить механизмы периодического контроля целостности бинарных файлов; 3) использовать Software Bill of Materials для анализа зависимостей; 4) обновить Powerstation версий x64.6.2.165 и ниже для устранения уязвимости CVE-2023-24838; 5) обновить minikube 1.26.0, 1.26.1, 1.27.0, 1.28.0 для устранения уязвимости инструмента настройки среды Kubernetes для разработки и тестирования приложений CVE-2023-1174; 6) обновить Microsoft Outlook до самой актуальной версии установкой патчей с официального сайта Microsoft для устранения уязвимости CVE-2023-23397; 7) обновить Check Point Quantum Gateway версий R81.20, R82.10, R81, R80.40, CloudGuard Network версий R81.20, R81.10, R81, Check Point Spark версий R80.10, R80.20 для устранения уязвимости данных межсетевых экранов и комплексной системы безопасности CVE-2024-24919.

Продолжение таблицы 102

1	2	3	4
Получение учётных данных	Перехват вводимых легитимным пользователем данных (например, через API или введением его в заблуждение методами социальной инженерии) для получения доступа в Yealink Meeting Server или Grafana, что говорит о применении техники T1056, эксплуатирующей уязвимости CVE-2024-48352 или CVE-2023-1387.	1) проверить целостность файлов реестра Windows, в случае обнаружения нарушения целостности восстановить исходные файлы из бэкапов и закрыть к ним доступ; 2) заблокировать скомпрометированные учётные записи для Yealink командой «yms-cli user revoke <имя_пользователя>» и «grafana-cli admin reset-password <id_пользователя>» для Grafana; 3) установить активные сессии командами «yms-cli session list | grep -v "IP-адрес сети."» для Yealink и SQL-запросом «SELECT * FROM auth_session WHERE last_seen > NOW() - INTERVAL '1 hour';» для Grafana; 4) отключить подозрительные API-ключи командой «grafana-cli api-keys delete <id>» для Grafana; 5) отслеживать вызовы функций API SetWindowsHookEx и SetWinEventHook, которые устанавливают процедуры-перехватчики.	1) очистить конфигурацию Yealink командой «yms-cli config purge --malicious»; 2) удалить неактивных пользователей, учётные записи которых могут быть использованы для повторения атаки SQL-запросом «DELETE FROM user WHERE last_seen > '2024-01-01';»; 3) настроить SIEM-системы или другие средства контроля аутентификации на мониторинг множественных неудачных попыток авторизации; 4) обновить сервер видео-конференц-связи Yealink Meeting Server 26.0.0.67 и ниже для устранения CVE-2024-48352; 5) обновить платформы для мониторинга и наблюдения Grafana версий от 9.1.0 до 9.2.17, от 9.3.0 до 9.3.13, от 9.4.0 до 9.4.9 и РЕД ОС 7.3 для устранения уязвимости CVE-2023-1387.

Продолжение таблицы 102

1	2	3	4
Получение учётных данных	Эксплуатация уязвимостей и ошибок Jenkins HashiCorp Vault Plugin, Git Credential Manager (GCM) или Fleet Server для получения учётных данных для, например, повышения уровня привилегий, что говорит о применении техники T1212, эксплуатирующей уязвимости CVE-2023-33001, CVE-2024-50338 или CVE-2024-52975.	1) деактивировать выданные токены командами «vault lease revoke -prefix auth/token/» для HashiCorp Vault; 2) очистить кэш Git командой «git credential-manager reject --all»; 3) сбросить токены агентов «fleetctl reset-tokens --all» для Fleet Server; 4) проверить и выявить подозрительные скрипты, задачи или процессы: для Jenkins в файле по пути /var/lib/jenkins/jobs/, крон-задачи командой «crontab -l, systemctl list-timers», процессы командой «ps aux | grep -E "vault|git"» и декативировать их для уменьшения ущерба от атаки; 5) установить C2-трафик командами «netstat -tulnp | grep -E "(443|80|22)"» и «tcpdump -i eth0 'dst port 443' -w c2_traffic.pcap» и проверить DNS-запросы командой « tshark -r c2_traffic.pcap -Y "dns && dns.flags.response == 0"»; 6) закрыть процессы, связанные с запуском интерпретаторов командной строки и сценариев из приложения, которые могут быть объектами эксплуатации.	1) интегрировать Защитник Windows/Exploit Guard/Enhanced Mitigation Experience Toolkit для защиты от вредоносной активности, связанной с эксплуатацией уязвимостей; 2) удалить плагин для Jenkins командой «rm -rf /var/lib/jenkins/plugins/hashicorp-vault-plugin/»; 3) отключить Git Credential Manager командой « git config --global --unset credential.helper»; 4) восстановить политики безопасности для HashiCorp Vault командой «vault policy write restricted_policy restricted.hcl»; 5) обновить Jenkins HashiCorp Vault Plugin версии 360.v0a_1c04cf807d для устранения уязвимости CVE-2023-33001; 6) обновить Microsoft Visual Studio и Git версии 2.6.1 и ниже для устранения уязвимости функции strbuf_getdelim_strip_crlf кроссплатформенного фреймворка для хранения учётных данных Git Credential Manager CVE-2024-50338; 7) обновить серверное программное средство управления агентами Elastic Agent Elastic Fleet Server версий от 8.13.0 до 8.15.0 для устранения уязвимости CVE-2024-52975.

Продолжение таблицы 102

1	2	3	4
Организация управления	Использование легитимных средств удалённого доступа или технической поддержки, игнорируемых системами контроля приложений в атакуемой системе, для запуска удалённых сеансов или организации в Drupal Git Utilities или Nextcloud Mail альтернативных каналов связи, что говорит о применении техники T1219, эксплуатирующей уязвимости CVE-2024-12142, CVE-2024-13310, CVE-2024-11053 или CVE-2024-52508.	1) установить и завершить подозрительные сеансы для Linux командами «sudo netstat -tulnp | grep -E "(3389|5900)"» и «sudo kill -9 <PID>», для Windows командами «qwinsta» и «rwinsta <ID>»; 2) запретить выполнение RMM-инструментов (RMM – удалённый мониторинг и управление) командами «New-AppLockerPolicy -RuleType Publisher -ReferenceFile "C:\path\to\teamviewer.exe" -Deny» для Windows и «sudo chattr +i /usr/bin/anydesk» для Linux; 3) отключить Drupal Git Utilities и Nextcloud Mail командами «drush pm-uninstall git_utilities -y» и «sudo -u www-data php occ app:disable mail» соответственно; 4) отследить средствами IPS/IDS анализом трафика сетевые соединения с подозрительными хостами и заблокировать входящий трафик с соответствующих IP-адресов.	1) сбросить конфигурации уязвимого ПО командами «drush config-import» и «sudo -u www-data php occ maintenance:repair»; 2) настроить Zero Trust Network Access, если вместо этого используется RDP или VNC; 3) обновить Modicon M340, BMXNOE0100, BMXNOE0110, BMXNOR0200H версий SV1.70IR26 и ниже для устранения уязвимости микропрограммного обеспечения программируемого логических контроллеров и сетевых модулей CVE-2024-12142; 4) обновить модуль Git Utilities for Drupal CMS-системы Drupal версий 1.0.3 и ниже для устранения уязвимости CVE-2024-13310; 5) обновить Debian GNU/Linux 11/12, Альт 8 СП, cURL версий от 6.5 до 8.11.1, ОСОН Основа Onyx версий 2.13 и ниже для устранения уязвимости обработчика netrc-файлов утилиты командной строки cURL CVE-2024-11053; 6) обновить РЕД ОС 7.3, Nextcloud mail версий от 1.9.0 до 1.15.4, от 2.1.0 до 2.2.11, от 3.1.0 до 3.7.7 для устранения уязвимости клиента электронной почты CVE-2024-52508.

Продолжение таблицы 102

1	2	3	4
Эксфильтрация данных	Эксфильтрация данных из облачных учётных записей в VSPC server machine или Moodle в отдельную подконтрольную злоумышленнику среду, что говорит о применении техники T1537, эксплуатирующей уязвимости CVE-2024-42449 или CVE-2024-48900.	1) провести анализ журналов доступа (VSPC) для обнаружения подозрительной активности; 2) выявить аномальный сетевой трафик с помощью IPS/IDS систем и NGFW и заблокировать входящий трафик с нелегитимных IP-адресов созданием соответствующих правил безопасности; 3) определить эксфильтрованные данные и при необходимости восстановить их из бэкапов; 4) отключить скомпрометированные учётные записи; 5) сменить аутентификационные данные для всех учтёных записей, которые могли быть скомпрометированы; 6) сравнить инфраструктуру облачной среды со стандартной для обнаружения и фиксации изменений, сделанных злоумышленниками.	1) ограничить политики пользовательских учётных записей и управления идентификацией и доступом минимально необходимыми привилегиями; 2) внедрить фильтрацию трафика в сети для запрета передачи данных в недоверенные облачные среды; 3) внедрить шифрование данных в хранилищах с помощью KMS или SSE; 4) ограничить публичный доступ обмена файлами в облачных хранилищах; 5) внедрить DLP системы Symantec DLP или Digital Guardian для обеспечения предотвращения утечек конфиденциальной информации; 6) внедрить EDR/XDR системы CrowdStrike для защиты конечных точек; 7) обновить Moodle версий от 4.4 до 4.4.3 для устранения уязвимости небезопасных прямых ссылок на объекты виртуальной обучающей среды CVE-2024-48900; 8) обновить Veeam Service Provider Console версий 8.1.0.21999 для устранения уязвимости программного средства резервного копирования и восстановления данных для удалённых и облачных клиентов CVE-2024-42449.

Таблица 103 – Организационно-правовой регламент шаблона атаки CAPEC-307

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный доступ	Попытки использовать программную ошибку, временный сбой или неправильную конфигурацию в общедоступном хосте или системе для получения первоначального доступа к системе через Cisco Nexus Dashboard или Copilot Studio, что говорит о применении техники T1091, эксплуатирующей уязвимости CVE-2024-20491 или CVE-2024-43610.	1) выявить посредством анализа трафика источник атаки и заблокировать доступ к уязвимому ПО командами «sudo ufw deny from <IP-адрес атакующего> to any port 443,8443» и «sudo iptables -A INPUT -s <IP-адрес злоумышленника> -j DROP»; 2) остановить уязвимые сервисы командами «sudo systemctl stop nexus-dashboard» и «sudo systemctl stop copilot-studio»; 3) проверить целостность файлов, расположенных на съёмных носителях, восстановить модифицированные файлы с помощью механизмов разграничения доступа закрыть к ним доступ; 4) включить multifactor authentication командой «sudo cpilot-cli --enable-mfa»; 5) сканировать сеть на бкэдоры командами «sudo rkhunter --check», «sudo clamscan -r /» и восстановить конфигурацию Cisco Nexus командой «sudo tar -xzvf /backups/nexus-backup-20240630.tar.gz -C /».	1) обновить Cisco Nexus Dashboard Insights версий от 6.5 до 6.5.1.32 и 6.3 для устранения уязвимости функции ведения журнала веб-интерфейса CVE-2024-20491; 2) обновить графический инструмент для создания и поддержки ИИ Microsoft Copilot Studio патчами с официального сайта разработчика для устранения CVE-2024-43610; 3) отключить автозапуск, если в нём нет необходимости; 4) включить правила Attack Surface Reduction (ASR) в Windows для блокировки неподписанных или недоверенных исполняемых файлов.
Закрепление	Модификация файла SSH *authorized_keys* для добавления собственных открытых ключей авторизации в D-Link DIR-823G, OneDev Git server или SAP Landscape Management, что говорит о применении техники T1098.004, эксплуатирующей уязвимости CVE-2024-44408, CVE-2024-45309 или CVE-2024-39593.	1) проверить файл с ключами SSH на подозрительные записи командами «cat ~/.ssh/authorized_keys», «ls -la ~/.ssh/» и «grep -Ev "^(#|$)" ~/.ssh/authorized_keys | awk '{print $NF}' | sort | uniq -c»; 2) проанализировать логи SSH командами «grep "Accepted publickey" /var/log/auth.log» и «journalctl -u sshd --since "2024-06-30" | grep -i "accepted|failed"»; 3) произвести поиск подозрительных процессов командами «ps aux | grep -E "ssh|wget|curl|nc|ncat|socat"» и «netstat -tulnp | grep -E 'ssh|9999|4444'» и деактивировать их.	1) обновить прошивку маршрутизатора D-Link DIR-823G версии 1.0.2B05_20181207 для устранения уязвимости недостаточной защиты служебных данных CVE-2024-44408; 2) обновить OneDev версий 11.0.8 и ниже для устранения уязвимости CVE-2024-45309; 3. обновить SAP Landscape Management 3.0 для устранения уязвимости CVE-2024-39593; 4) отключить аутентификацию SSH по паролю командой «sudo sed -i 's/^PasswordAuthentication yes/PasswordAuthentication no/' /etc/ssh/sshd_config»; 5) проводить регулярный аудит и контроль целостности файла ключей SSH командой «sudo find / -name "authorized_keys" -exec ls -la {} \;».

Продолжение таблицы 103

1	2	3	4
Предотвращение обнаружения	Использование техники «простукивания» портов для сокрытия открытых портов, обеспечивающих закрепление или управления в Microsoft Office, Cisco Nexus Dashboard Fabric Controller (NDFC) или Cisco Nexus Dashboard Orchestrator (NDO), для открытия динамических прослушивающих портов или установления соединения с атакуемой сетью, что говорит о применении техники T1205.001, эксплуатирующей уязвимости CVE-2024-20490 или CVE-2024-43609.	1) проверить открытые порты и подозрительные соединения командами «sudo netstat -tulnp | grep -E '20490|43609'» и «sudo ss -antp | grep -i "established" | awk '{print $5}' | cut -d: -f2 | sort | uniq -c» и блокировать нелегитимные соединения командами «sudo iptables -A INPUT -p tcp --dport 20490 -j DROP» и «sudo nft add rule ip filter input tcp dport 43609 counter drop»; 2) определить подозрительные процессы командой «ps aux | grep -E "nc|ncat|socat|meterpreter"» для определения источника атаки; 3) остановить уязвимые процессы командами «sudo systemctl stop nexus-ndfc» и «sudo systemctl stop nexus-ndo».	1) обновить Nexus Dashboard Fabric Controller версий от 12.1 до 12.2.2.241, Cisco Nexus Dashboard Orchestrator (NDO) версий от 4.1 до 4.4.1.1012, Cisco Nexus Dashboard 6.3, Cisco Nexus Dashboard версий от 6.5 до 6.5.1.32 для устранения уязвимости функции ведения журнала платформы управления сетевыми ресурсами и средства управления сетью и политиками дата-центров CVE-2024-20490; 2) обновить Microsoft Office до актуальных версий для устранения уязвимости CVE-2024-43609, связанной с недостаточной защитой служебных данных; 3) внедрить fail2ban для мониторинга портов командами «sudo apt install fail2ban» и «sudo nano /etc/fail2ban/jail.local → добавить порты 20490, 43609»; 4) настроить SIEM-оповещения командой «index=network (port=20490 OR port=43609) | stats count by src_ip».

Продолжение таблицы 103

1	2	3	4
Предотвращение обнаружения	Использование уязвимостей Undertow или Veeam Reporter Service для обхода защитных средств обнаружения вторжений, что говорит о применении техники T1211, эксплуатирующей уязвимости CVE-2024-7885 или CVE-2024-42019.	1) проверить логи сервисов Undertow и Veeam Reporter командами «grep -i "undertow" /var/log/wildfly/server.log | grep -E "CVE-2024-7885|exploit"» и «Get-EventLog -LogName Application -Source "VeeamReporter" | Where-Object {$_.Message -match "CVE-2024-42019"}» соответственно; 2) проанализировать сетевой трафик командами «netstat -tulnp | grep -E '8080|8443|9092'» и «ss -antp | grep -i "java|veeam" | grep -v <IP-адрес подсети>»; 3) определить вектор атаки посредством поиска эксплойтов в системе и анализа модифицированных файлов командами «find /tmp /var/tmp -name "*.war" -o -name "*.jsp" -mtime -3» и «rpm -Va | grep -E "undertow|jboss"»/« dpkg -V | grep -i "veeam"» соответственно; 4) изолировать уязвимое ПО командами «sudo systemctl stop wildfly» и «Stop-Service -Name "VeeamReporterSvc" -Force».	1) использовать песочницу для затруднения движения злоумышленников внутри сети за счёт эксплуатации неизвестных уязвимостей; 2) внедрить Enhanced Mitigation Expirience Toolkit для защиты от эксплуатации уязвимостей; 3) обновить Red Hat Single Sign-On 7, Red Hat JBoss Enterprise Application Platform 7, Red Hat Build of Keycloak, Red Hat JBoss Enterprise Application Platform 8, undertow версий 2.3.15 и ниже, Red Hat build of Apache Camel 4.4.2/3.20.7 для устранения уязвимости функции parseProxyProtocolV1() класса ProxyProtocolReadListener веб-сервера Undertow CVE-2024-7885; 4) обновить Veeam ONE версий 12.1.0.3208 и ниже для устранения уязвимости службы программного мониторинга ИТ-инфраструктуры CVE-2024-42019; 5) восстановить систему из бэкапов командой «Restore-VBRBackup -Latest -Confirm:$false»; 6) настроить оповещения SIEM-систем об эксплуатации уязвимостей командой «index=application (source="wildfly" OR source="veeam") AND ("CVE-2024-7885" OR "CVE-2024-42019")».

Продолжение таблицы 103

1	2	3	4
Обнаружение	Использование утилит администрирования операционных систем для сбора информации о VSPC server, SAP Commerce Cloud, LiteSpeed Technologies или Roundcube, что говорит о применении техники T1016, эксплуатирующей уязвимости CVE-2024-38650, CVE-2024-33003, CVE-2024-44000 или CVE-2024-42010.	1) отслеживать вызовы API GetAdaptersInfo() и GetIpNetTable(), с помощью которых можно получить информацию о конфигурации и топологии сети; 2) отслеживать запущенные процессы (например, ipconfig/ifconfig и arp) с аргументами, которые могут использоваться для несанкционированного получения информации о конфигурации сети; 3) выяснить источник атаки с помощью анализа трафика и заблокировать входящий трафик с соответствующих IP-адресов командами «sudo iptables -A INPUT -s <IP-адрес> -j DROP» и «sudo ufw deny from <IP-адрес>»; 4) провести мониторинг бэкдоров системы с помощью fail2ban командой «sudo fail2ban-client set ssh aggressive».	1) обновить Debian GNU/Linux 11/12, РЕД ОС 7.3, RoundCube Webmail версий от 1.6.0 до 1.6.8 и от 1.5.0 до 1.5.8 для устранения уязвимости функции mod_css_styles компонента Cascading Style Sheet Handler почтового клиента CVE-2024-42010; 2) обновить Veeam Service Provider Console версий 8.0.0.19552 и ниже для устранения уязвимости реализации протокола NTLM CVE-2024-38650; 3) обновить SAP Commerce Cloud версий 1811, 1905, 2005, 2011, HY_COM 1808, 2105, 2205, COM_CLOUD 2211 для устранения уязвимости компонента OCC API Endpoint платформ электронной коммерции CVE-2024-33003; 4) обновить LiteSpeed Cache for Wordpress 6.5.0.1 и ниже для устранения уязвимости CVE-2024-44000; 5) внедрить Lynis для включения автоматического аудита системы командой «sudo lynis audit system»; 6) периодически совершать пентесты для тестирования системы на устойчивость к атакам командой «nmap -sV --script=vuln <target_IP> -p 80,443,8080».

Продолжение таблицы 103

1	2	3	4
Обнаружение	Использование открытых окон приложений Oracle, Apache HTTP Server, FortiAIOps или Microsoft Office для определения потенциальных данных для сбора или обнаружения конкретных средств защиты атакуемой системы, что говорит о применении техники T1010, эксплуатирующей уязвимости CVE-2024-21147, CVE-2024-39884, CVE-2024-27784 или CVE-2024-38200.	1) отслеживать вызовы API, например GetForegroundWindow(), с помощью которых можно получить информацию об открытых окнах на рабочем столе; 2) отслеживать выполнение команд с аргументами, которые могут использоваться для извлечения информации о системе и сети; 3) остановить уязвимые сервисы командами «sudo systemctl stop oracle-database» для Oracle, «sudo systemctl stop apache2» для Apache, «sudo systemctl stop fortiaiops» для FortiAIOps, «taskkill /IM "WINWORD.EXE" /F» для Microsoft Office; 4) удалить временные файлы командой «find /tmp /var/tmp -name "*.tmp" -mtime -1 -exec rm -f {} \;».	1. обновить Astra Linux Special Edition 1.6 «Смоленск»/4.7, РЕД ОС 7.3, Альт 8 СП, Альт СП 10, Apache HTTP Server версий от 2.4.60 до 2.4.62, ОСОН Основа Onyx версий 2.11.1 и ниже и версий 2.12 и ниже для устранения уязвимости ядра веб-сервера Apache HTTP Server CVE-2024-39884; 2. обновить FortiAIOps 2.0.0 для устранения уязвимости графического пользовательского интерфейса программного средства выявления угроз безопасности на основе искусственного интеллекта CVE-2024-27784; 3. обновить ПО пакета программ Microsoft Office до актуальных версий для устранения уязвимости CVE-2024-38200, связанной с недостаточной защитой служебных данных; 4. обновить Debian GNU/Linux, РЕД ОС, GraalVM Enterprise Edition, Oracle GraalVM for JDK, Java SE, Axiom AxiomJDK, ОСОН ОСнова Onyx до актуальных версий для устранения уязвимости компонента Hotspot виртуальных машин CVE-2024-21147; 5. внедрить EDR для отслеживания вызова API.

Продолжение таблицы 103

1	2	3	4
Деструктивное воздействие	Шифрование данных DuckDB SQL database, VMware Workspace One UEM, Oracle Retail Xstore Office или Microsoft Outlook с возможным внедрением в шифровальное ПО вредоносного контента, позволяющего распространять его по сети и шифровать большие объёмы данных, для нанесения максимального ущерба атакуемой системе и эксплуатирующей её организации или нарушения доступа к ним с целью вымогательства, что говорит о применении техники T1486, эксплуатирующей уязвимости CVE-2024-41672, CVE-2024-22260, CVE-2024-21136 или CVE-2024-38020.	1) отслеживать выполнение команд с аргументами, которые могут использоваться для уничтожения данных, например vsadmin, wbadmin и bcdedit; 2) провести мониторинг аномальной активности шифрования командами «grep -r "encrypt" /var/log/duckdb/ | grep -i "error|fail"» для DuckDB, «journalctl -u ws1-uem --since "24h ago" | grep -i "encryption|malware"» для VMware Workspace One, «tail -n 100 /opt/oracle/xstore/logs/encryption.log | grep -v "legitimate"» для Oracle Xstore, «Get-WinEvent -LogName "Application" | Where-Object {$_.Message -match "encryption.*malicious"}» для Outlook; 3) идентифицировать зашифрованные компоненты системы и проанализировать сетевой трафик командами «ps aux | grep -E "(openssl|gpg|crypt|sqlcipher)" | grep -v "grep"» и «netstat -tulnp | grep -E "duckdb|vmware|oracle|outlook"» соответственно; 4) отключить уязвимые сервисы командами «sudo systemctl stop duckdb-server» для DuckDB, «sudo systemctl stop ws1-uem» для VMware Workspace One, «sudo systemctl stop xstore-office» для Oracle Xstore.	1) обновить DuckDB версий 1.0.0 и ниже для устранения уязвимости функции sniff_csv() системы управления реляционными базами данных CVE-2024-41672; 2) обновить Workspace ONE UEM версий от 23.10.0 до 23.10.0.13 , от 23.6.0 до 23.6.0.30, от 23.2.0 до 23.2.0.46, от 22.12.0 до 22.12.0.47 для устранения уязвимости системы унифицированного управления конечными точками CVE-2024-22260; 3) обновить Oracle Retail Xstore Office версий 9.0.5, 20.0.3, 20.0.4, 22.0.0, 23.0.1 для устранения уязвимости компонента Security программного обеспечения для торговли CVE-2024-21136; 4) обновить пакет программ Microsoft Office, 365 Apps for Enterprise и Microsoft Office LTSC 2021 до актуальных версий с помощью официального сайта разработчика для устранения уязвимости почтового клиента Outlook CVE-2024-38020; 5) разработать планы аварийного восстановления инфраструктуры, содержащие процедуры регулярного создания и тестирования резервных копий данных и хранить их вне системы под защитой от распространённых методов получения доступа к ним.

Таблица 104 – Организационно-правовой регламент шаблона атаки CAPEC-308

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный доступ	Попытки получения доступа к местным данным сервера и Server-side Request Forgery через библиотеку @solana/web3.js, что говорит о применении техники T1190, эксплуатирующей уязвимостей CVE-2024-55875 и CVE-2024-54134.	1) ограничить соединения к узлам, взаимодействующим с @solana/web3.js созданием правил в брандмауэре для диапазона IP-адресов; 2) блокировка IP-адресов, с которых поступают подозрительные запросы командой «iptables -A OUTPUT -d <IP_ADDRESS> -j DROP».	1) обновить Kotlin HTTP до версии 5.41.0.0, устраняющую уязвимость CVE-2024-55875; 2) обновить библиотеку «@solana/web3.js» до версии 1.95.8 для устранения CVE-2024-54134; 3) автоматизировать процесс анализа логов и подозрительных запросов.
Выполнение	Попытки чтения произвольных свойств файлов в системе Apache OFBiz, маршрутизатора TP-Link TL-WR841N или устройств с ОС семейства macOS/iOS, что говорит о применении техники T1203, эксплуатирующей уязвимостей CVE-2023-50968, CVE-2023-50224 и CVE-2023-42922.	1) поиск в логах подозрительных запросов, после чего командой «ufw deny from <IP_address> to any port 8080» блокировать адрес «отправителя» таких запросов; 2) ограничение прав доступа к атакуемому файлу(ам) командой «sudo chmod 700 /path/to/файл»; 3) на macOS/iOS использовать файл pfctl для настройки брандмауэра и создания соответствующих правил фильтрации трафика.	1) обновить Apache Software Foundation Apache OFBiz до версии 18.12.11 для устранения CVE-2023-50968; 2) загрузить обновления TP-Link TL-WR841N для устранения CVE-2023-50224; 3) обновить ПО установкой: Sonoma 14.2, iOS 17.2 и iPadOS 17.2, macOS Ventura 13.6.3, iOS 16.7.3 и iPadOS 16.7.3, macOS Monterey 12.7.2 для устранения CVE-2023-42922.
Выполнение	Использование функции Edge Panel в Workspace ONE Launcher для обхода ограничений безопасности и получения доступа к защищённым данным внутри домена, что говорит о применении техники T1059, эксплуатирующей уязвимостей CVE-2023-34064 и CVE-2023-47146.	1) ограничить трафик к порту DNS-сервера командой «sudo iptables -A INPUT -p udp --dport 53»; 2) использовать политики безопасности в консоли UEM или MDM-профилей для ограничения функции Edge Panel.	1) обновить IBM Qradar SIEM до версии 7.6 для устранения CVE-2023-47146; 2) задать лимит количества запросов к DNS-серверу в промежуток времени n созданием соответствующих правил безопасности.

Продолжение таблицы 104

1	2	3	4
Получение учётных данных	Попытки внедрения вредоносных документов в Microsoft Word и Outlook обходом механизмов защиты и выполнением несанкционированных HTTP-запросов в urlib3 или DHCP-сервере с целью выполнения произвольного кода или получения доступа к системе, что свидетельствует о применении T1555, эксплуатирующей уязвимости CVE-2023-36009 или CVE-2023-35636, CVE-2023-43804 и CVE-2023-35643.	1) принудительно завершить процессы Word и Outlook командами «taskkill /IM WINWORD.EXE /F» или «taskkill /IM OUTLOOK.EXE /F»; 2) ограничить HTTP трафик или трафик на DHCP-сервер командами «sudo iptables -A INPUT -p tcp --dport 80 (HTTP) (или) 67 (DHCP-сервер)»; 3) остановить подозрительный процесс выполнения произвольного кода командой «pkill *имя_процесса*».	1) обновить Microsoft Outlook и Word для устранения CVE-2023-36009 и CVE-2023-35636; 2) обновить библиотеку Python urlib3 до версии 1.26.17 или 2.0.5 для устранения CVE-2023-43804; 3) загрузить патчи с сайта Microsoft для устранения CVE-2023-35643; 4) автоматизировать процесс анализа HTTP и DHCP трафика созданием соответствующих правил безопасности.
Обнаружение	Атаки на Oracle iSupplier Portal или KVstore в Splunk Secure Gateway app с целью получения несанкционированного доступа или получения конфиденциальных данных, свидетельствующие о применении T1046, эксплуатирующей уязвимости CVE-2023-21825 и CVE-2024-53243.	1) выявить подозрительные соединения командой «netstat -tunap | grep»; 2) блокировать IP-адрес, с которого поступает подозрительный трафик командой «sudo iptables -A INPUT -s <подозрительный_IP> -j DROP»; 3) завершить подозрительный процесс командой «kill –9 <PID>».	1) обновить Oracle Isupplier portal версий 12.2.6-12.2.8 и Oracle E-Business Suite версий 12.2.6-12.2.8 до более новых версий для устранения CVE-2023-21825; 2) не использовать Splunk Enterprise версий ниже 9.3.2, 9.2.4, 9.1.7, Splunk Secure Gateway версий ниже 3.2.462, 3.7.18, 3.8.5 во избежание эксплуатации CVE-2024-53243.
Перемещение внутри периметра	Использование уязвимости в Moodle для несанкционированного перенаправления URL-запросов или уязвимости SAP GUI Windows для получения аутентификационных данных, что свидетельствует о применении T1021, эксплуатирующей уязвимости CVE-2024-39600 и CVE-2024-43432.	1) проанализировать логи для выявления аномальной активности; 2) блокировать подозрительные IP-адреса командой «sudo iptables -A INPUT -s <подозрительный_IP> -j DROP»; 3) изолировать уязвимые процессы Moodle командой «sudo systemctl stop apache2».	1) обновить SAP GUI патчами, загружаемыми с официального сайта разработчика для устранения CVE-2024-39600; 2) обновить Moodle до 4.4.2, 4.3.6, 4.2.9 или 4.1.12 для устранения CVE-2024-43432; 3) использовать IDS/IPS системы для автоматизации процесса анализа трафика.

ЗАКЛЮЧЕНИЕ

По результатам исследования, поставленная во введении данной работы цель была достигнута - защищённость автоматизированных информационных систем была повышена от атак класса «Методы сканирования портов». Достижению данной цели способствовало последовательное получение в ходе выполнения работы следующих результатов:

1) разработана база данных кибератак класса «Методы сканирования портов» на АИС, систематизирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

2) получено векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE, CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

3) сформирована методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Методы сканирования портов» с учётом специфики используемых злоумышленником сценариев;

4) разработан комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы сканирования портов», эксплуатирующих уязвимости АИС.

Открываются дополнительные возможности для достижения цели повышения защищённости автоматизированных информационных систем благодаря полученным результатам оценки рисков успешной реализации атак класса «Методы сканирования портов».

Также результаты данной работы подтверждают важность консолидации шаблонов атак CAPEC, техник MITRE ATT&CK и агрегированных параметров уязвимостей в единое целое. Данный подход обеспечивает более углубленное понимание потенциальных действий злоумышленников при совершении атак класса «Методы сканирования портов» и позволяет разрабатывать результативные превентивные меры, способные снизить риски нарушения безопасности информации.

Для эффективного решения задачи по повышению защищённости автоматизированных информационных систем от кибератак класса «Методы сканирования портов» необходимо применять комплексный подход, подразумевающий под собой последовательность процессов оценки и управления рисками нарушения безопасности, что подтверждает проделанная работа.

Сочетание аналитических и практических методик и высокая степень точности оценки рисков дают возможность применять разработанную методологию для решения широкого спектра задач по обеспечению информационной безопасности. Полученные результаты могут стать основой организации эффективного противодействия в отношении атак класса «Методы сканирования портов» для специалистов по защите информации.

Итак, разработанная методология оценки и управления рисками успешности кибератак класса «Методы сканирования портов» представляет собой эффективный инструмент для повышения защищённости автоматизированных информационных систем. Применение сформированных мер защиты позволяют говорить о повышении способности систем и сетей к противодействию атакам класса «Методы сканирования портов» и снижению связанных с ними рисков.

Кроме того, полученные результаты могут стать основой организации эффективного противодействия в отношении атак класса «Методы сканирования портов» для специалистов по защите информации или быть применены в учебном процессе при выполнении курсовых и дипломных работ по специальностям группы «Информационная безопасность»

СПИСОК ЛИТЕРАТУРЫ

1 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков, Д.С. Покудин, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 219-230.

2 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238.

3 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30.

4 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54.

5 Остапенко А.А. Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, П.А. Меркулов, Н.Д. Никитин, М.О. Титаренко // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 521-542.

6 Остапенко А.А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 543-552.

7 Остапенко Г.А. Актуальность и целеполагание построения автоматизированного атласа кибератак в условиях цифровой трансформации / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко // Вопросы обеспечения безопасности в киберпространстве. Материалы II Всероссийской научно-технической конференции. Махачкала, 2024. С. 263-265.

8 Смирнов В.В. Кибератаки вида «Анализ целевого объекта»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284.

9 Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 285-294.

10 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420.

11 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336.

12 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378.

13 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть III) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, С.В. Безбородых, А.Г. Остапенко, Н.П. Жуков // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 477-488.

14 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть IV) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, С.В. Безбородых, А.Г. Остапенко, Н.П. Жуков // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 489-508.

15 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин,

Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246.

16 Остапенко А.Г. Нейросетевые компетенции и инструменты подготовки специалистов по защите информации / А.Г. Остапенко, Е.А. Москалева, А.П. Васильченко, А.А. Остапенко // Кибернетика и информационная безопасность «КИБ-2024»: Сб. науч. трудов Второй Всероссийской научно-технической конференции. Москва, 2024. С. 266-267.

17 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалёва, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400.

18 Итоги пентестов 2023. – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/research/analytics/results-of-pentests-2023/#id1. – Текст: электронный.

19 M. Almiani. A Systematic Review of Network Reconnaissance Techniques and Their Defenses / M. Almiani // IEEE Access – USA: New-York, 2023. С. 1-11. – Текст: непосредственный.

20 K. Zaffar. The Blind Spots of Risk Calculators in Port Scanning Attacks / K. Zaffar, R. Al-Shaer // ACM Conference on Computer and Communications Security (CCS) – USA: Los-Angeles, 2022. С. 1-9. – Текст: непосредственный.

21 S. M. Milajerdi. Automated Threat Intelligence: Challenges in Mapping Port Scanning to Exploitable Vulnerabilities / S. M. Milajerdi // USENIX Security Symposium – Anaheim: CA, 2023. С. 1-13. – Текст: непосредственный.

22 J. Smith. Operationalizing Defenses Against Port Scanning: Why Current Frameworks Fail / J. Smith, L. Garcia // Journal of Cybersecurity – Great Britain: London, 2024. С. 1-10. – Текст: непосредственный.

23 Security Report 2024. – Элетрон. дан. – Режим доступа: https://www.akamai.com/state-of-the-internet/security-reports. – Текст: электронный.

24 Rapid7 National Exposure Index Report 2024. – Электрон. дан. – Режим доступа: https://www.rapid7.com/research/report/national-exposure-index/. – Текст: электронный.

25 CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

26 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

27 MITRE ATT&CK(PositiveTechnologies). – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

28 MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

29 MITRE ATLAS. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/– Текст: электронный.

30 MITRE ATLAS (ФБИТ ИТМО). – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/– Текст: электронный.

31 CVE. – Электрон. дан. – Режим доступа: https://cve.mitre.org/. – Текст: электронный.

32 CWE - Common Weakness Enumeration. – Электрон. дан. – Режим доступа: https://cwe.mitre.org/index.html. – Текст: электронный.

33 Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat – Текст: электронный.

34 НКЦКИ. – Электрон. дан. – Режим доступа: https://cert.gov.ru/ – Текст: электронный.

35 CISA KEV. – Электрон. дан. – Режим доступа: https://www.cisa.gov/knownexploited-vulnerabilities-catalog– Текст: электронный.

36 NIST NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

37 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss – Текст: электронный.

38 Общая система оценки уязвимостей (CVSS). – Электрон. дан. – Режим доступа: https://www.first.org/cvss/specificationdocument – Текст: электронный.

39 Common Vulnerability Scoring System v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/. – Текст: электронный.

40 Common Vulnerability Scoring System v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/. – Текст: электронный.

41 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp riskrating.com/. – Текст: электронный.

42 SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

43 The Vulnerability Impact Scoring System (VISS). – Электрон. дан. – Режим доступа: https://viss.zoom.com/specifications#2-metrics. – Текст: электронный.

44 VISS калькулятор. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/0.07#VISS:0.07:PLI:NA/ICI:N/III:N/IAI:N/ITN:NA/STN:NA/DTN:NA/TIM:N/DCI:N/DII:N/DAI:N/DCL:N/UCI:NA – Текст: электронный.

45 Калькулятор BVSS. – Электрон. дан. – Режим доступа: https://www.halborn.com/bvss. – Текст: электронный.

46 Healthcare Vulnerability Scoring System (HVSS). – Электрон. дан. – Режим доступа: https://hvss.online/. – Текст: электронный.

47 HVSS v1.0 Documentation. – Электрон. дан. – Режим доступа: https://hvss.online/doc/v1.0/HVSS_v1.0_Documentation.pdf. – Текст: электронный.

48 How Red Hat uses CVSSv3 to Assist in Rating Flaws. – Электрон. дан. – Режим доступа: https://www.redhat.com/en/blog/how-red-hatuses-cvssv3-assist-rating-flaws. – Текст: электронный.

49 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование рискландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203- 210. – Текст: непосредственный.

50 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

51 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

52 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мир ошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

53 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

54 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. -Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

55 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т. 26. Вып. 4. - С.597-602. – Текст: непосредственный.

56 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В.

Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. -С. 235-246. – Текст: непосредственный.

57 Остапенко А.Г. Направление совершенствования нормативно-правового-обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т. 25. Вып. 4. - С.593-598. – Текст: непосредственный.

58 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. - С. 261-276. – Текст: непосредственный.

59 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. - С. 89-106. – Текст: непосредственный.

60 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. -С. 115-128. – Текст: непосредственный.

61 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. - С. 475-484. – Текст: непосредственный.

62 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. -С. 159-178. – Текст: непосредственный.

63 Архипова К.В. Автоматизированная информационная система моделирования эпидемических процессов, порожденных саморазмножающимися и мутирующими вредоносами / К.В. Архипова, А.А. Остапенко, В.В. Сафронова, В.Ю. Остапенко, Ю.Г. Пастернак // Информация и безопасность. 2022. Т. 25. № 3. С. 349-366. – Текст: непосредственный.

64 Остапенко Г.А. Киберполигон как проект управления информационными рисками / Г.А. Остапенко, В.И. Белоножкин, А.А. Остапенко, М.Е. Волкова // Информация и безопасность. 2023. Т. 26. № 1. С. 9-16. – Текст: непосредственный.

65 Остапенко Г.А. Разработка архитектуры киберполигона для повышения качества и результативности учебного процесса в исследовании атак на информационные системы и сети / Г.А. Остапенко, С.С. Куликов, А.В. Коноплин, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. № 1. С. 101-108. – Текст: непосредственный.

66 Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. Т. 26. № 2. С. 169-176. – Текст: непосредственный.

67 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта "безопасный интернет" / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын // Информация и безопасность. 2021. Т. 24. № 2. С. 287-296. – Текст: непосредственный.

68 Сердечный А.Л. Метод информационно-картографического анализа активности группировок хактивистов / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. № 4. С. 587-596. – Текст: непосредственный.

69 Остапенко А.Г. Сетевая вирусология: прогнозирование развития двувирусных эпидемических процессов в сетях. / А.Г. Остапенко, Е.В. Зарочинцев, О.А. Остапенко, К.В. Сибирко, В.В. Сафронова, П.Д. Федоров. // Информация и безопасность. 2021. Т. 24. Вып. 2. - С. 203-222. – Текст: непосредственный.

70 Остапенко А.Г. Картографические модели процессов диффузии вредоносов в сетевом киберпространстве. / А.Г. Остапенко, А.Л. Сердечный, А.А. Остапенко, С.С. Куликов. // Информация и безопасность. 2021. Т. 24. Вып. 2. - С. 281-286. – Текст: непосредственный.

71 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 55-66. – Текст: непосредственный.

72 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 67-80. – Текст: непосредственный.

73 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 81-90. – Текст: непосредственный.

74 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 91-98. – Текст: непосредственный.

75 Золотарев А.А. Сетевые атаки с помощью «сниффер -пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 99-108. – Текст: непосредственный.

76 Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 117-124. – Текст: непосредственный.

77 Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков //

Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 135-142. – Текст: непосредственный.

78 Александров А.Г. Анализ угроз информационной безопасности при использовании облачных сервисов / А.Г. Александров, А.Ю. Петухов, М.Ю. Рытов // Информация и безопасность. 2024. Т. 27. Вып. 1. - С. 143-151. – Текст: непосредственный.

79 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. - С. 185-196. – Текст: непосредственный.

80 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. - С. 197-208. – Текст: непосредственный.

81 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю. Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. - С. 209-218. – Текст: непосредственный.

82 Сердечный А.Л. Информационное картографирование Blockchain транзакций киберпреступников в экосистеме TON / А.Л. Сердечный, А.О. Абрамов, Е.А. Москалева // Информация и безопасность. 2024. Т. 27. Вып. 2. - С. 257-272. – Текст: непосредственный.

83 Громов Ю.Ю. Изучение возможности виртуализации технических средств защиты объектов с применением имитационного моделирования / Ю.Ю. Громов, П.И. Карасев, Ф.М. Пыршев // Информация и безопасность. 2024. Т. 27. Вып. 3. - С. 379-388. – Текст: непосредственный.

84 Подтопельный В.В. Исследование специфики моделирования компьютерных атак с использованием марковских процессов принятий решений и Qобучения / В.В. Подтопельный // Информация и безопасность. 2024. Т. 27. Вып. 3. - С. 421-440. – Текст: непосредственный.

85 Зорин В.А. Информационная безопасность и нейробиология социальной инженерии: когнитивные искажения, эмпатия / В.А. Зорин // Информация и безопасность. 2024. Т. 27. Вып. 3. - С. 441-448. – Текст: непосредственный.

86 Зимницкий А.Г. Программно-технический комплекс выявления субъектов с повышенным риском девиантного поведения / А.Г. Зимницкий, А.А. Остапенко // Информация и безопасность. 2022. Т. 25. № 4. С. 571-582. – Текст: непосредственный.

87 Сердечный А.Л. Информационная карта киберконфликта "палестинаизраиль" / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. № 4. С. 519-534. – Текст: непосредственный.

88 Остапенко А.Г. Целеполагание проектной деятельности по созданию инструментария автоматизированного выявления и риск-анализа деструктивных контентов, аффилированных с персоналом корпораций / А.Г. Остапенко, И.А, Боков, С.В. Лихобабин, Д.С. Ясенко, Е.Ю. Чапурин // Информация и безопасность. 2023. Т. 26. № 4. С. 465-494. – Текст: непосредственный.

89 Остапенко А.А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. № 4. С. 543-552.– Текст: непосредственный.

90 CWE Discovery – Электрон. дан. – Режим доступа: https://hackerone.com/hacktivity/cwe_discovery. – Текст: электронный.

91 Security Breaches in 2024: How ARCON Privileged Access Management (PAM) Could Have Prevented Them – Электрон. дан. – Режим доступа: https://arconnet.com/security-breaches-in-2024-how-arcon-privileged-access-managementpam-could-have-prevented-them. – Текст: электронный.

92 Privileged Accounts, Hidden Threats: Why Privileged Access Security Must Be a Top Priority – Электрон. дан. – Режим доступа: https://thehackernews.com/2024/11/privileged-accounts-hidden-threats-why.html – Текст: электронный.

93 Secure Your Privileged Access: Insights from IBM’s 2024 Cost of A Breach Report – Электрон. дан. – Режим доступа: https://krontech.com/secure-your-privilegedaccess-insights-from-ibm-s-2024-cost-of-a-breach-report – Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица А1 – Паспорт уязвимости CVE-2024-54134

Идентификатор уязвимости	CVE-2024-54134 Уязвимость функции addToQueue() пакета разработки для блокчейн-платформы Solana web3.js связана с недостаточной защитой приватных ключей для доступа к криптокошелькам. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.4) Высокий уровень опасности (оценка CVSS 4.0 составляет 8.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Данные уточняются

Таблица А2 – Паспорт уязвимости CVE-2023-50968

Идентификатор уязвимости	CVE-2023-50968 Уязвимость программного обеспечения планирования ресурсов предприятия Apache OFBiz связана с недостаточной проверкой поступающих запросов. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить SSRF-атаку путём отправки специально сформированного HTTP-запроса
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А3 – Паспорт уязвимости CVE-2023-50224

Идентификатор уязвимости	CVE-2023-50224 Уязвимость компонента dropbearpwd микропрограммного обеспечения маршрутизатора TP-Link TL-WR841N связана с недостатками контроля доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.1) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А4 – Паспорт уязвимости CVE-2023-42922

Идентификатор уязвимости	CVE-2023-42922 Уязвимость компонента Find My операционных систем macOS, iOS, iPadOS и tvOS связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.9) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 5.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А5 – Паспорт уязвимости CVE-2023-47146

Идентификатор уязвимости	CVE-2023-47146 Уязвимость системы сбора и анализа событий безопасности IBM QRadar SIEM связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы А5

Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.6) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 4.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А6 – Паспорт уязвимости CVE-2023-34064

Идентификатор уязвимости	CVE-2023-34064 Уязвимость компонента Edge Panel программного средства запуска приложений VMware Workspace ONE Launcher связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии и получить доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4.6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А7 – Паспорт уязвимости CVE-2023-36009

Идентификатор уязвимости	CVE-2023-36009 Уязвимость текстового редактора Microsoft Word связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А8 – Паспорт уязвимости CVE-2023-35636

Идентификатор уязвимости	CVE-2023-35636 Уязвимость пакетов программ Microsoft Office и Microsoft 365 Apps for Enterprise связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации путем открытия специально созданного файла
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А9 – Паспорт уязвимости CVE-2023-35643

Идентификатор уязвимости	CVE-2023-35643 Уязвимость службы DHCP-сервера операционных систем Windows связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А10– Паспорт уязвимости CVE-2023-43804

Идентификатор уязвимости	CVE-2023-43804 Уязвимость модуля urllib3 интерпретатора языка программирования Python связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Продолжение таблицы А10

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А11 – Паспорт уязвимости CVE-2023-21825

Идентификатор уязвимости	CVE-2023-21825 Уязвимость подкомпонента Supplier Management компонента Oracle iSupplier Portal системы автоматизации деятельности предприятия Oracle E-Business Suite связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить доступ на чтение данных при помощи HTTP-запросов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А12 – Паспорт уязвимости CVE-2024-53243

Идентификатор уязвимости	CVE-2024-53243 Уязвимость средства регистрации мобильных устройств и развертывания мобильных приложений Splunk Secure Gateway платформы для операционного анализа Splunk Enterprise связана с недостаточной защитой служебных данных в результате неправильного разграничения доступа к хранилищу KV Store (Key Value Store),. Эксплуатация уязвимость может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются

Продолжение таблицы А12

Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А13 – Паспорт уязвимости CVE-2024-39600

Идентификатор уязвимости	CVE-2024-39600 Уязвимость графического интерфейса пользователя SAP GUI для Windows связана с отображением пароля, используемого для входа в систему SAP в результате недостаточной защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:H/PR:H/UI:R/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3.8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А14 – Паспорт уязвимости CVE-2024-43432

Идентификатор уязвимости	CVE-2024-43432 Уязвимость виртуальной обучающей среды Moodle связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А15 – Паспорт уязвимости CVE-2024-23280

Идентификатор уязвимости	CVE-2024-23280 Уязвимость модулей отображения веб-страниц WebKitGTK и WPE WebKit связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ к конфиденциальным данным, нарушить их целостность, а также вызвать отказ в обслуживании с помощью специально созданной веб-страницы
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А16 – Паспорт уязвимости CVE-2024-21183

Идентификатор уязвимости	CVE-2024-21183 Уязвимость компонента Core сервера приложений Oracle WebLogic Server связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации с помощью T3/IIOP протоколов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А17 – Паспорт уязвимости CVE-2024-5535

Идентификатор уязвимости	CVE-2024-5535 Уязвимость функции SSL_select_next_proto инструментария для протоколов TLS и SSL OpenSSL связана с раскрытием информации. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, получить доступ к конфиденциальным данным, а также вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Продолжение таблицы А17

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9.4) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А18 – Паспорт уязвимости CVE-2024-21152

Идентификатор уязвимости	CVE-2024-21152 Уязвимость компонента Allocation Rules средства управления финансами Oracle Process Manufacturing Financials системы автоматизации деятельности предприятия Oracle E-Business Suite связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ на чтение, изменение или удаление данных с помощью протокола HTTP
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А19 – Паспорт уязвимости CVE-2023-52237

Идентификатор уязвимости	CVE-2023-52237 Уязвимость веб-серверов микропрограммного обеспечения Ethernet-коммутаторов RUGGEDCOM связана с недостатками разграничения доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к хэшам и паролям всех пользователей системы
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.1) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения

Продолжение таблицы А19

Участие в инцидентах	Данные уточняются

Таблица А20 – Паспорт уязвимости CVE-2024-36986

Идентификатор уязвимости	CVE-2024-36986 Уязвимость модуля Analytics Workspace веб-интерфейса Splunk Web платформы для операционного анализа Splunk Enterprise связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти ограничения безопасности и выполнить произвольные команды путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:L/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А21 – Паспорт уязвимости CVE-2024-4540

Идентификатор уязвимости	CVE-2024-4540 Уязвимость механизма авторизации OAuth 2.0 Pushed Authorization Requests программного средства для управления идентификацией и доступом Keycloak связана с хранением служебных данных в открытом виде в файле cookie KC_RESTART. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации путем отправки запроса request_uri
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А22 – Паспорт уязвимости CVE-2024-54565

Идентификатор уязвимости	CVE-2024-54565 Уязвимость системы обнаружения вирусов XProtect операционных систем macOS связана с недостатками разграничения доступа. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.9) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6.2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А23 – Паспорт уязвимости CVE-2025-30474

Идентификатор уязвимости	CVE-2025-30474 Уязвимость класса FtpFileObject единого API для доступа к различным файловым системам Apache Commons VFS (Virtual File System) связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А24 – Паспорт уязвимости CVE-2024-39822

Идентификатор уязвимости	CVE-2024-39822 Уязвимость программного обеспечения для проведения видеоконференций Zoom Workplace, SDK, клиентах Rooms и контроллерах Rooms связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы А24

Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А25 – Паспорт уязвимости CVE-2024-41066

Идентификатор уязвимости	CVE-2024-41066 Уязвимость функции ibmvnic_xmit() модуля drivers/net/ethernet/ibm/ibmvnic.c ядра операционной системы Linux связана с неправильным освобождением памяти перед удалением последней ссылки («утечка памяти»). Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А26 – Паспорт уязвимости CVE-2025-24071

Идентификатор уязвимости	CVE-2025-24071 Уязвимость проводника Windows (Windows File Explorer) операционных систем Windows связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А27 – Паспорт уязвимости CVE-2024-13131

Идентификатор уязвимости	CVE-2024-13131 Уязвимость камер видеонаблюдения для систем мониторинга и наблюдения IntelBras IP Camera связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.3) Средний уровень опасности (оценка CVSS 4.0 составляет 6.9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А28 – Паспорт уязвимости CVE-2024-45336

Идентификатор уязвимости	CVE-2024-45336 Уязвимость языка программирования Golang связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к учетным данным
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А29 – Паспорт уязвимости CVE-2025-27615

Идентификатор уязвимости	CVE-2025-27615 Уязвимость интерфейса шлюза umatiGateway связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ на чтение и изменение защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:H

Продолжение таблицы А29

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8.5) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 8.2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А30 – Паспорт уязвимости CVE-2024-21685

Идентификатор уязвимости	CVE-2024-21685 Уязвимость программных продуктов для обработки данных Atlassian Jira Data Center и Jira Server связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А31 – Паспорт уязвимости CVE-2024-34510

Идентификатор уязвимости	CVE-2024-34510 Уязвимость пакета Python для создания приложений для моделей машинного обучения Gradio связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ к учетным данным
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А32 – Паспорт уязвимости CVE-2024-53991

Идентификатор уязвимости	CVE-2024-53991 Уязвимость компонента FileStore::LocalStore программного обеспечения управления списком рассылки Discourse связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А33 – Паспорт уязвимости CVE-2025-47969

Идентификатор уязвимости	CVE-2025-47969 Уязвимость функции биометрической проверки подлинности Windows Hello операционных систем Windows связана с ошибками при обработке информации. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.6) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 4.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А34 – Паспорт уязвимости CVE-2025-32044

Идентификатор уязвимости	CVE-2025-32044 Уязвимость виртуальной обучающей среды Moodle связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы А34

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А35 – Паспорт уязвимости CVE-2025-24226

Идентификатор уязвимости	CVE-2025-24226 Уязвимость компонента IDE Assets интегрированной среды разработки Xcode связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4.9) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 5.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А36 – Паспорт уязвимости CVE-2024-49723

Идентификатор уязвимости	CVE-2024-49723 Уязвимость компонента Conscrypt операционной системы Android связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 1.7) Низкий уровень опасности (базовая оценка CVSS 3.1 составляет 3.3) Средний уровень опасности (оценка CVSS 4.0 составляет 4.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А37 – Паспорт уязвимости CVE-2025-5064

Идентификатор уязвимости	CVE-2025-5064 Уязвимость программного интерфейса Background Fetch API браузера Google Chrome связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию с помощью специально созданной HTML-страницы
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.4) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 5.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А38 – Паспорт уязвимости CVE-2025-5054

Идентификатор уязвимости	CVE-2025-5054 Уязвимость функции _check_global_pid_and_forward службы регистрации ошибок apport операционной системы Ubuntu связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3.8) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 4.7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А39 – Паспорт уязвимости CVE-2024-45245

Идентификатор уязвимости	CVE-2024-45245 Уязвимость платформы для управления и мониторинга терминалами Vynamic View связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.8)

Продолжение таблицы А39

Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А40 – Паспорт уязвимости CVE-2025-24899

Идентификатор уязвимости	CVE-2025-24899 Уязвимость программного инструмента для автоматизированной разведки веб-приложений reNgine связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6.8) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6.5) Высокий уровень опасности (оценка CVSS 4.0 составляет 7.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А41 – Паспорт уязвимости CVE-2024-31817

Идентификатор уязвимости	CVE-2024-31817 Уязвимость функции getSysStatusCfg микропрограммного обеспечения роутеров TOTOLINK EX200 связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Данные уточняются

Таблица А42 – Паспорт уязвимости CVE-2024-29960

Идентификатор уязвимости	CVE-2024-29960 Уязвимость программного обеспечения для управления сетью Brocade SANnav связана с использованием жестко закодированных учетных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить атаку «человек посередине» (MITM) и расшифровать SSH-трафик
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.7) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А43 – Паспорт уязвимости CVE-2025-3035

Идентификатор уязвимости	CVE-2025-3035 Уязвимость браузера Mozilla Firefox связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А44 – Паспорт уязвимости CVE-2025-29805

Идентификатор уязвимости	CVE-2025-29805 Уязвимость почтового клиента Microsoft Outlook for Android связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы А44

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А45 – Паспорт уязвимости CVE-2025-24204

Идентификатор уязвимости	CVE-2025-24204 Уязвимость операционной системы macOS связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А46 – Паспорт уязвимости CVE-2024-8884

Идентификатор уязвимости	CVE-2024-8884 Уязвимость приложения для системного мониторинга System Monitor промышленных ПК Harmony Industrial PC серий HMIBMO/HMIBMI/HMIPSO/HMIBMP/HMIBMU/HMIPSP/HMIPEP связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть учетные данные
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Данные уточняются

Таблица А47 – Паспорт уязвимости CVE-2023-32191

Идентификатор уязвимости	CVE-2023-32191 Уязвимость программного обеспечения управления кластерами Kubernets Rancher связана с отсутствием ограничения доступа к защищаемой информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемые данные и получить административный контроль над кластером Kubernetes
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 10)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А48 – Паспорт уязвимости CVE-2024-30300

Идентификатор уязвимости	CVE-2024-30300 Уязвимость сервера автоматизации процесса публикации и управления содержимым документов Adobe FrameMaker Publishing Server (FMPS) связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А49 – Паспорт уязвимости CVE-2024-42256

Идентификатор уязвимости	CVE-2024-42256 Уязвимость функции smb2_async_writev() (fs/smb/client/smb2pdu.c) ядра операционной системы Linux связана с некорректным управлением ресурсом в результате повторного выбора сервера при повторной попытке подзапроса. Эксплуатация уязвимости может позволить нарушителю оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации

Продолжение таблицы А49

Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А50 – Паспорт уязвимости CVE-2025-31225

Идентификатор уязвимости	CVE-2025-31225 Уязвимость модуля Call History операционных систем iPadOS и iOS связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А51 – Паспорт уязвимости CVE-2025-22218

Идентификатор уязвимости	CVE-2025-22218 Уязвимость инструмента для анализа сетевых журналов VMware Aria Operations for Logs связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.1) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А52 – Паспорт уязвимости CVE-2025-29846

Идентификатор уязвимости	CVE-2025-29846 Уязвимость операционной системы Synology Router Manager (SRM) связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А53 – Паспорт уязвимости CVE-2024-29958

Идентификатор уязвимости	CVE-2024-29958 Уязвимость программного обеспечения для управления сетью Brocade SANnav связана с недостаточной защитой регистрационных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А54 – Паспорт уязвимости CVE-2024-29966

Идентификатор уязвимости	CVE-2024-29966 Уязвимость программного обеспечения для управления сетью Brocade SANnav связана с использованием жестко закодированных учетных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить учетные данные пользователя с правами root
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы А54

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А55 – Паспорт уязвимости CVE-2024-29156

Идентификатор уязвимости	CVE-2024-29156 Уязвимость компонента YAQL интерфейса для управления конфигурацией сервисов в облачной платформе OpenStack Murano связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.2) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А56 – Паспорт уязвимости CVE-2024-24919

Идентификатор уязвимости	CVE-2024-24919 Уязвимость межсетевых экранов Check Point Quantum Gateway и Check Point Spark, комплексной системы безопасности CloudGuard Network связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А57 – Паспорт уязвимости CVE-2023-24838

Идентификатор уязвимости	CVE-2023-24838 Уязвимость системы балансировки сетевой нагрузки PowerStation связана с отсутствием аутентификации для критичной функции в результате недостаточной защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации, выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А58 – Паспорт уязвимости CVE-2023-1174

Идентификатор уязвимости	CVE-2023-1174 Уязвимость инструмента настройки среды Kubernetes для разработки и тестирования приложений minikube связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить доступ к контейнеру
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А59 – Паспорт уязвимости CVE-2023-23397

Идентификатор уязвимости	CVE-2023-23397 Уязвимость почтового клиента Microsoft Outlook связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии путем отправки специально сформированного письма электронной почты
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Продолжение таблицы А59

Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А60 – Паспорт уязвимости CVE-2024-48352

Идентификатор уязвимости	CVE-2024-48352 Уязвимость сервера видео-конференц-связи Yealink Meeting Server связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ к учетным данным
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А61 – Паспорт уязвимости CVE-2023-1387

Идентификатор уязвимости	CVE-2023-1387 Уязвимость платформы для мониторинга и наблюдения Grafana связана с возможностью искать JWT в параметре URL-запроса auth_token и использовать его в качестве токена аутентификации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А62 – Паспорт уязвимости CVE-2023-33001

Идентификатор уязвимости	CVE-2023-33001 Уязвимость плагина Jenkins HashiCorp Vault Plugin связана с раскрытием информации через регистрационные файлы. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А63 – Паспорт уязвимости CVE-2024-50338

Идентификатор уязвимости	CVE-2024-50338 Уязвимость функции strbuf_getdelim_strip_crlf кроссплатформенного фреймворка для хранения учётных данных Git Credential Manager (GCM) распределенной системы управления версиями Git связана с несоответствием обработки новой строки между Git и GCM. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию, перенаправив пользователя на произвольный URL-адрес
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А64 – Паспорт уязвимости CVE-2024-52975

Идентификатор уязвимости	CVE-2024-52975 Уязвимость серверного программного средства управление агентами Elastic Agent Elastic Fleet Server связана с недостатками контроля доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Продолжение таблицы А64

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.7) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А65 – Паспорт уязвимости CVE-2024-12142

Идентификатор уязвимости	CVE-2024-12142 Уязвимость микропрограммного обеспечения программируемого логического контроллера Schneider Electric Modicon M340 и сетевых модулей BMXNOE0100, BMXNOE0110 и BMXNOR0200H связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ на чтение, изменение или удаление данных или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 8.6) Высокий уровень опасности (оценка CVSS 4.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Данные уточняются

Таблица А66 – Паспорт уязвимости CVE-2024-13310

Идентификатор уязвимости	CVE-2024-13310 Уязвимость модуля Git Utilities for Drupal CMS-системы Drupal связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ на чтение, изменение или удаление данных или выполнить произвольный код
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:R/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 8.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются

Продолжение таблицы А66

Участие в инцидентах	Данные уточняются

Таблица А67 – Паспорт уязвимости CVE-2024-11053

Идентификатор уязвимости	CVE-2024-11053 Уязвимость обработчика netrc-файлов утилиты командной строки cURL связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ к учётным данным при условии HTTP-перенаправления на другой ресурс
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9.4) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А68 – Паспорт уязвимости CVE-2024-52508

Идентификатор уязвимости	CVE-2024-52508 Уязвимость клиента электронной почты Nextcloud mail связана с некорректной автоматической настройкой. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.3) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А69 – Паспорт уязвимости CVE-2024-42449

Идентификатор уязвимости	CVE-2024-42449 Уязвимость программного средства резервного копирования и восстановления данных для удалённых и облачных клиентов Veeam Service Provider Console (VSPC) связана с ошибками разграничения доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, удалять произвольные файлы на сервере VSPC
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А70 – Паспорт уязвимости CVE-2024-48900

Идентификатор уязвимости	CVE-2024-48900 Уязвимость виртуальной обучающей среды Moodle связана с использованием небезопасных прямых ссылок на объекты в результате некорректного разграничения доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А71 – Паспорт уязвимости CVE-2024-43610

Идентификатор уязвимости	CVE-2024-43610 Уязвимость графического инструмента для создания и поддержки искуственного интелекта Microsoft Copilot Studio связана с с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

Продолжение таблицы А71

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А72 – Паспорт уязвимости CVE-2024-44408

Идентификатор уязвимости	CVE-2024-44408 Уязвимость микропрограммного обеспечения маршрутизаторов D-Link DIR-823G связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Данные уточняются

Таблица А73 – Паспорт уязвимости CVE-2024-45309

Идентификатор уязвимости	CVE-2024-45309 Уязвимость платформы совместной разработки OneDev связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, читать произвольные файлы
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А74 – Паспорт уязвимости CVE-2024-39593

Идентификатор уязвимости	CVE-2024-39593 Уязвимость компонента REST Provider Definition Response программного обеспечения для управления SAP-системами SAP Landscape Management связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:R/S:C/C:H/I:L/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А75 – Паспорт уязвимости CVE-2024-20490

Идентификатор уязвимости	CVE-2024-20490 Уязвимость функции ведения журнала платформы управления сетевыми ресурсами Cisco Nexus Dashboard Fabric Controller (NDFC) и средства управления сетью и политиками дата-центров Cisco Nexus Dashboard Orchestrator (ранее Cisco Multi-Site Orchestrator) связана с раскрытием информации через регистрационные файлы журнала. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А76 – Паспорт уязвимости CVE-2024-43609

Идентификатор уязвимости	CVE-2024-43609 Уязвимость пакетов программ Microsoft Office и Microsoft 365 Apps for Enterprise связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, проводить спуфинг-атаки
Идентификатор типа ошибки	CWE-200

Продолжение таблицы А76

Базовый вектор уязвимости	CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А77 – Паспорт уязвимости CVE-2024-7885

Идентификатор уязвимости	CVE-2024-7885 Уязвимость функции parseProxyProtocolV1() класса ProxyProtocolReadListener веб-сервера Undertow связана с асинхронизацией запросов и ответов при обработке параметра StringBuilder. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А78 – Паспорт уязвимости CVE-2024-42019

Идентификатор уязвимости	CVE-2024-42019 Уязвимость службы Veeam Reporter Service программного средства мониторинга ИТ-инфраструктуры Veeam ONE связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А79 – Паспорт уязвимости CVE-2024-38650

Идентификатор уязвимости	CVE-2024-38650 Уязвимость реализации протокола NTLM программного средства резервного копирования и восстановления данных для удалённых и облачных клиентов Veeam Service Provider Console (VSPC) связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, обойти процедуру аутентификации и получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А80 – Паспорт уязвимости CVE-2024-33003

Идентификатор уязвимости	CVE-2024-33003 Уязвимость компонента OCC API Endpoint платформ электронной коммерции SAP Commerce Cloud связана с ошибками при обработке информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации или оказать воздействие на целостность данных
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9.4) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9.1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А81 – Паспорт уязвимости CVE-2024-44000

Идентификатор уязвимости	CVE-2024-44000 Уязвимость плагина LiteSpeed Cache for WordPress (LSCWP) системы управления содержимым сайта WordPress связана с недостатками разграничения доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к файлу журнала отладки «/wp-content/debug.log»

Продолжение таблицы А81

Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А82 – Паспорт уязвимости CVE-2024-42010

Идентификатор уязвимости	CVE-2024-42010 Уязвимость функции mod_css_styles компонента Cascading Style Sheet Handler почтового клиента RoundCube связана с недостаточной фильтрацией последовательности токенов каскадных таблиц стилей (CSS) в отображаемых сообщениях электронной почты. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть конфиденциальную информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А83 – Паспорт уязвимости CVE-2024-21147

Идентификатор уязвимости	CVE-2024-21147 Уязвимость компонента Hotspot виртуальных машин Oracle GraalVM Enterprise Edition, Oracle GraalVM for JDK и программной платформы Oracle Java SE связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ на чтение или изменение данных
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.1) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются

Продолжение таблицы А83

Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А84 – Паспорт уязвимости CVE-2024-39884

Идентификатор уязвимости	CVE-2024-39884 Уязвимость ядра веб-сервера Apache HTTP Server связана с использованием устаревшей конфигурации обработчиков. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А85 – Паспорт уязвимости CVE-2024-27784

Идентификатор уязвимости	CVE-2024-27784 Уязвимость графического пользовательского интерфейса программного средства выявления угроз безопасности на основе искусственного интеллекта FortiAIOps связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию, хранящуюся в конечных точках API и журналах
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А86 – Паспорт уязвимости CVE-2024-38200

Идентификатор уязвимости	CVE-2024-38200 Уязвимость пакетов программ Microsoft Office и Microsoft 365 Apps for Enterprise связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, реализовать спуфинг атаку при условии перехода пользователя по ссылке и открытии им специально сформированного файла
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А87 – Паспорт уязвимости CVE-2024-41672

Идентификатор уязвимости	CVE-2024-41672 Уязвимость функции sniff_csv() системы управления реляционными базами данных DuckDB связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А88 – Паспорт уязвимости CVE-2024-22260

Идентификатор уязвимости	CVE-2024-22260 Уязвимость системы унифицированного управления конечными точками VMware Workspace ONE UEM связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Продолжение таблицы А88

Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.1) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А89 – Паспорт уязвимости CVE-2024-21136

Идентификатор уязвимости	CVE-2024-21136 Уязвимость компонента Security программного обеспечения для торговли Oracle Retail Xstore Office связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8.6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются

Таблица А90 – Паспорт уязвимости CVE-2024-38020

Идентификатор уязвимости	CVE-2024-38020 Уязвимость почтового клиента Microsoft Outlook связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, осуществлять спуфинг-атаки
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7.8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6.5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Данные уточняются